



Microsoft Cybersecurity Reference Architectures (MCRA)

Plan your end-to-end security
architecture using Zero Trust principles

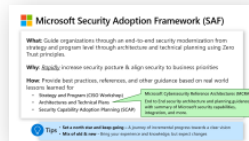
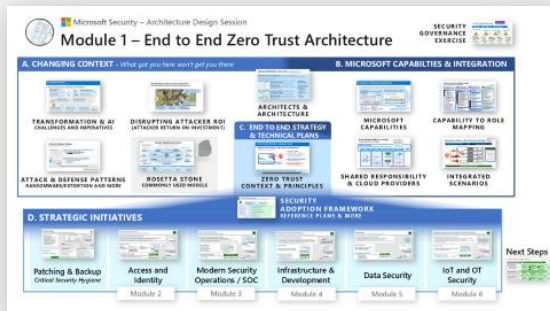
Top End to End Security Challenges

- Incomplete or network-centric architectures aren't agile & can't keep up with continuous change (security threats, technology platform, and business requirements)
- Challenges with
 - Creating integrated end to end architecture
 - Integrating security technologies
 - Planning and prioritizing security modernization initiatives

MCRA Agenda

- Overview of Security Adoption Framework and end to end cybersecurity architecture
 - **End to End Security:** Consider the whole problem
 - **Ruthlessly Prioritize:** Identify top gaps + quick wins
 - **Get started:** Start somewhere & continuously improve
- Antipatterns and best practices
- Guiding rules and laws for security
- Diagrams and references
Applying Zero Trust principles

MCRA is a subset of the full Security Architecture Design Session (ADS) module 1 workshop:



SAF Overview





Discussion – Current Security Architecture

Business and Technical Drivers

- What is top of mind for business stakeholders?
- What risks are important to the business?
- Business/technology initiatives driving change?
- What metrics are important to your program?



Geography and Cloud Usage

- Where does your organization operate?
- Which workloads are in the cloud? Which major cloud providers? (SaaS, PaaS, IaaS)

Architecture, Policy, and Collaboration

Describe how teams work together on end to end security + guiding documents/artifacts

- Enterprise-wide security architecture approach and documentation
- Policy update, monitoring, and related governance processes
- Posture and vulnerability management processes
- Technical collaboration processes (e.g. sharing learnings, joint technical planning, etc. with security operations, architects, engineers, posture management, governance, others)
- Differences between on premises vs. cloud processes



Compliance

Large & notable regulatory requirements



Threats

What types of attack techniques and threat actors are top of mind?

Security Adoption Framework (SAF)



End to end reference strategy, architecture, & implementation using Zero Trust principles



Business Scenarios

Desired Outcomes

I want to rapidly and securely adopt AI

I want people to do their job securely from anywhere

I want to minimize business damage from security incidents

I want to identify and protect critical business assets

I want to continuously improve security posture and compliance



Security Disciplines – *Security planning and execution*



Planning and Oversight



Strategy, Integration, and Governance



End to End Security Architecture



Technical Strategy



Access and Identity



Infrastructure Security



Development Security



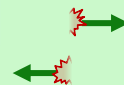
Data Security



OT and IoT Security



Operational Disciplines



Security Operations (SecOps/SOC)

Security Posture Management

Artificial Intelligence (AI)



Technology

Implementation



Endpoints



Identities



Network



Apps



AI



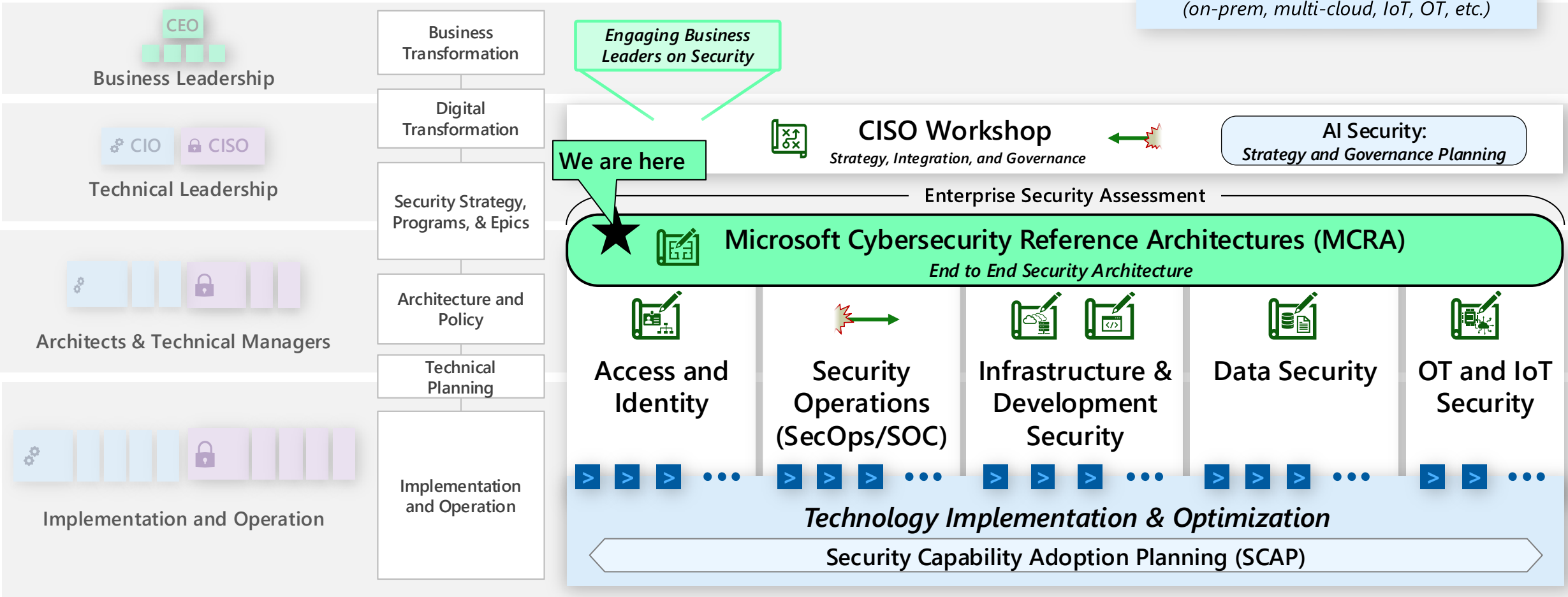
Data



Infrastructure

SAF Workshops

Accelerate Zero Trust security modernization with Microsoft Unified Engagements



Workshops available as Microsoft Unified Engagements
Contact your account manager for more information and to schedule a workshop (full titles in slide notes)

Classic security includes broken assumptions

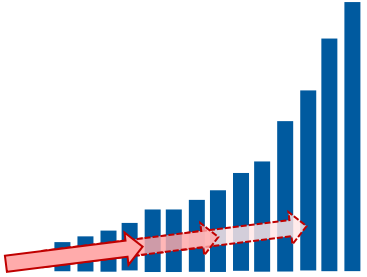
Security is part of everyone's job
~~the security team's job~~

Assets must be protected wherever they are
~~behind the security perimeter are safe~~

Zero Trust is built on practical assumptions

Security must be integrated

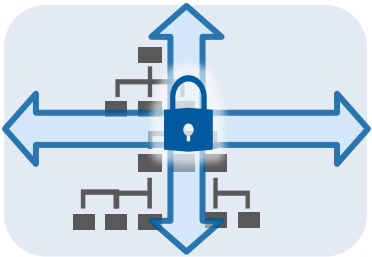
and stay on a journey of continuous improvement



Attackers are practical

Prefer cheapest/easiest options, but often willing and able to go further and spend more

Assets must be protected
wherever they are



Security is a Team Sport

...because **anyone in the organization** can create organizational risk

- **Individuals** – Click link, share sensitive data or passwords, etc.
- **Leaders** – Set restrictive budget / revenue targets that prevent security controls

Security is part of
everyone's job

Common Security Antipatterns - Technical Architecture

Common mistakes that impede security effectiveness and increase organizational risk



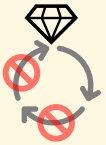
Disconnected security approach

Independent security teams, strategies, tech, and processes for network, identity, devices, etc.



Off-balance Security

Try to block everything or focusing only on SecOps/SOC



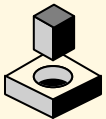
Lack of commitment to lifecycle

Treating security controls and processes as points in time instead of an ongoing lifecycle



Skipping basic maintenance

Skipping backups, disaster recovery exercises, and software updates/patching on assets



Securing cloud like on-premises

Attempting to force on-prem controls and practices directly onto cloud resources



Wasting resources on legacy

Legacy system maintenance and costs draining ability to effectively secure business assets

Best Practices

Develop and implement an **end to end technical security strategy** focused on durable capabilities and Zero Trust Principles

This workshop helps you define and rapidly improve on best practices across security including:

- **Asset-centric security** aligned to business priorities & technical estate (beyond network perimeter)
- **Consistent principle-driven approach** throughout security lifecycle
- **Pragmatic prioritization** based on attacker motivations, behavior, and return on investment
- **Balance investments** between preventing incidents and responding to the incident that happen (SecOps/SOC)
- **'Configure before customize'** approach that embraces automation, innovation, and continuous improvement
- **Security is a team sport** across security, technology, and business teams

Security Success

Invest intentionally into providing these durable outcomes



Attacker Failure + Increased Attacker Cost/Friction

Block Cheap and Easy Attacks

Increase cost and friction for well known & proven attack methods (or easy to block options)

Find and kick them out fast

Reduce dwell time (mean time to remediate) with rapid detection and remediation

'Left of Bang'

'Right of Bang'

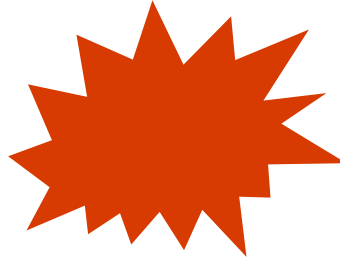
Feedback, Collaboration, and Continuous Improvement

Improving Resiliency

Enable business mission while continuously increasing security assurances

'Left of Bang'

Prevent or lessen impact of attacks



'Right of Bang'

Rapidly and effectively manage attacks



The job will never be 'done' or 'perfect', but it's important to keep doing (like cleaning a house)

[NIST Cybersecurity Framework v2](#)

End to End Security

Enable business mission and increasing security assurances with intentional approach

Security Strategy and Program

Zero Trust Architecture

Security Posture Management

Modern Security Operations (SecOps/SOC)

Access and Identity

Infrastructure & Development Security

OT and IoT Security

Data Security

'Left of Bang'

Prevent or lessen impact of attacks

'Right of Bang'

Rapidly and effectively manage attacks



IDENTIFY

PROTECT

DETECT

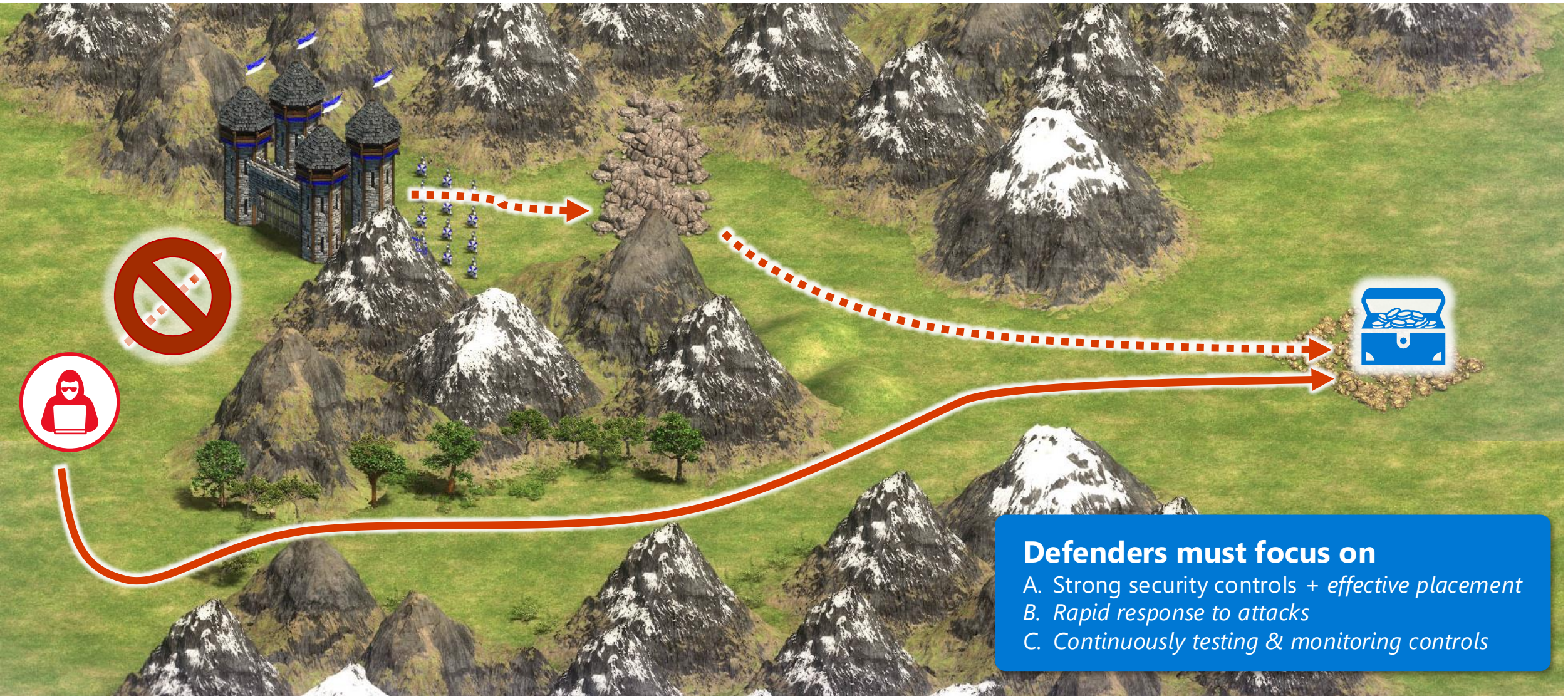
RESPOND

RECOVER

GOVERN

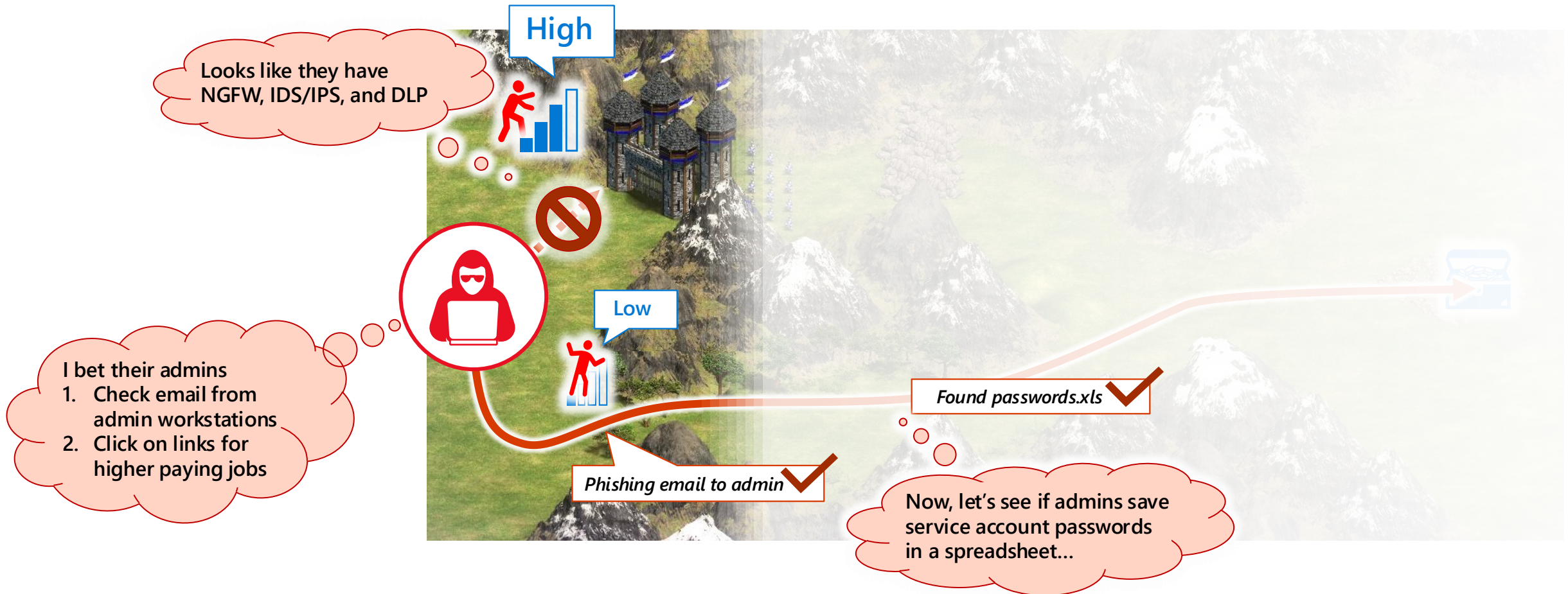
Attackers choose the path of least cost/resistance

Antipattern: Believing attackers will follow the planned path



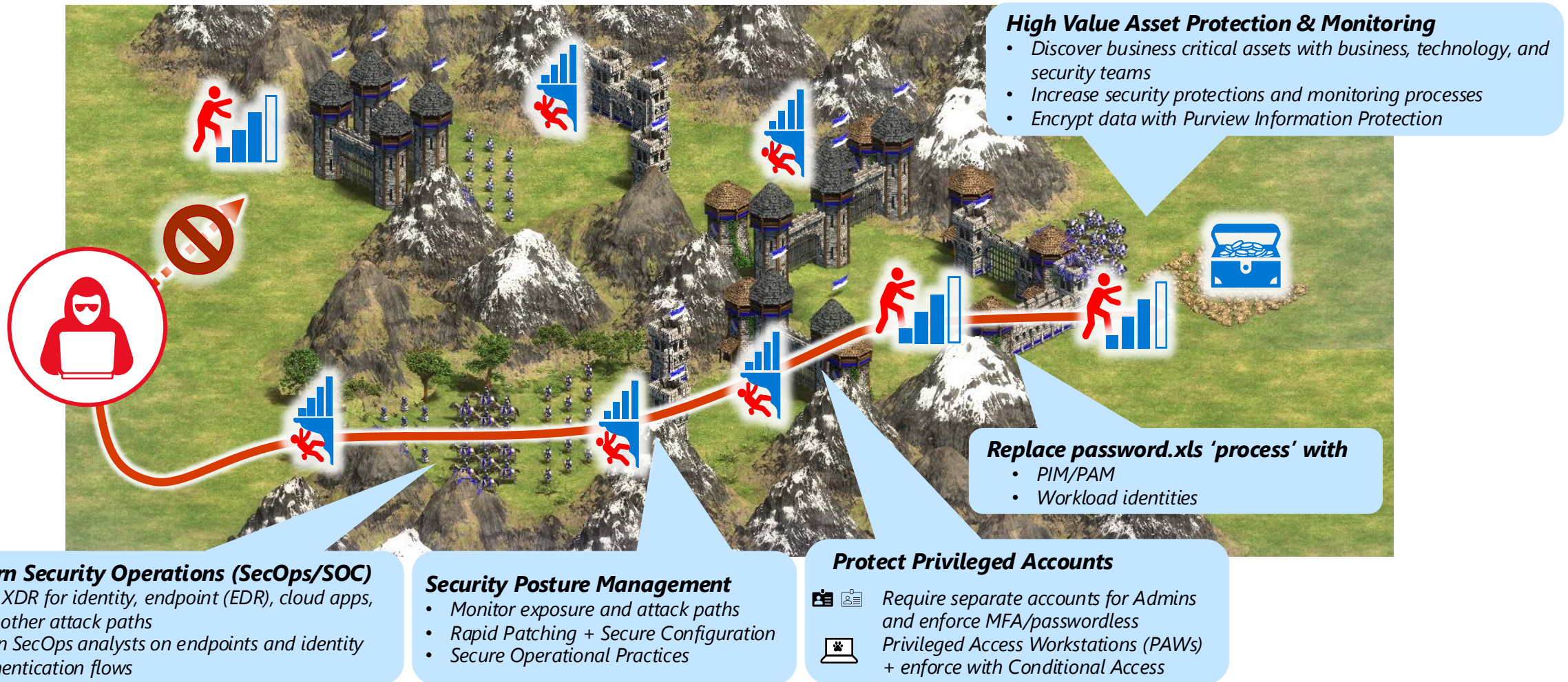
Attacker Perspective: shaped by experience & 'fog of war'

Attackers use what they see, know, and can guess



Strategically position security investments

Raise cost and friction on attacker's easiest and highest impact paths



Goal: Zero Assumed Trust

Reduce risk by finding and removing implicit assumptions of trust

False Assumptions

of implicit or explicit trust

Security is the opposite of productivity

All attacks can be prevented

Network security perimeter will keep attackers out

Passwords are strong enough

IT Admins are safe

IT Infrastructure is safe

Developers always write secure code

The software and components we use are secure



With 30+ years of backlog at most organizations, it will take a while to burn down the backlog of assumed trust

Zero Trust Mitigation

Systematically Build & Measure Trust

Business Enablement

Align security to the organization's mission, priorities, risks, and processes

Assume Compromise

Continuously reduce blast radius and attack surface through prevention and detection/response/recovery

Shift to Asset-Centric Security Strategy

Revisit how to do access control, security operations, infrastructure and development security, and more

Explicitly Validate Account Security

Require MFA and analyze all user sessions with behavior analytics, threat intelligence, and more

Plan and Execute Privileged Access Strategy

Establish security of accounts, workstations, and other privileged entities (aka.ms/spa)

Validate Infrastructure Integrity

Explicitly validate trust of operating systems, applications, services accounts, and more

Integrate security into development process

Security education, issue detection and mitigation, response, and more

Supply chain security

Validate the integrity of software and hardware components from open source, vendors, and others



Zero Trust Security Architecture

End to End Prioritized Execution + Continuous Improvement

1. Look End to End: Consider the whole security problem

OBSERVE, ORIENT



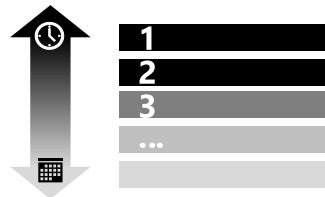
Security is complex and challenging



Resilience required across the lifecycle

2. Ruthlessly Prioritize: Identify top gaps + quick wins

DECIDE



Focus on prevalent attacks and use data



Disrupt attacker return on investment (ROI)

3. Get started: Start somewhere and continuously improve

ACT



Microsoft Security Adoption Framework



Leverage reference plans and architectures

Guiding Rulesets for End to End Architecture

Zero Trust Commandments
Standardized Rules for Zero Trust security

Assume Success  Assume Failure

Practice Deliberate Security
Establishes pragmatic view of 'trust' in today's world of continuous threats + how to prioritize applying that in a world of complex and continuously changing requirements

- Secure Assets by Organizational Risk
- Validate Trust Explicitly

Develop a Security-Centric Culture
Guides the application of security across all teams

- Practice Accountability
- Enable Pervasive Security
- Utilize Least Privilege
- Deploy Simple (User-Friendly) Security

Support Business Objectives
Aligns security explicitly to business priorities and assets (vs. networks) and considers long term implications

- Enable the Organization's Mission
- Implement Asset-Centric Controls
- Enable Sustainable Security

Deploy Agile and Adaptive Security
Ensures security can keep up with continuous change

- Make Informed Decisions
- Improve and Evolve Security Controls
- Utilize Defense in Depth
- Enable Resiliency

From publications.opengroup.org/c247

Zero Trust Commandments

Requirements that represent best practices for a Zero Trust Architecture (ZTA) and transformation. (The Open Group Standard)

Usage: General planning + Testing whether something is 'Zero Trust' or not

10 Laws of Cybersecurity Risk

aka.ms/SecurityLaws

- 1 Security success is attacker failure (ruin their ROI)
- 2 Not keeping up is falling behind
- 3 Security is a business enabler (Productivity always wins)
- 4 Attackers don't care
- 5 Ruthless Prioritization is a survival skill
- 6 Cybersecurity is a team sport
- 7 Your network isn't as trustworthy as you think it is
- 8 Isolated networks aren't automatically secure
- 9 Encryption alone isn't a data protection solution
- 10 Technology doesn't solve people & process problems

10 Laws of Cybersecurity Risk

Key truths about managing security risk that bust common myths.

Usage: Ensuring security strategy, controls, and risk are managed with realistic understanding of how attacks, humans, and technology work

Immutable Laws of Security

aka.ms/SecurityLaws

- 1 If a bad actor can persuade you to run their program on your computer, it's not solely your computer anymore.
- 2 If a bad actor can alter the operating system on your computer, it's not your computer anymore.
- 3 If a bad actor has unrestricted physical access to your computer, it's not your computer anymore.
- 4 If you allow a bad actor to run active content in your website, it's not your website anymore.
- 5 Weak passwords trump strong security.
- 6 A computer is only as secure as the administrator is trustworthy.
- 7 Encrypted data is only as secure as its decryption key.
- 8 An out-of-date antimalware scanner is only marginally better than no scanner at all.
- 9 Absolute anonymity isn't practically achievable, online or offline.
- 10 Technology isn't a panacea.

Immutable Laws of Security

Key truths about security claims and controls that bust common myths.

Usage: Validating design of security controls, systems, and processes to ensure they are technically sound

Business Enablement | Assume Compromise | Verify Explicitly | Use Least Privilege Access

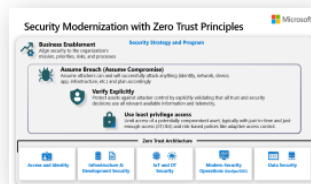
Planning and Oversight

Threat Environment



Attack Chain Mapping

Zero Trust



NIST ZT Mapping

People



Role/Product Mapping

Artificial Intelligence (AI)



Security Capabilities



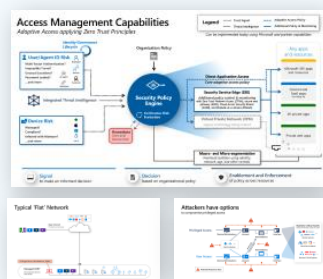
Build Slide M365 E5

Standards



Open Standards Mapping & Compliance Features

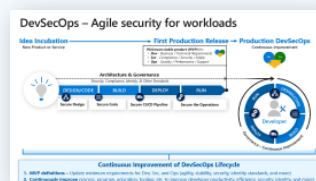
Access and Identity



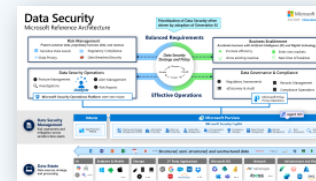
Infrastructure Security



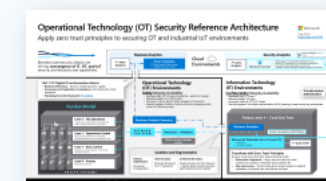
Development Security



Data Security



OT & IoT Security

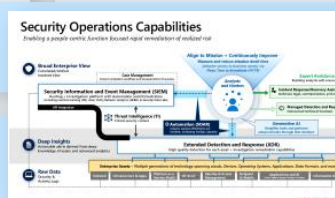


Technical Strategy Disciplines



Next Steps →

Security Posture Management



Security Operations (SecOps/SOC)

Operational Disciplines

Speaker notes & change history

Where do you want to go next?

Engagements help navigate the vast complexity of security

- Recommend combination of:
- Context – Strategy/Architecture
 - Action – Technical Implementation

What do we own? Are we using it?

Capabilities Review

Security Capability Adoption Planning (SCAP)

How are we doing today?

End to End Security Assessment

Enterprise Security Assessment (ESA)

Strategic Security Integration

Security Strategy
and Program



End to End Security Architecture
Microsoft Cybersecurity Reference Architectures (MCRA)

Technical Architecture and Planning

Access and
Identity

Security
Operations
(SecOps/SOC)

Infrastructure &
Development
Security

Data Security

Microsoft Product and Technology Implementation



Defender



Purview



Entra



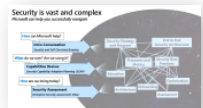
Sentinel



Security Copilot



Intune



Security
Modernization
Journey

Let's get next steps locked in

Capture actions and who follows up on them

#	Next Step	Point of Contact
1		
2		
3		
4		
5		

Standards Mapping

References

Key Industry References and Resources

**The Open Group**

- Zero Trust Components Standard - <https://pubs.opengroup.org/standards/zero-trust-components>
- Zero Trust Reference Model - <https://pubs.opengroup.org/standards/zero-trust-reference-model>
- Security Principles for Architecture - <https://pubs.opengroup.org/standards/zero-trust-security-principles>

**NIST**

- Framework of Standards and Technology (NIST)
- Zero Trust Architecture - <https://www.nist.gov/zero-trust-architecture>
- Zero Trust Reference Model - <https://www.nist.gov/zero-trust-reference-model>
- Secure Software Development Framework (SSDF) - <https://www.nist.gov/secure-software-development-framework>

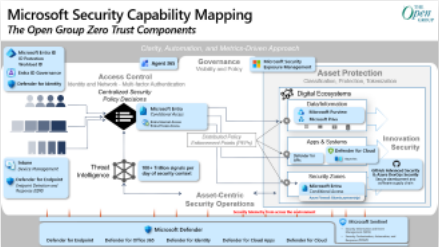
**Cybersecurity and Infrastructure Security Agency (CISA)**

- Zero Trust Maturity Model - <https://www.cisa.gov/zero-trust-maturity-model>

**Center for Internet Security (CIS)**

- CIS Benchmarks - <https://www.cisecurity.org/benchmarks>

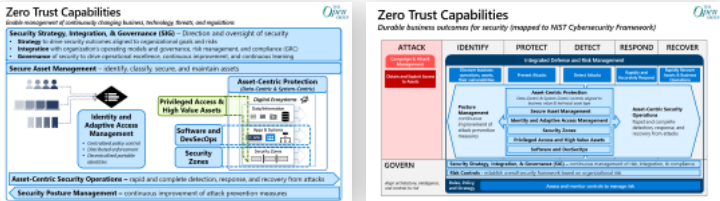
Zero Trust Model The Open Group



Key SecOps Terminology

SecOps Terminology

Zero Trust Capabilities The Open Group



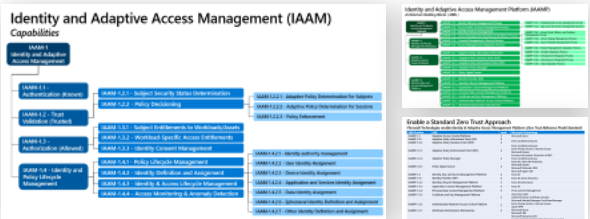
All capabilities ...mapped to NIST CSF

Asset-Centric Security Operations (SecOps/SOC)



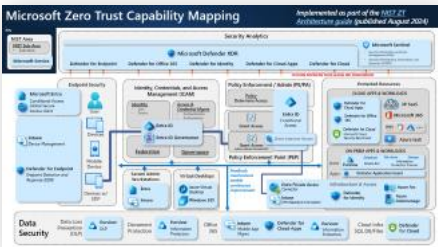
Capabilities

Identity and Adaptive Access Management (IAAM)



Capabilities

Zero Trust Model NIST



Report Regulatory Compliance



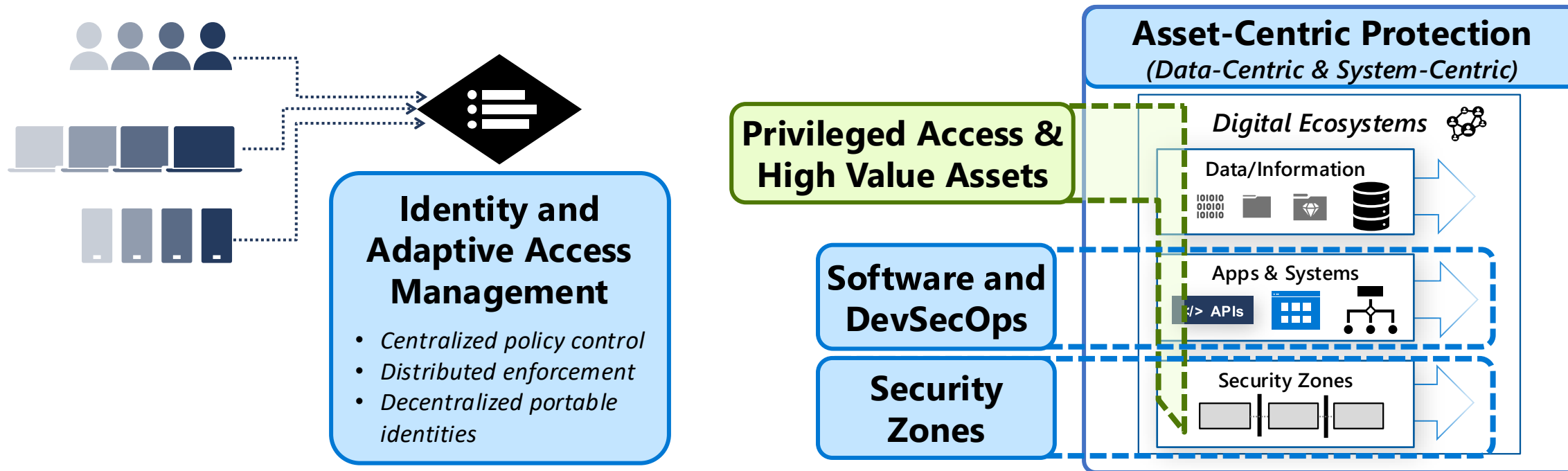
Zero Trust Capabilities

Enable management of continuously changing business, technology, threats, and regulations

Security Strategy, Integration, & Governance (SIG) – Direction and oversight of security

- **Strategy** to drive security outcomes aligned to organizational goals and risks
- **Integration** with organization's operating models and governance, risk management, and compliance (GRC)
- **Governance** of security to drive operational excellence, continuous improvement, and continuous learning

Secure Asset Management – identify, classify, secure, and maintain assets

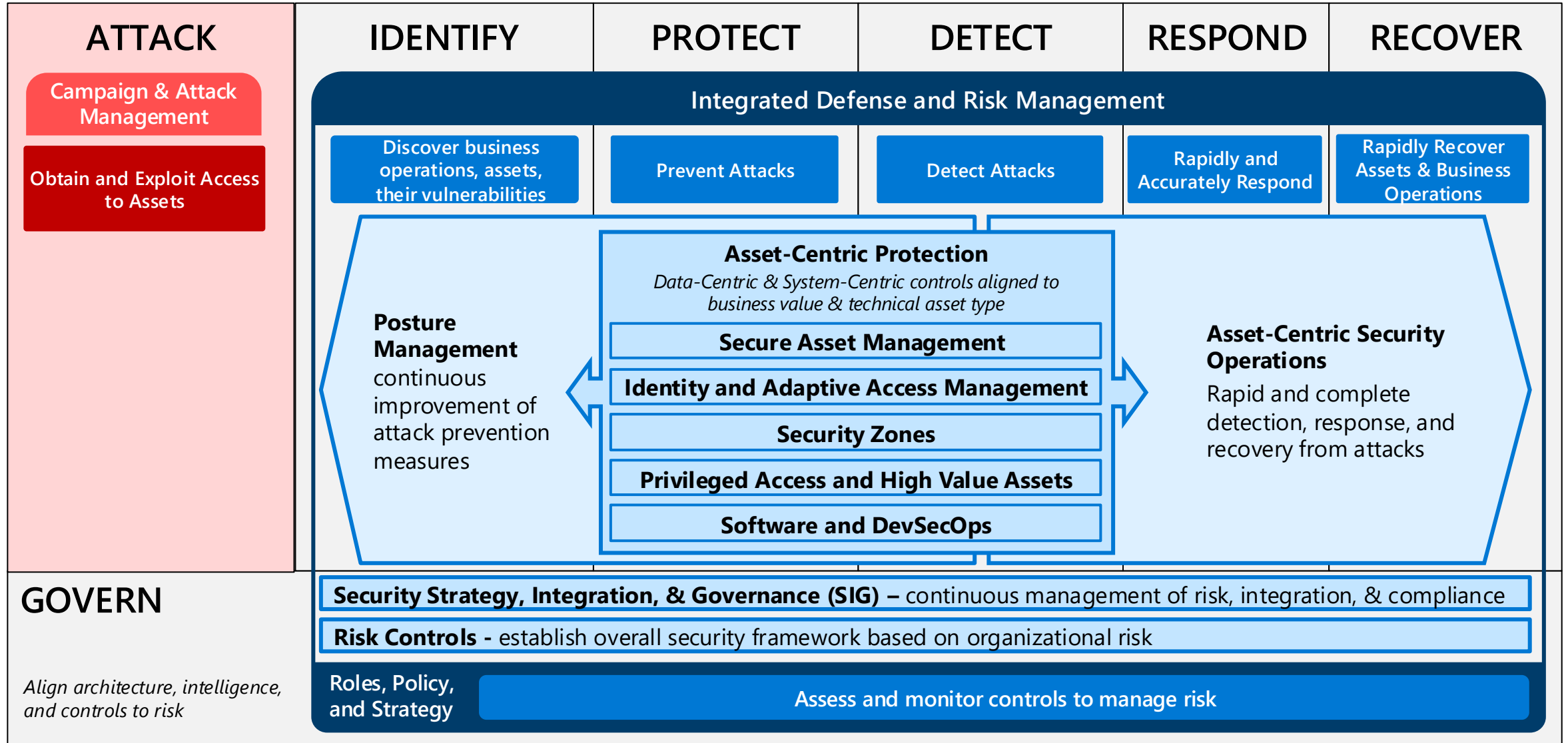


Asset-Centric Security Operations – rapid and complete detection, response, and recovery from attacks

Security Posture Management – continuous improvement of attack prevention measures

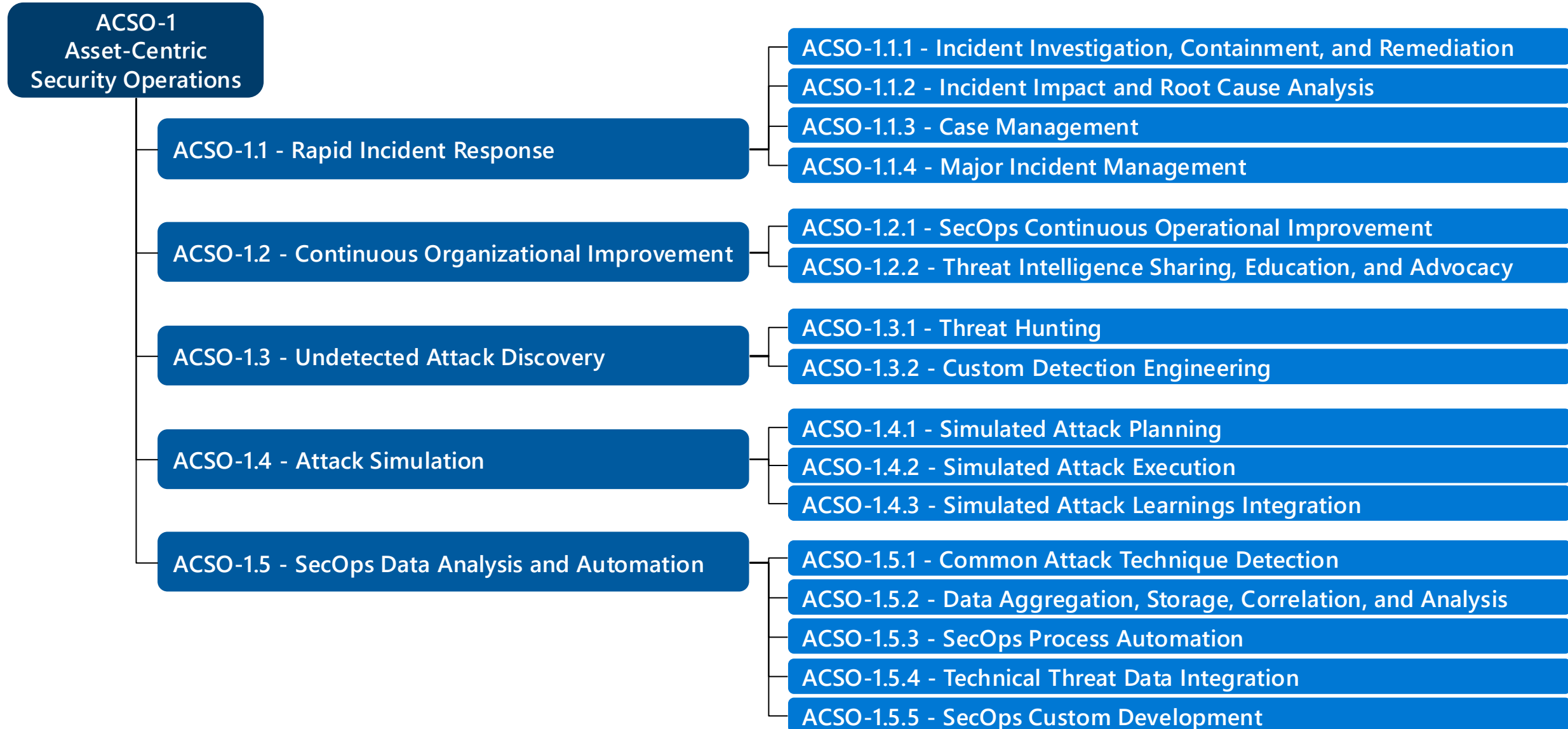
Zero Trust Capabilities

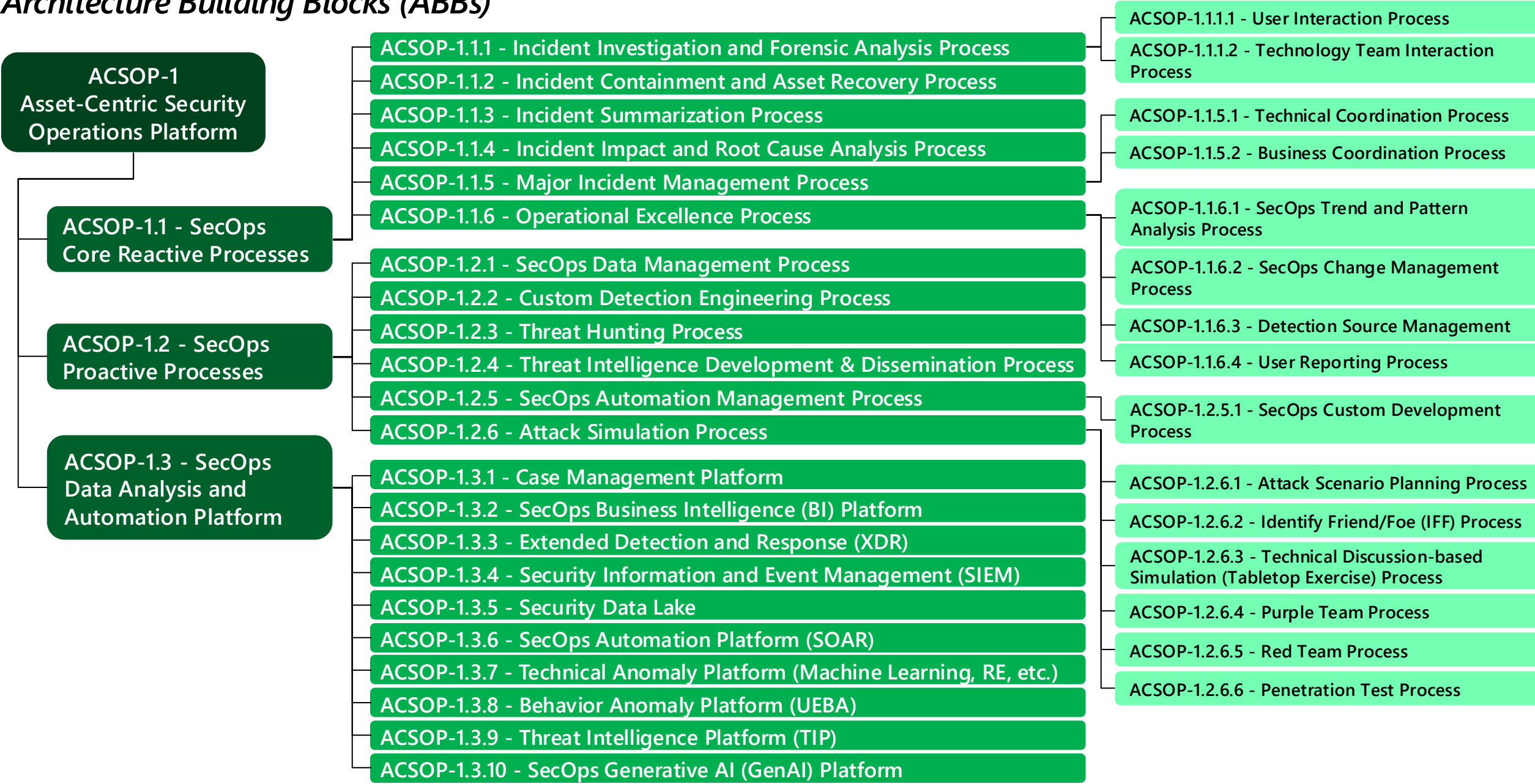
Durable business outcomes for security (mapped to NIST Cybersecurity Framework)



Asset-Centric Security Operations (ACSO)

Capabilities





Enable a Standard Zero Trust Approach

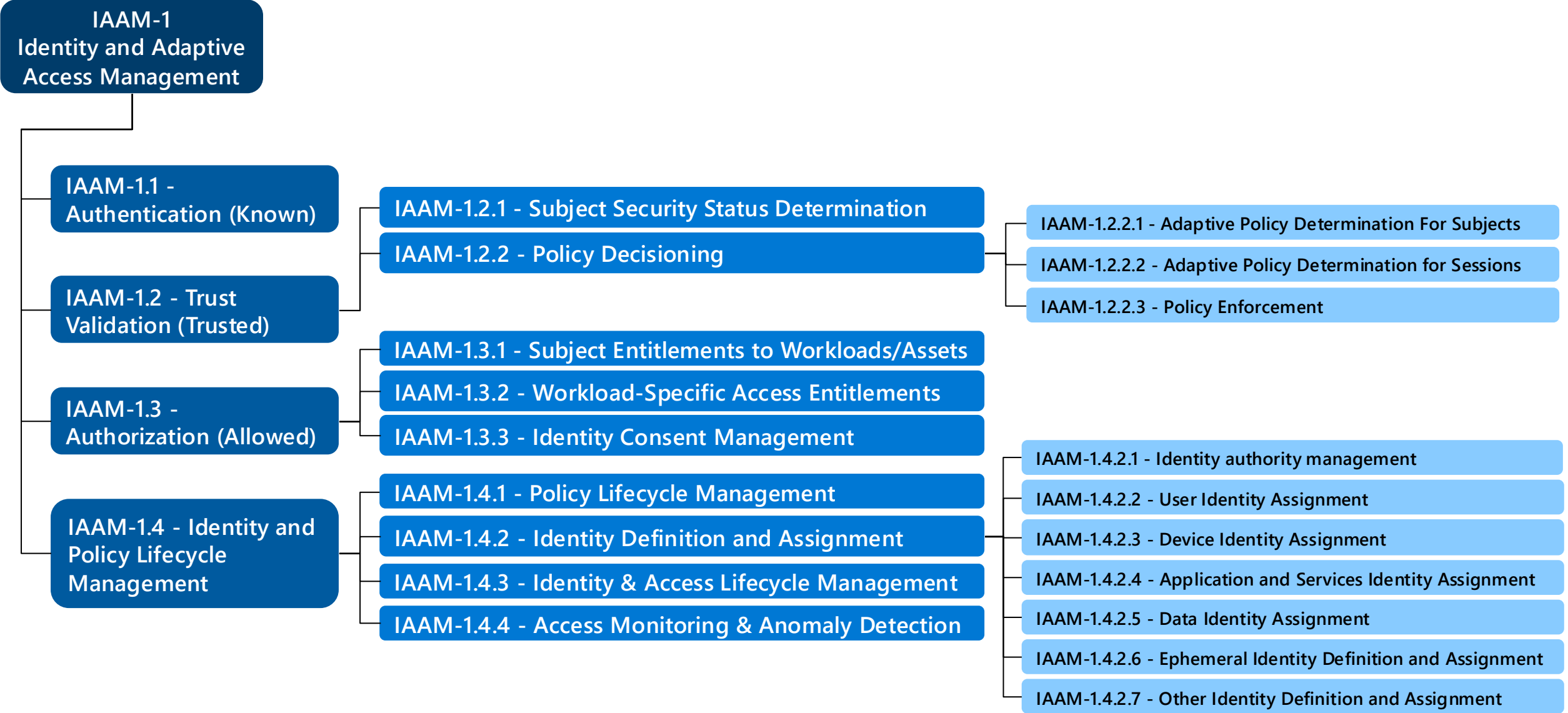
Microsoft Technologies enable Asset-Centric Security Operations Platform (Zero Trust Reference Model)

ABB #	Architecture Building Block (ABB) Name	Level	Microsoft Technology
ACSOP-1.3	SecOps Data Analysis and Automation Platform	2	<All Below>
ACSOP-1.3.1	Case Management Platform	3	Microsoft 365 Defender Microsoft Sentinel
ACSOP-1.3.2	SecOps Business Intelligence (BI) Platform	3	Microsoft PowerBI
ACSOP-1.3.3	Extended Detection and Response (XDR)	3	Microsoft 365 Defender (and Agent 365) Microsoft Defender for Cloud
ACSOP-1.3.4	Security Information and Event Management (SIEM)	3	Microsoft Sentinel
ACSOP-1.3.5	Security Data Lake	3	Microsoft Azure Data Explorer (ADX)
ACSOP-1.3.6	SecOps Automation Platform (SOAR)	3	Microsoft 365 Defender (AutoIR) Microsoft Sentinel
ACSOP-1.3.7	Technical Anomaly Platform (Machine Learning, RE, etc.)	3	Microsoft 365 Defender Microsoft Defender for Cloud
ACSOP-1.3.8	Behavior Anomaly Platform (UEBA)	3	Microsoft Sentinel
ACSOP-1.3.9	Threat Intelligence Platform (TIP)	3	Microsoft Defender Threat Intelligence Security Copilot
ACSOP-1.3.10	SecOps Generative AI (GenAI) Platform	3	Security Copilot

Note: Security Architecture Design Session (ADS) workshop for Security Operations (SecOps/SOC) includes guidance for *ACSOP-1.1 SecOps Core Reactive Processes* and *ACSOP-1.2 SecOps Proactive Processes ABBs*

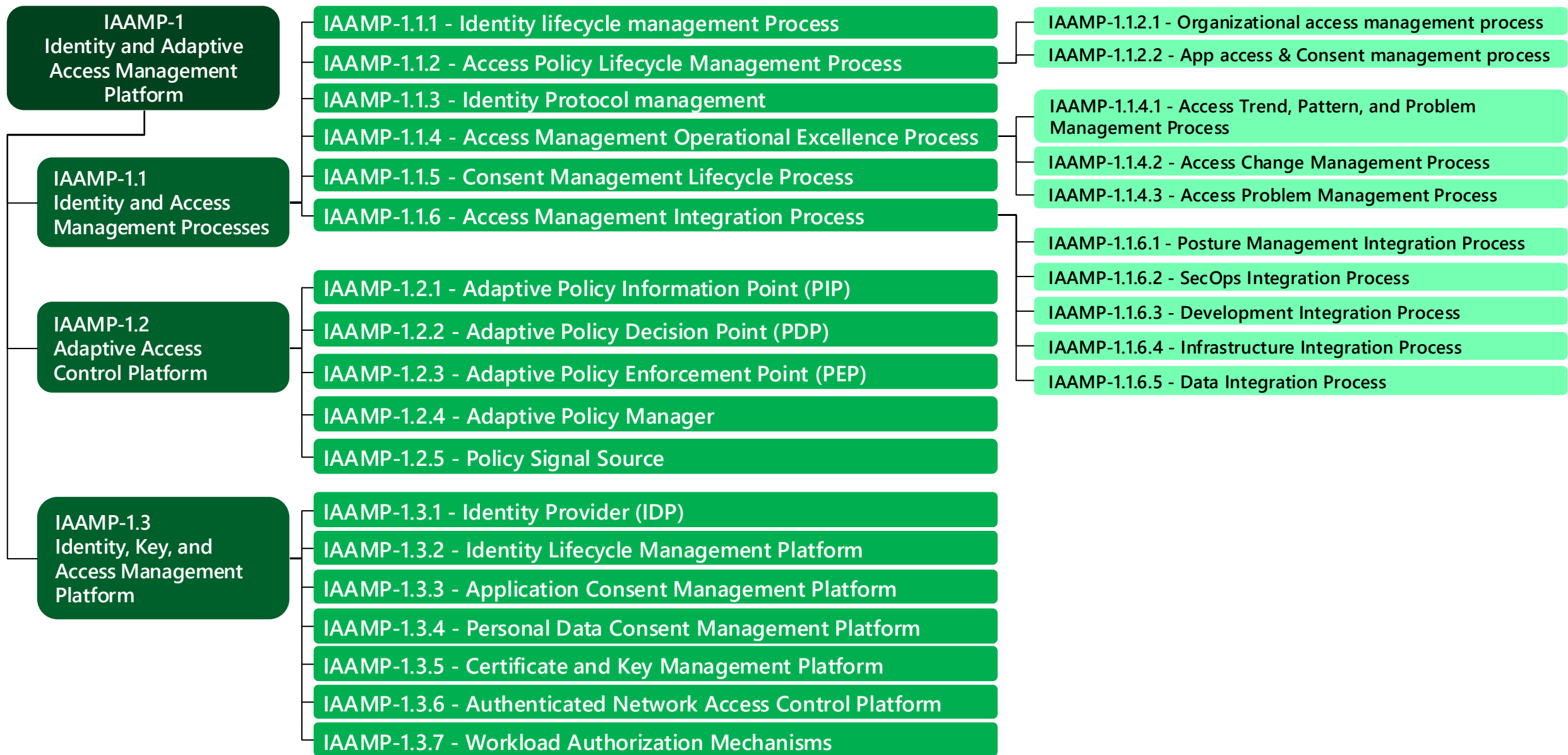
Identity and Adaptive Access Management (IAAM)

Capabilities



Identity and Adaptive Access Management Platform (IAAMP)

Architecture Building Blocks (ABBs)



Enable a Standard Zero Trust Approach

Microsoft Technologies enable Identity & Adaptive Access Management Platform (Zero Trust Reference Model Standard)

ABB Number	ABB	Level	Microsoft Technology
IAAMP-1.2	Adaptive Access Control Platform	2	Microsoft Entra
IAAMP-1.2.1	Adaptive Policy Information Point (PIP)	3	Entra Conditional Access
IAAMP-1.2.2	Adaptive Policy Decision Point (PDP)	3	
IAAMP-1.2.3	Adaptive Policy Enforcement Point (PEP)	3	Entra Conditional Access Entra Private Access / Internet Access Microsoft Intune Purview Information Protection & DLP
IAAMP-1.2.4	Adaptive Policy Manager	3	Entra Conditional Access
IAAMP-1.2.5	Policy Signal Source	3	Entra ID / Entra ID Protection Microsoft Intune Microsoft Defender XDR Microsoft Agent 365
IAAMP-1.3	Identity, Key, and Access Management Platform	2	Entra ID
IAAMP-1.3.1	Identity Provider (IDP)	3	Entra ID, Active Directory
IAAMP-1.3.2	Identity Lifecycle Management Platform	3	Entra ID Governance
IAAMP-1.3.3	Application Consent Management Platform	3	Entra ID
IAAMP-1.3.4	Personal Data Consent Management Platform	3	Priva Consent Management
IAAMP-1.3.5	Certificate and Key Management Platform	3	Azure Key Vault Active Directory Certificate Services Microsoft Identity Manager Certificate Manager
IAAMP-1.3.6	Authenticated Network Access Control Platform	3	Entra Private Access / Internet Access Azure VPN
IAAMP-1.3.7	Workload Authorization Mechanisms	3	Microsoft Azure Microsoft 365 Microsoft Dynamics 365 <i>Custom Workload RBAC/ABAC/Permission models</i>

Security Modernization with Zero Trust Principles



Business Enablement

Align security to the organization's mission, priorities, risks, and processes

Security Strategy and Program



Assume Breach (Assume Compromise)

Assume attackers can and will successfully attack anything (identity, network, device, app, infrastructure, etc.) and plan accordingly



Verify Explicitly

Protect assets against attacker control by explicitly validating that all trust and security decisions use all relevant available information and telemetry.



Use least privilege access

Limit access of a potentially compromised asset, typically with just-in-time and just-enough-access (JIT/JEA) and risk-based policies like adaptive access control.

Zero Trust Architecture



Access and Identity



Infrastructure &
Development Security



IoT and OT
Security



Modern Security
Operations (SecOps/SOC)



Data Security

Applying Zero Trust Principles

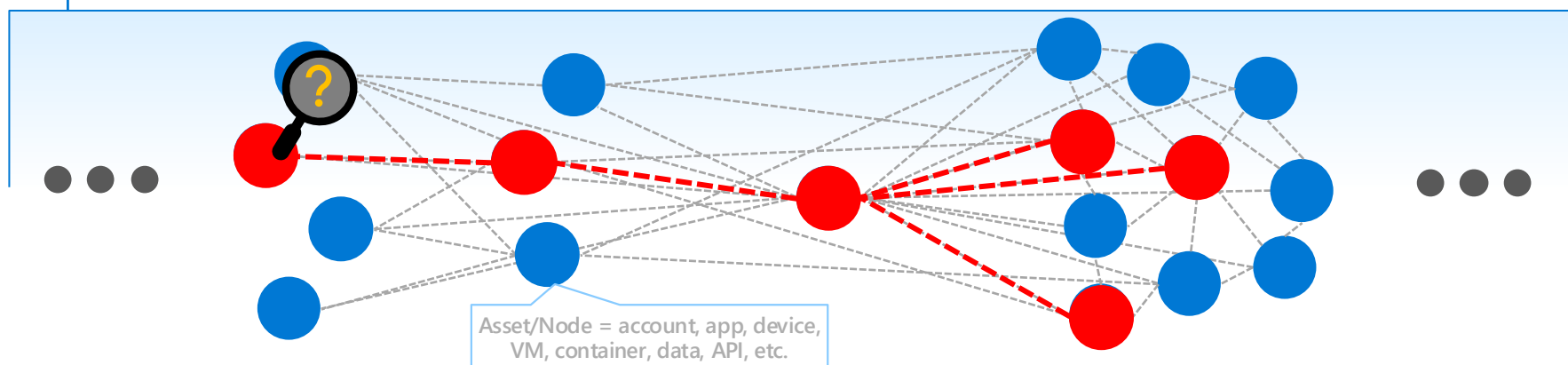
Business Enablement

Align security to the organization's mission, priorities, risks, and processes

Assume Breach (Assume Compromise)

Assume attackers can and will successfully attack anything (identity, network, device, app, infrastructure, etc.) and plan accordingly

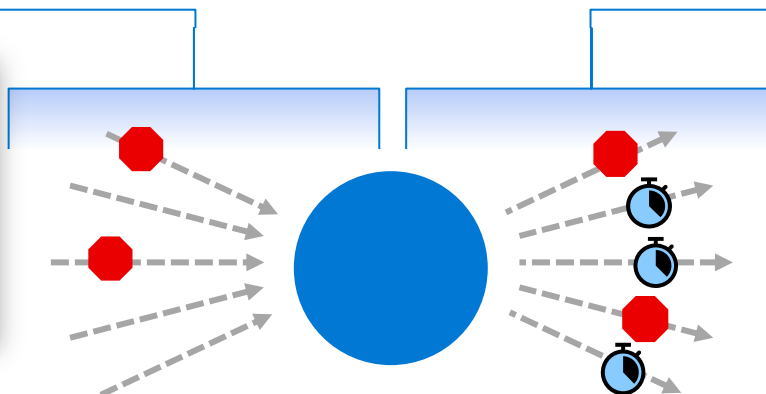
→ Transforms from *"defend the network"* to *"enable secure productivity on any network"*



Verify explicitly

Protect assets against attacker control by explicitly validating that all trust and security decisions use all relevant available information and telemetry.

→ Reduces *"attack surface"* of each asset

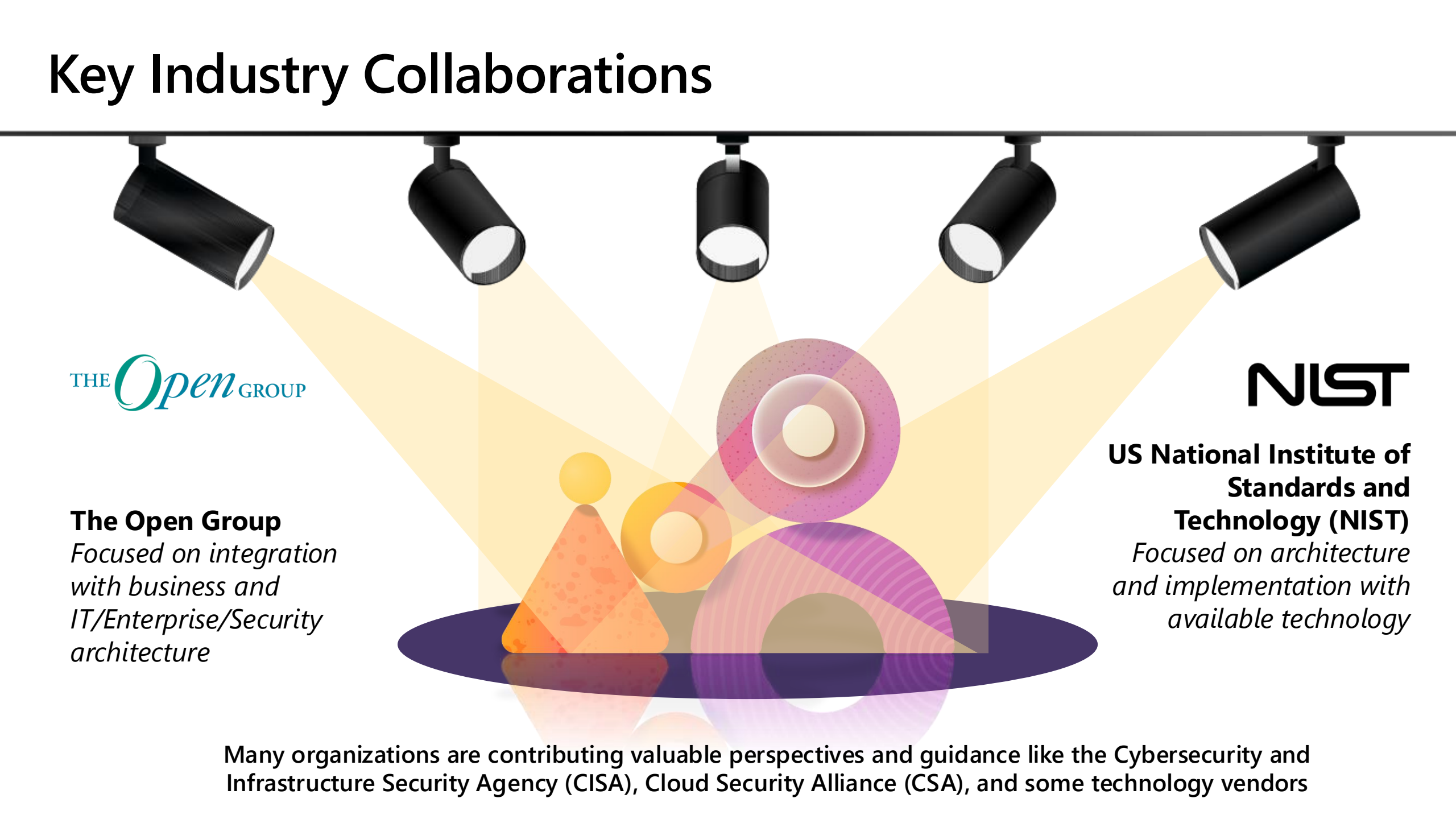


Use least privilege access

Limit access of a potentially compromised asset, typically with just-in-time and just-enough-access (JIT/JEA) and risk-based policies like adaptive access control.

→ Reduces *"blast radius"* of compromises

Key Industry Collaborations

A conceptual diagram showing five black track lights at the top, each casting a yellow beam of light downwards. The beams converge on a central area containing several overlapping, semi-transparent geometric shapes: a yellow triangle, an orange circle, a purple circle, and a larger purple circle with concentric rings. The shapes are reflected on a dark purple oval base. The overall theme is collaboration and focus on key industry partners.

THE *Open* GROUP

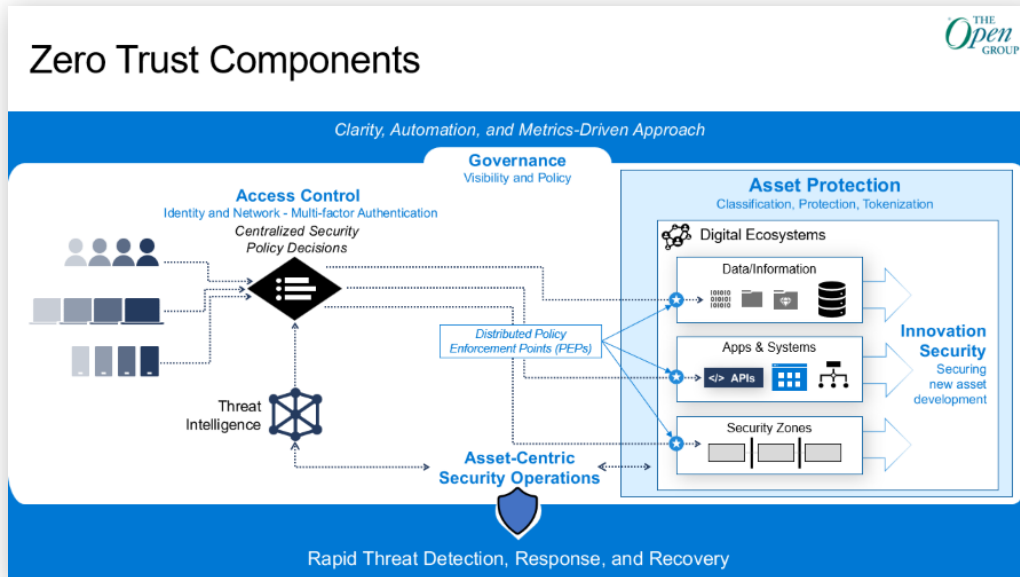
The Open Group
*Focused on integration
with business and
IT/Enterprise/Security
architecture*

NIST

**US National Institute of
Standards and
Technology (NIST)**
*Focused on architecture
and implementation with
available technology*

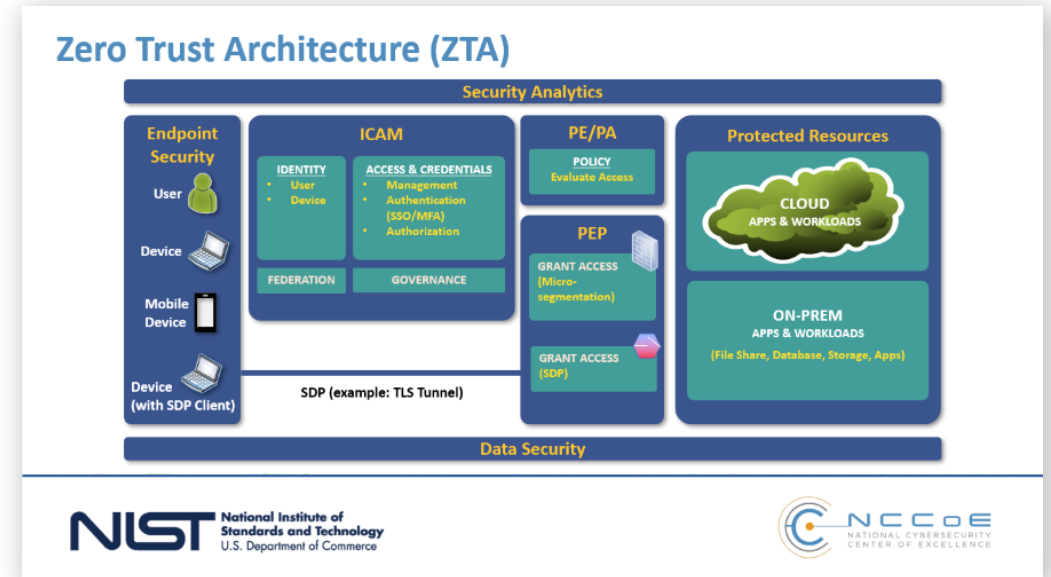
Many organizations are contributing valuable perspectives and guidance like the Cybersecurity and Infrastructure Security Agency (CISA), Cloud Security Alliance (CSA), and some technology vendors

Key Zero Trust Models and Architectures



The Open Group

Focused on integration with business and IT/Enterprise/Security architecture

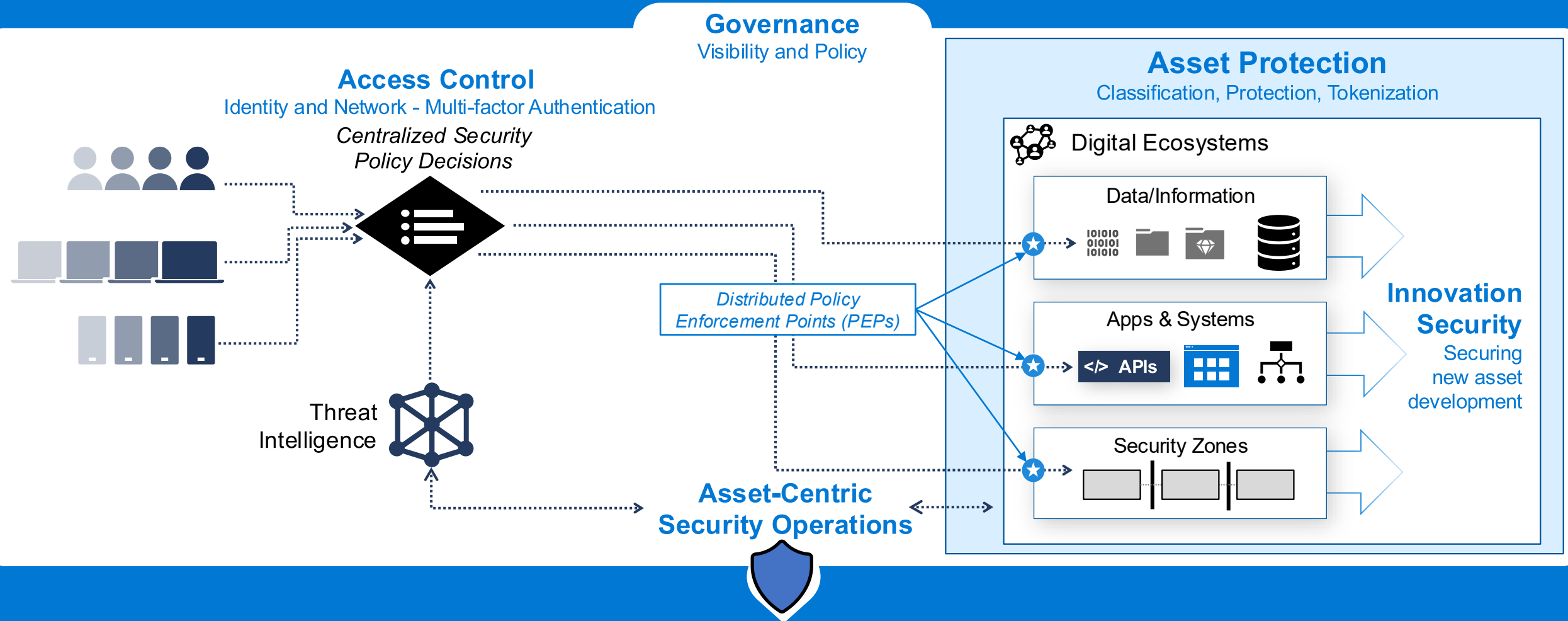


US National Institute of Standards and Technology (NIST)

Focused on architecture and implementation with available technology

Zero Trust Components

Clarity, Automation, and Metrics-Driven Approach

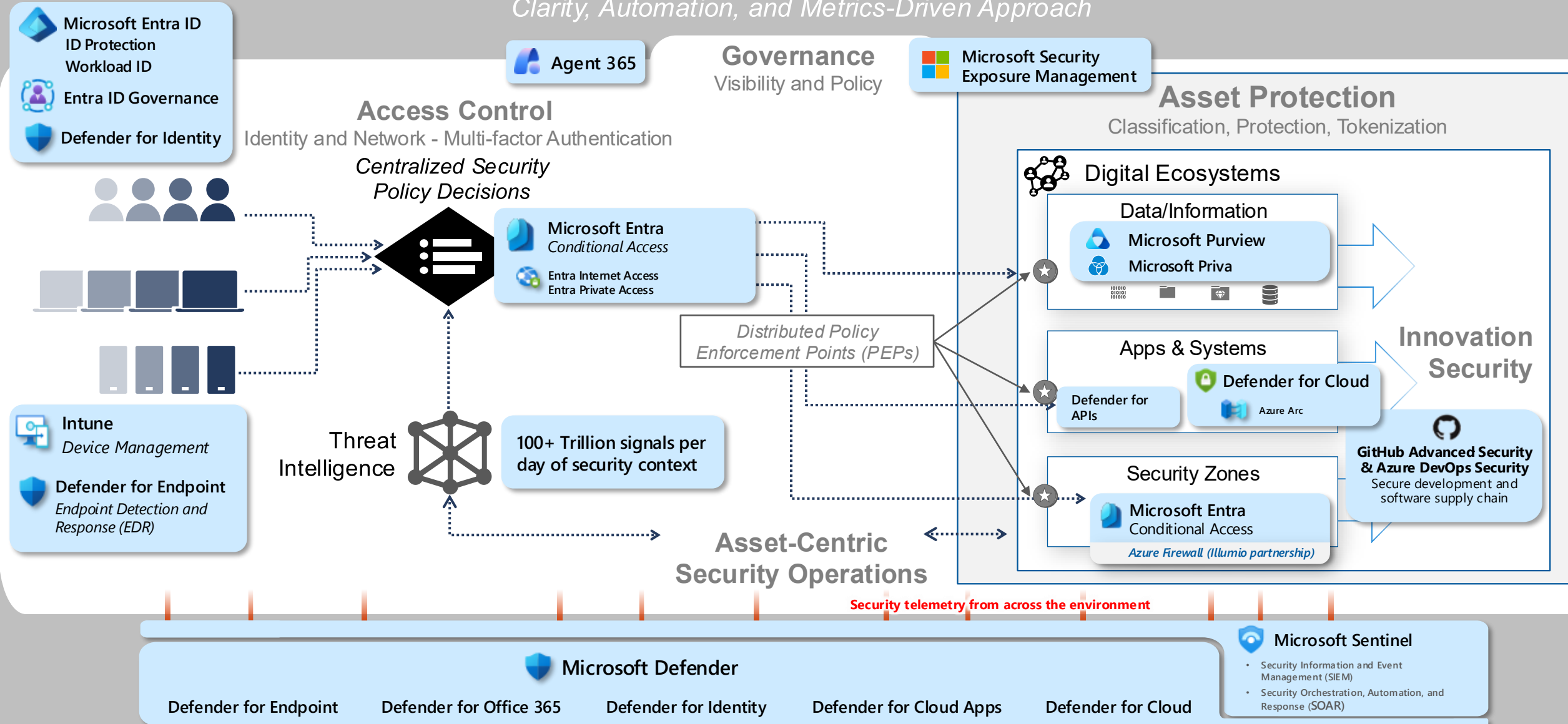


Rapid Threat Detection, Response, and Recovery

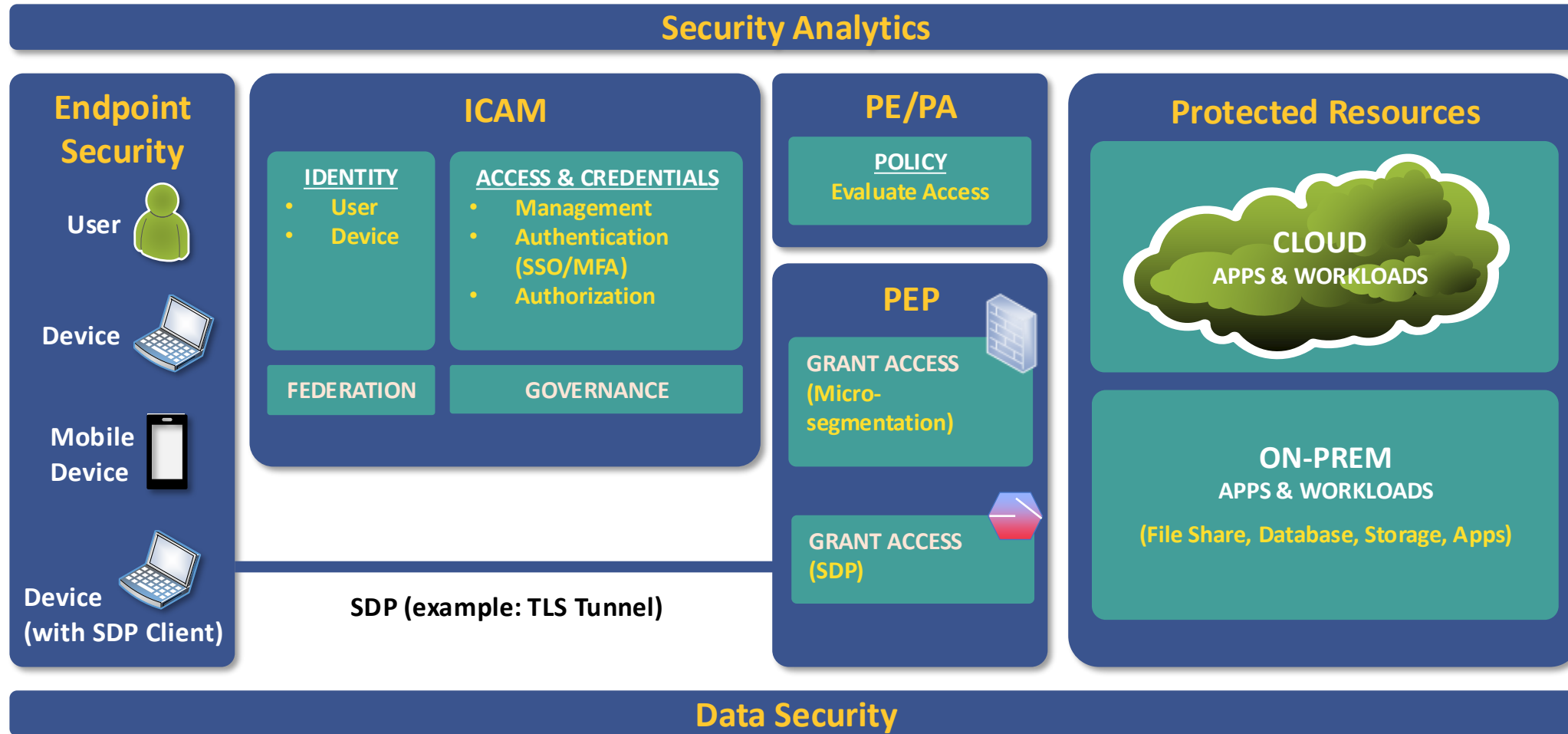
Microsoft Security Capability Mapping

The Open Group Zero Trust Components

Clarity, Automation, and Metrics-Driven Approach



Zero Trust Architecture (ZTA)



Microsoft Zero Trust Capability Mapping

Implemented as part of the [NIST ZT Architecture guide](#) (published August 2024)

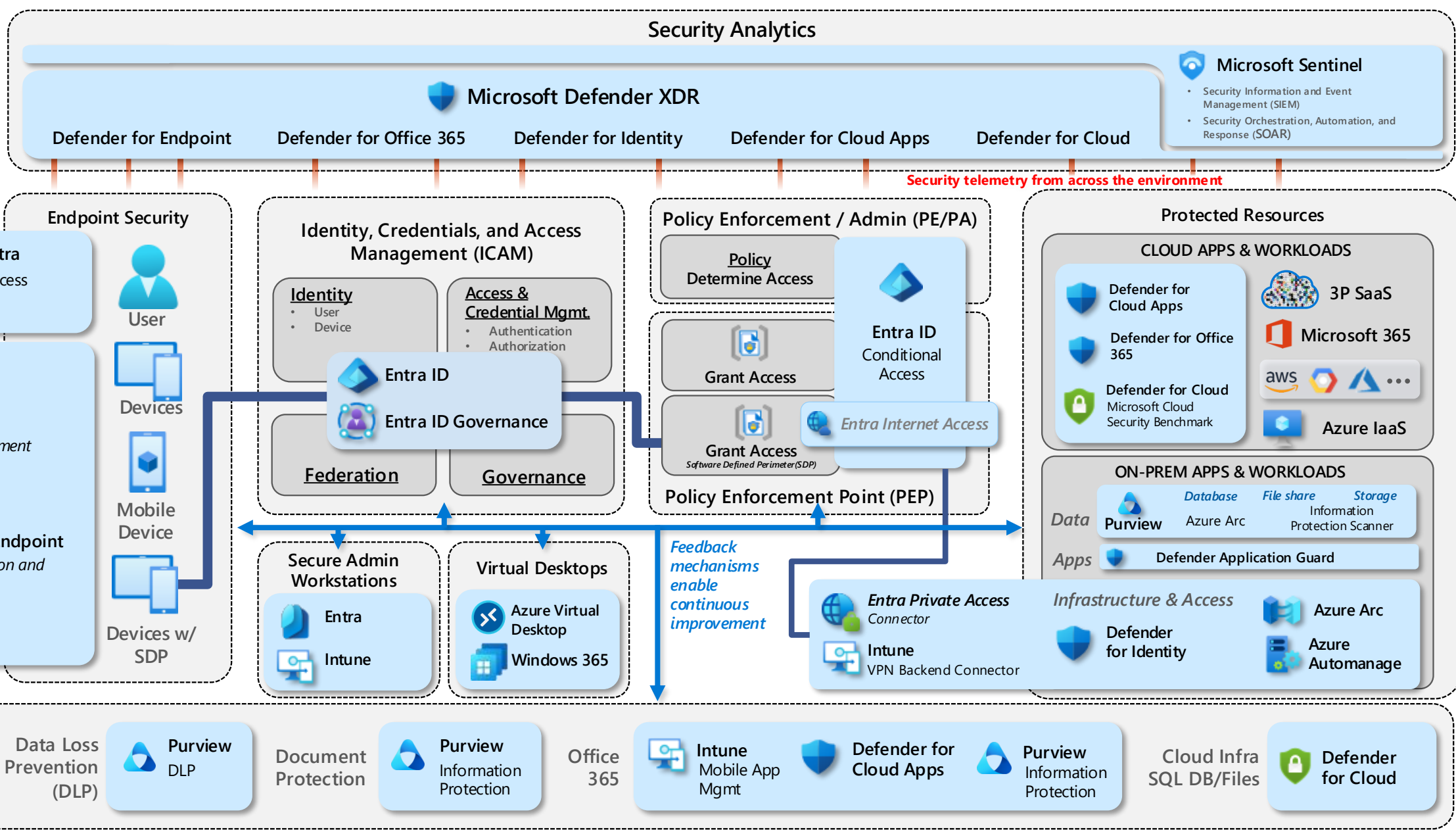
Key

NIST Area

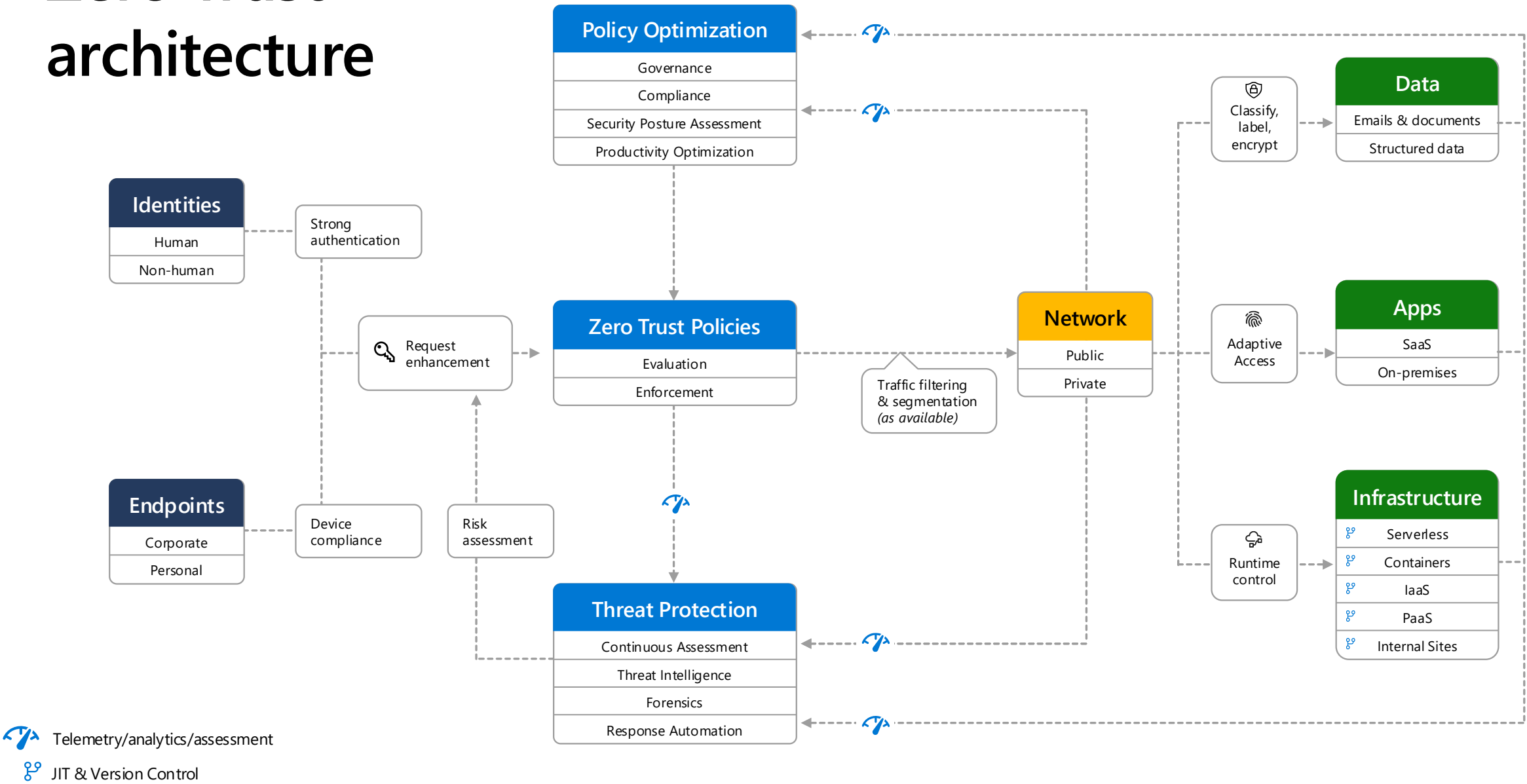
NIST Sub-Area

- Sub-Area

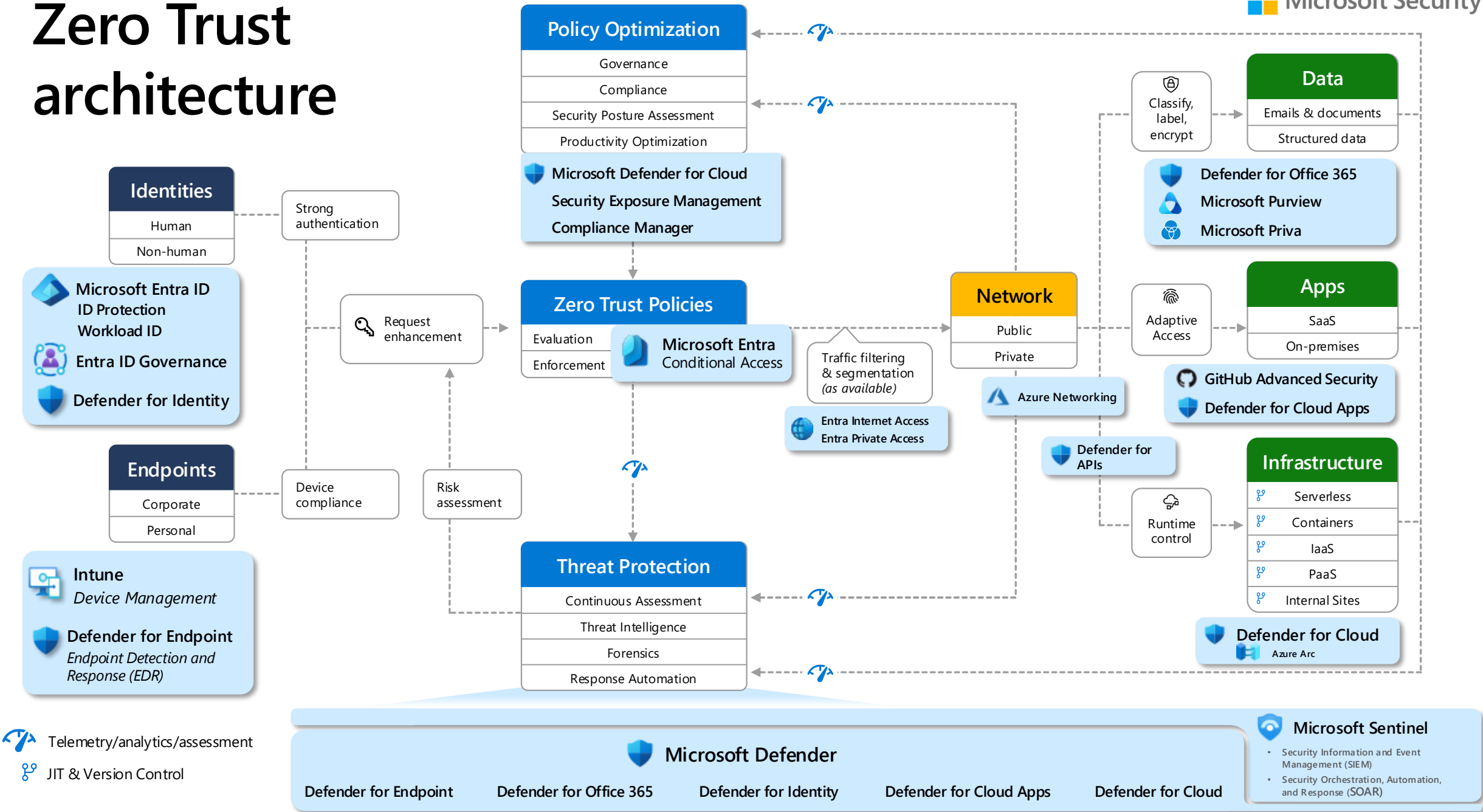
Microsoft Service



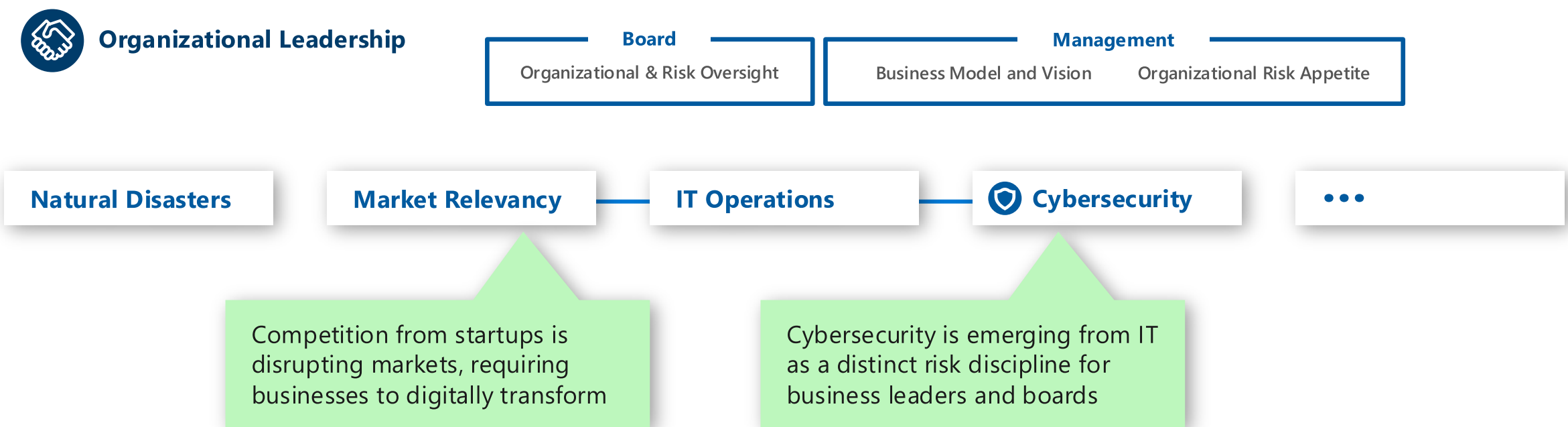
Zero Trust architecture



Zero Trust architecture

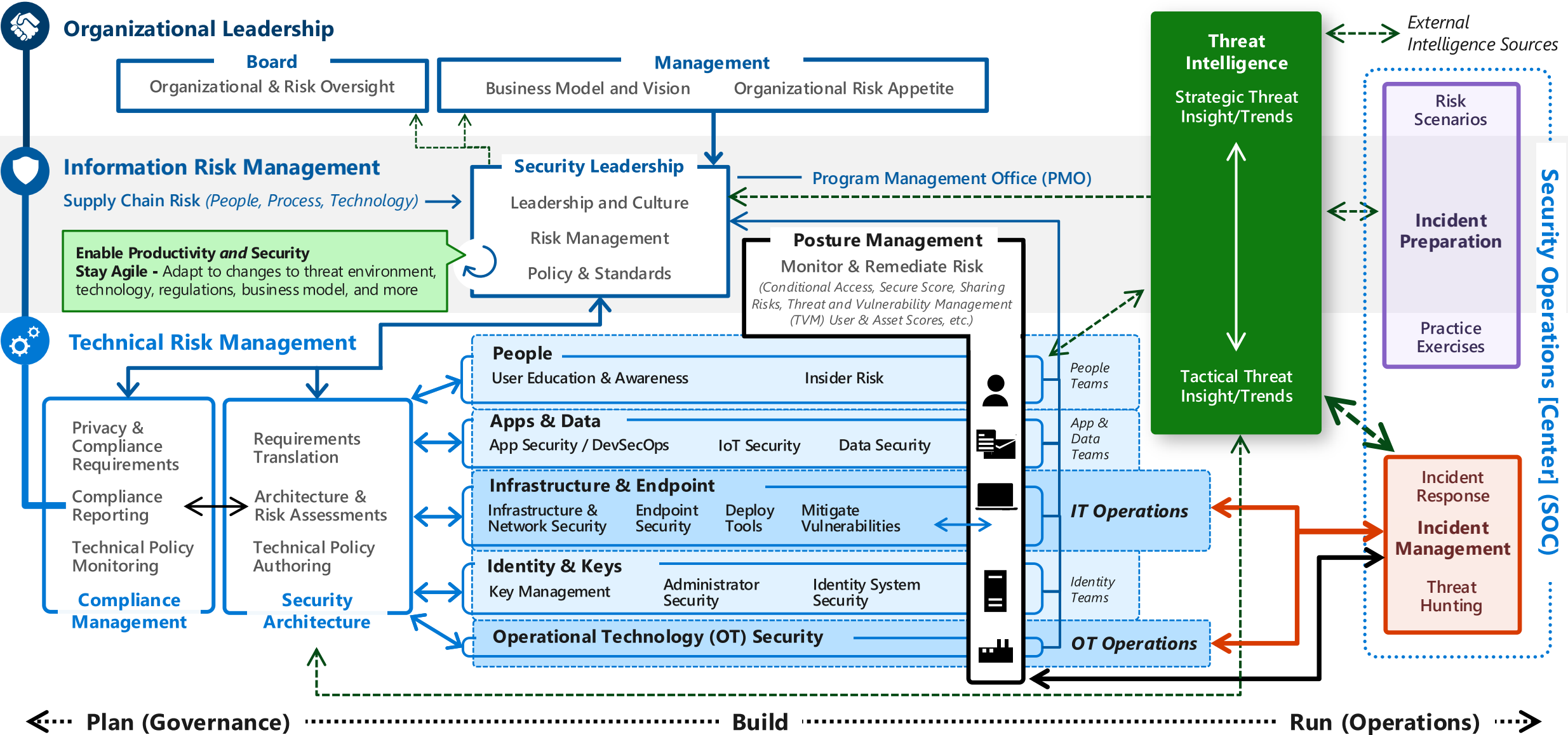


Managing organizational risk



Managing Information/Cyber Risk

Security responsibilities or "jobs to be done"



Microsoft security capability mapping

Which roles typically use which capabilities

June 2026 – <https://aka.ms/MCRA>



Access Control

Establish **Zero Trust** access model to modern and legacy assets using identity & network controls

Microsoft Entra

Identity Admin, Identity Architect, Identity Security

- **Entra ID (Formerly Azure AD)**
 - Multifactor Authentication
 - Conditional Access
 - Application Proxy
 - External Identities / B2B & B2C
 - Internet/Private Access
 - Identity Governance
 - and more..
- **Windows Hello for Business**
- **Microsoft 365 Defender**
 - Microsoft Defender for Identity
 - Microsoft Defender for Cloud Apps
- **Microsoft 365 Lighthouse** [multi-tenant]
- **Azure Lighthouse**
- **Azure Bastion**
- **Azure Administrative Model**
 - Portal, Management Groups, Subscriptions
 - Azure RBAC & ABAC

Network Security

- **Azure Firewall**
- **Azure Firewall Manager**
- **Azure DDoS**
- **Azure Web Application Firewall**
- **Azure Networking Design**
 - Virtual Network, NSG, ASG, VPN, etc.
 - PrivateLink / Private EndPoint

Endpoint / Device Admin

- **Microsoft Intune**
 - Configuration Management
- **Microsoft Defender for Endpoint**



Security Operations

Detect, Respond, and Recover from attacks; Hunt for hidden threats; share threat intelligence broadly

Incident preparation

Security Operations Analyst

Microsoft Defender XDR

- Microsoft Defender for Endpoint
- Microsoft Defender for Office 365
- Microsoft Defender for Identity
- Microsoft Defender for Cloud Apps
- Microsoft Entra Identity Protection
- **Microsoft Defender for Cloud**
 - Microsoft Defender for DevOps
 - Microsoft Defender for Servers
 - Microsoft Defender for Storage
 - Microsoft Defender for SQL
 - Microsoft Defender for Containers
 - Microsoft Defender for App Service
 - Microsoft Defender for APIs
 - Microsoft Defender for Key Vault
 - Microsoft Defender for DNS
 - Microsoft Defender for open-source relational databases
 - Microsoft Defender for Azure Cosmos DB
- **Microsoft Security Copilot**
- **Microsoft Sentinel**
- **Microsoft Security Experts**
- **Microsoft Incident Response**
 - Detection and Response Team (DART)

Microsoft Defender

Threat intelligence Analyst

- **Microsoft Defender Threat Intelligence (Defender TI)**
- **Microsoft Sentinel**



Security Governance

Protect sensitive data and systems. Continuously discover, classify & secure assets

Security architecture

- Microsoft Cybersecurity Reference Architecture <https://aka.ms/MCRA>

Posture management, Policy and standards, Compliance management

- **Microsoft Exposure Management**
- **Agent 365**
- **Microsoft Defender for Cloud**
- **Azure Blueprints**
- **Azure Policy**
- **Microsoft Defender External Attack Surface Management (MD-EASM)**
- **Azure Administrative Model**
 - Portal, Management Groups, Subscriptions
 - Azure RBAC & ABAC
- **Microsoft Purview**
 - Compliance manager

Microsoft Purview

Data security

- **Microsoft Purview**
 - Information Protection
 - Data Loss Prevention
- **Microsoft 365 Defender**
 - Microsoft Defender for Cloud Apps

People security

- **Attack Simulator**
- **Insider Risk Management**

Privacy Manager

- **Microsoft Priva**



Asset Protection

Continuously **Identify**, measure, and manage security posture to reduce risk & maintain compliance

Infrastructure and endpoint security, IT Ops, DevOps

- **Microsoft Defender for Cloud** (including Azure Arc)
- **Azure Blueprints**
- **Azure Policy**
- **Azure Firewall**
- **Azure Monitor**
- **Azure Web Application Firewall**
- **Azure DDoS**
- **Azure Backup and Site Recovery**
- **Azure Networking Design**
 - Virtual Network, NSG, ASG, VPN, etc.
 - PrivateLink / Private EndPoint
- **Azure Resource Locks**

OT and IoT Security

- **Microsoft Defender for IoT (& OT)**
- **Azure Sphere**



Innovation Security

Integrate Security into DevSecOps processes. Align security, development, and operations practices.

Application security and DevSecOps

- (Same as Infrastructure Roles)
- **GitHub Advanced Security**
- **Azure DevOps Security**

Security accountabilities & responsibilities across an organization

Organizational Leadership & Governance

- Member of Board of Directors
- Chief Executive Officer (CEO)
- Chief Financial Officer (CFO)
- Chief Operating Officer (COO)
- Chief Counsel / Chief Legal Officer (CLO)
- Product and Business Line Leaders

Business Management and Operations

- Product Line Manager / Director
- Product Owner
- Business Architect / Analyst
- Business Analyst
- ★ Information Worker / Frontline Worker

Security-Adjacent Disciplines

- Chief Security Officer (CSO) and team
- Chief Risk Officer (CRO) and team
- Chief Privacy Officer (CPO) and team
- Data Officer / Data Governance and team
- Compliance and Audit team
- Anti-Fraud Team

Other Cross-Functional Disciplines

- Legal Team
- Finance Team
- Procurement & Acquisition
- Human Resources
- Communications / Public Relations
- Organizational Readiness / Training

Technical Leadership

- Chief Information Officer (CIO)
- Chief Digital Officer (CDO)
- Chief Technology Officer (CTO)
- Chief Information Security Officer (CISO)
- Business Information Security Officer (BISO)
- Chief Architect
- Software Delivery Vice President (VP)
- Technology Director
- Security Director
- Software Development Director

Architecture

- Enterprise Architect
- Security Architect
- Infrastructure Architect
- Data and Artificial Intelligence (AI) Architect
- Access Architect (Identity, Network, App, etc.)
- Solution Architect
- Software / Application Architect

Application & Product Development

- Technology Delivery Manager
- Software Testing/Quality Manager
- Software Security Engineer
- Software Developers (including AI)
- Software Testers
- DevOps Lead
- Supply Chain Security
- Internet of Things (IoT)

Security Strategy, Integration, & Governance

- Security Business Architect / Analyst
- Security Education and Engagement
- Insider Risk Management
- Security Posture Management
- Security Compliance Management

Technical Engineering and Operations

- Technology Manager
- Security Manager
- Automation Engineer
- Identity
- Network
- User Endpoints
- User Productivity and Support
- Infrastructure/Platform (Cloud, On-Prem, CI/CD, etc.)
- Data and Artificial Intelligence (AI)
- Operational Technology (OT)
- Security Engineer

Security Operations (SecOps/SOC)

- Security Operations (SecOps) Manager
- Triage (Tier 1) Analyst
- Investigation (Tier 2) Analyst
- Reverse Engineer
- Digital Forensics Specialist
- Threat Hunter (Tier 3)
- Detection Engineer
- SecOps Platform and Data Engineer
- Attack Simulation (Offensive Security)
- Incident Coordination and Management
- Threat Intelligence

Role Example – CEO

List of Security Duties

Chief Executive Officer (CEO)

- Provide final decisions for high consequence security risk situations

The CEO must make the final decision on high consequence security risk decisions for the

Risk of neglect for each

Risk of Neglect - Without CEOs making these high consequence decisions, the final decision may be made by a stakeholder without full context and organizational accountability. This can result in avoidable material damage and violations of fiduciary duty.

- Establish or correct organizational security culture
- Establish or correct organizational accountability structure for security
- Sponsor or approve inclusion of security into acquisition and purchasing policy

Standard Security Tasks for all leadership roles

- Discover and prepare for business disruptions from cyber threats
- Participate in security attack simulation exercises
- Support Zero Trust security modernization initiative
- Support quantum safe initiative

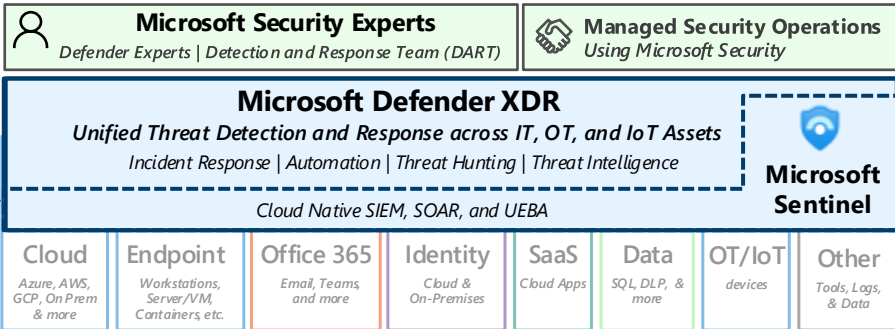
Asset Security Scope

The CEO is ultimately accountable for all organizational assets of all types in aggregate.

Required Knowledge, Skills, Abilities

- Standard cybersecurity skills for information workers
- Organizational leader's understanding of security threats, risks, and challenges

Security Operations (SecOps/SOC)



Cybersecurity Reference Architecture

Security modernization with Zero Trust Principles

June 2026 – aka.ms/MCRA

This is interactive!

1. Present Slide
2. Hover for Description
3. Click for more information

Security Guidance

1. [Security Adoption Framework](#)
2. [Security Documentation](#)
3. Cloud Security [Benchmarks](#)

Software as a Service (SaaS)



Microsoft Entra Internet Access

Agent 365

Identity & Access

Conditional Access – Zero Trust Adaptive Access Control based on explicit validation users, session, & endpoint integrity

Endpoints & Devices

Unified Endpoint Management (UEM)

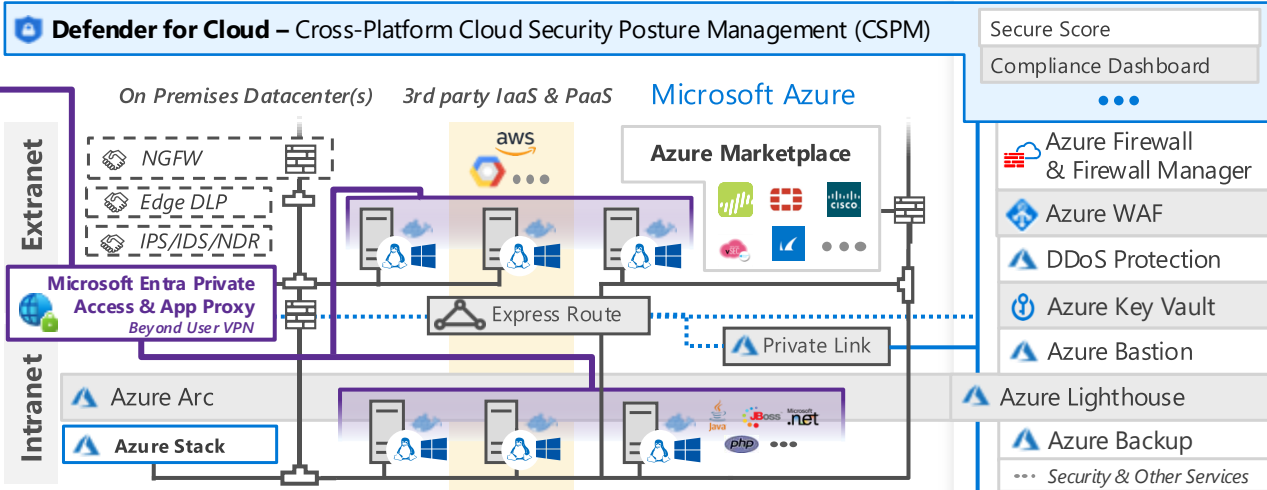
Intune Configuration Manager



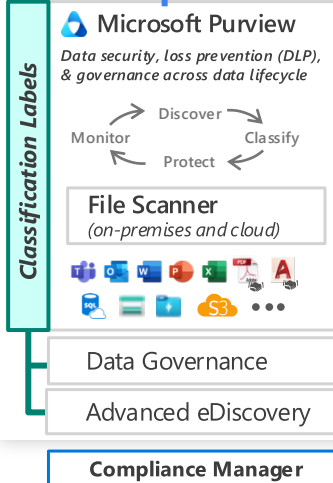
Microsoft Defender for Endpoint
Unified Endpoint Security

- Endpoint Detection & Response (EDR)
- Web Content Filtering
- Threat & Vuln Management
- Endpoint Data Loss Protection (DLP)

Infrastructure and Development Security (across hybrid of IaaS, PaaS, On-Premises)



Information Protection



Microsoft Entra

- Passwordless & MFA
- Hello for Business
- Verified Identity
- Passkeys
- FIDO2 Keys
- Entra ID Protection
- Leaked cred protection
- Behavioral Analytics
- ID Governance
- Microsoft Entra PIM
- External Identities

Defender for Identity

Active Directory

Securing Privileged Access – aka.ms/SPA

Privileged Access Workstations (PAWs) - Secure workstations for administrators, developers, and other sensitive users

Privileged Access Management (PAM)

Cloud Infrastructure Entitlement Management (CIEM)

Microsoft Security Exposure Management – Provides unified view of security posture + attack surface across organization, enabling you to investigate security insights, identify critical assets, reduce attack surfaces and security risk

Windows 11 & 10 Security

- Windows LAPS**
Protect Local Admin Account Credentials
- Exploit protection
- App control
- Full Disk Encryption
- Attack surface reduction
- Network protection
- Credential protection

IoT and Operational Technology (OT)

Azure Sphere

Microsoft Defender for IoT (and OT)

- ICS, SCADA, OT
- Internet of Things (IoT)
- Industrial IoT (IIoT)
- Asset & Vulnerability management
- Threat Detection & Response

Defender for Cloud – Cross-Platform, Multi-Cloud XDR
Detection and response capabilities for infrastructure and development across IaaS, PaaS, and on-premises

Defender for APIs

People Security

- Attack Simulator
- Insider Risk Management
- Communication Compliance

GitHub Advanced Security & Azure DevOps Security
Secure development and software supply chain

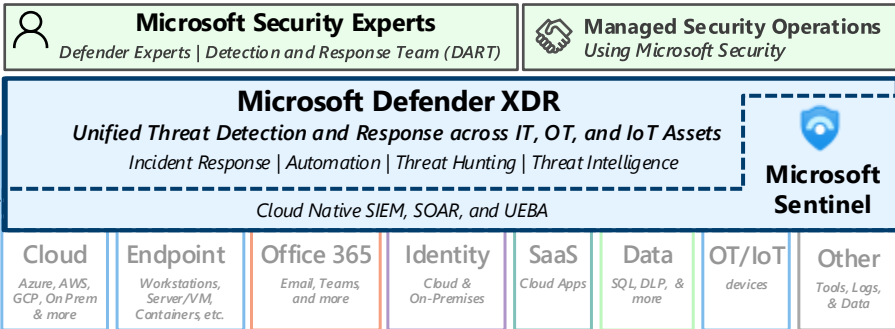
Microsoft Security Copilot

Threat Intelligence – 100+ Trillion signals per day of security context

Service Trust Portal – How Microsoft secures cloud services

Security Development Lifecycle (SDL)

Security Operations (SecOps/SOC)



Cybersecurity Reference Architecture

Security modernization with Zero Trust Principles

June 2026 – aka.ms/MCRA

This is interactive!

1. Present Slide
2. Hover for Description
3. Click for more information

Security Guidance

1. [Security Adoption Framework](#)
2. [Security Documentation](#)
3. Cloud Security [Benchmarks](#)

Software as a Service (SaaS)



Microsoft Entra Internet Access

Agent 365

Identity & Access

Conditional Access – Zero Trust Adaptive Access Control based on explicit validation users, session, & endpoint integrity

Endpoints & Devices

Unified Endpoint Management (UEM)

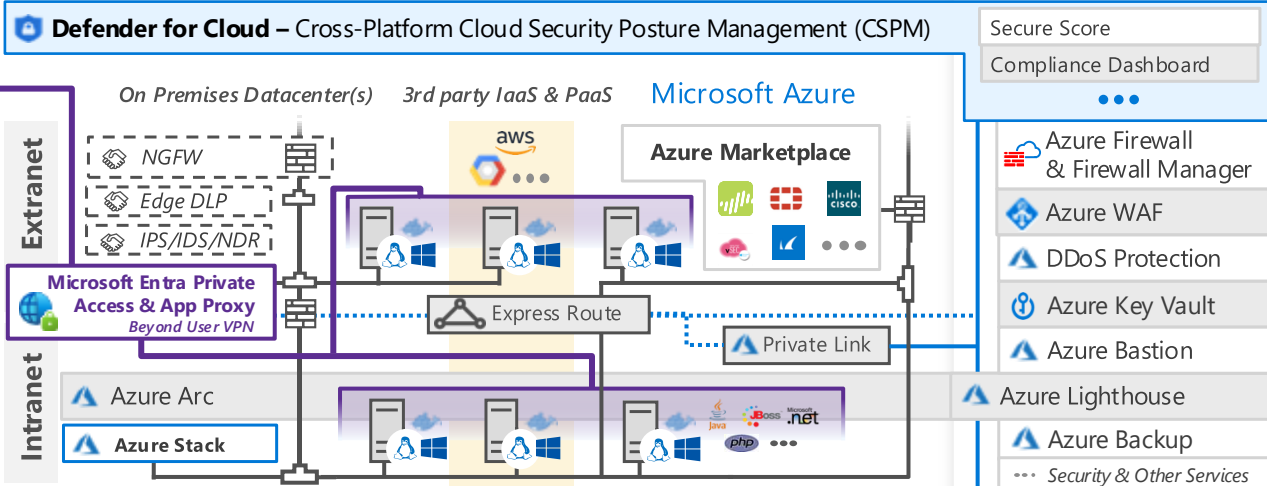
Intune Configuration Manager



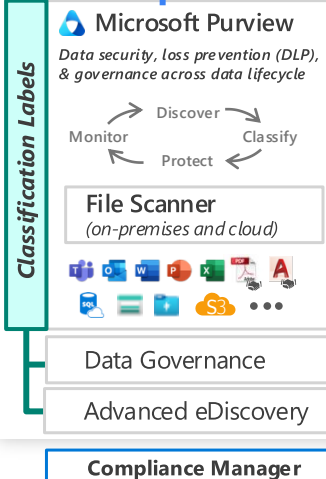
Microsoft Defender for Endpoint
Unified Endpoint Security

- Endpoint Detection & Response (EDR)
- Web Content Filtering
- Threat & Vuln Management
- Endpoint Data Loss Protection (DLP)

Infrastructure and Development Security (across hybrid of IaaS, PaaS, On-Premises)



Information Protection



Microsoft Entra

- Passwordless & MFA
- Hello for Business
- Verified Identity
- Passkeys
- FIDO2 Keys
- Entra ID Protection
- Leaked cred protection
- Behavioral Analytics
- ID Governance
- Microsoft Entra PIM
- External Identities

Defender for Identity

Active Directory

Securing Privileged Access – aka.ms/SPA

Privileged Access Workstations (PAWs) - Secure workstations for administrators, developers, and other sensitive users

Privileged Access Management (PAM)

Cloud Infrastructure Entitlement Management (CIEM)

Microsoft Security Exposure Management – Provides unified view of security posture + attack surface across organization, enabling you to investigate security insights, identify critical assets, reduce attack surfaces and security risk

Windows 11 & 10 Security

- Windows LAPS**
Protect Local Admin Account Credentials
- Exploit protection
- App control
- Full Disk Encryption
- Attack surface reduction
- Network protection
- Credential protection

IoT and Operational Technology (OT)

Azure Sphere

Microsoft Defender for IoT (and OT)

- ICS, SCADA, OT
- Internet of Things (IoT)
- Industrial IoT (IIoT)
- Asset & Vulnerability management
- Threat Detection & Response

Defender for Cloud – Cross-Platform, Multi-Cloud XDR
Detection and response capabilities for infrastructure and development across IaaS, PaaS, and on-premises

Defender for APIs

People Security

Attack Simulator

Insider Risk Management

Communication Compliance

GitHub Advanced Security & Azure DevOps Security
Secure development and software supply chain

Microsoft Security Copilot

Threat Intelligence – 100+ Trillion signals per day of security context

Service Trust Portal – How Microsoft secures cloud services

Security Development Lifecycle (SDL)

✓ What's in Microsoft 365 E5



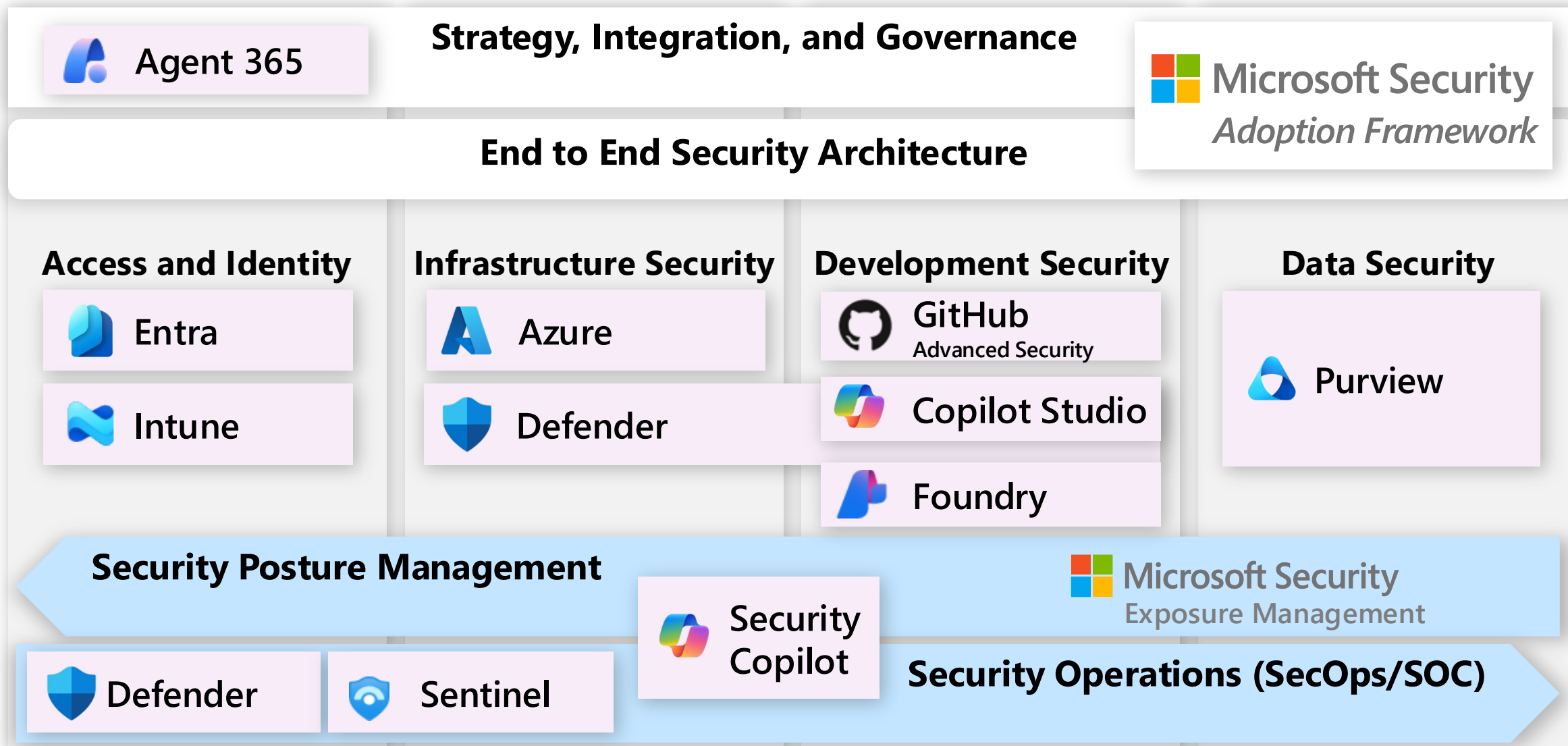
Product
Licensing
Details

June 2026 — <https://aka.ms/MCRA>

Product Name (& Previous Product Names)	Product Category(ies)	Security Modernization Initiative(s)
Microsoft Defender for Endpoint (MDE) <i>Formerly Microsoft Defender ATP, Windows Defender ATP, Windows Defender Antivirus</i>	Extended Detection and Response (XDR) Endpoint Detection and Response (EDR) Threat and Vulnerability Management (TVM) Endpoint Protection Platforms (EPP)	• Modern Security Operations • Infrastructure and Development • Security Hygiene: Backup and Patching
Microsoft Defender for Identity (MDI) <i>Formerly Azure ATP</i>	Extended Detection and Response (XDR)	• Modern Security Operations
Microsoft Defender for Office (MDO) <i>Formerly Office 365 ATP</i>	Extended Detection and Response (XDR)	• Modern Security Operations
Microsoft Defender for Cloud Apps (MDCA) <i>Formerly Microsoft Cloud App Security</i>	Cloud App Security Broker (CASB) Extended Detection and Response (XDR)	• Access and Identity • Modern Security Operations • Data Security
Entra ID (Formerly Azure AD) • Multifactor Authentication • Microsoft Entra Conditional Access • Self-service password management • Identity Protection • Identity Governance • Privileged Identity Management (PIM)	Access Management	• Access and Identity • Modern Security Operations
Microsoft Purview • Compliance Management • Data Lifecycle Management • eDiscovery and auditing • Insider Risk Management • Information Protection		• Data Security
Windows 10 & Windows 11 • Windows Hello for Business • Windows AutoPilot • Advanced Windows Security		• Access and Identity
Microsoft Intune	Unified Endpoint Management (UEM)	• Access and Identity

Product Families Enable Security Modernization

including AI Security



It's bad out there!

For sale in "bad neighborhoods" on the internet

Attacker techniques, business models, and skills/technology, are continuously evolving



Other Services

Continuous attack
supply chain innovation

Attacker for hire (per job)

\$250 per job (and up)

Ransomware Kits

\$66 upfront
(or 30% of the profit / affiliate model)

Compromised PCs / Devices

PC: \$0.13 to \$0.89
Mobile: \$0.82 to \$2.78

Spearphishing for hire

\$100 to \$1,000
(per successful account takeover)

Stolen Passwords

\$0.97 per 1,000 (average)
(Bulk: \$150 for 400M)

Denial of Service

\$766.67 per month

Attackers

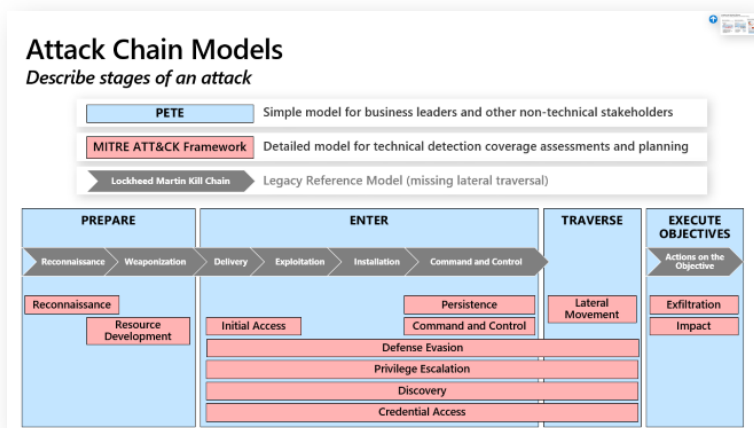
Many attack tools and
tutorials/videos available
for free on internet

Continuously Evolving Threats

Require consistency, visibility, prioritization, and continuous learning

Attack Chain Models

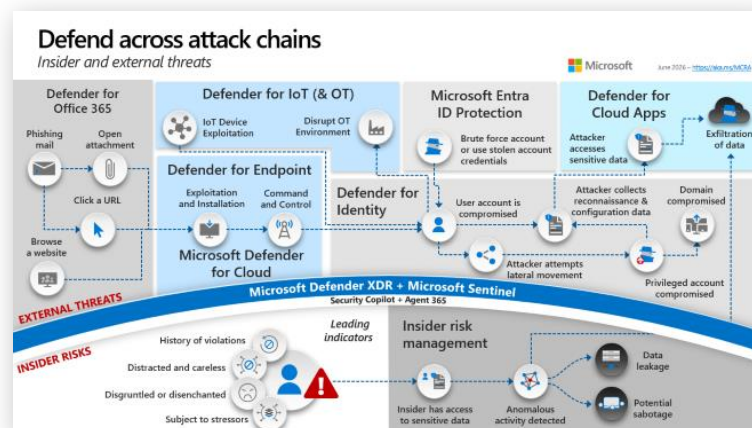
Consistently describe attacks & techniques



- Use MITRE Attack Framework to evaluate detection coverage
- Use PETE to describe incidents simply and consistently (including to business leaders)

Broad & Deep Visibility

Required across assets & techniques



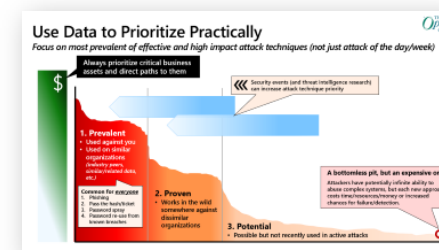
- Ensure visibility and coverage across asset types and common attack patterns



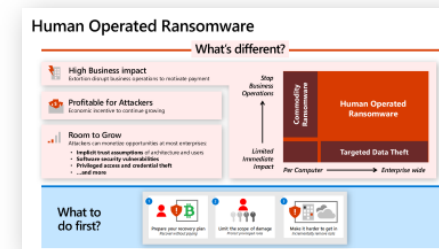
Build Slide

Prioritize Ruthlessly

Highest impact and likelihood first



- Avoid distractions

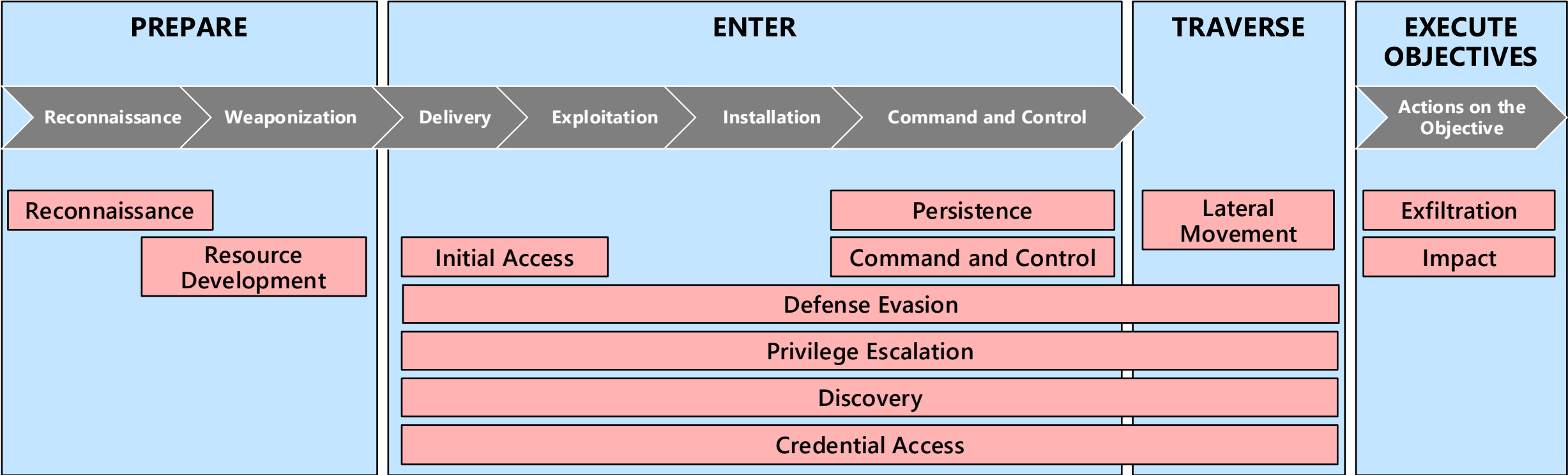


- Ransomware is top attack and defenses must be prioritized pragmatically
aka.ms/humanoperated

Attack Chain Models

Describe stages of an attack

PETE	Simple model for business leaders and other non-technical stakeholders
MITRE ATT&CK Framework	Detailed model for technical detection coverage assessments and planning
Lockheed Martin Kill Chain	Legacy Reference Model (missing lateral traversal)

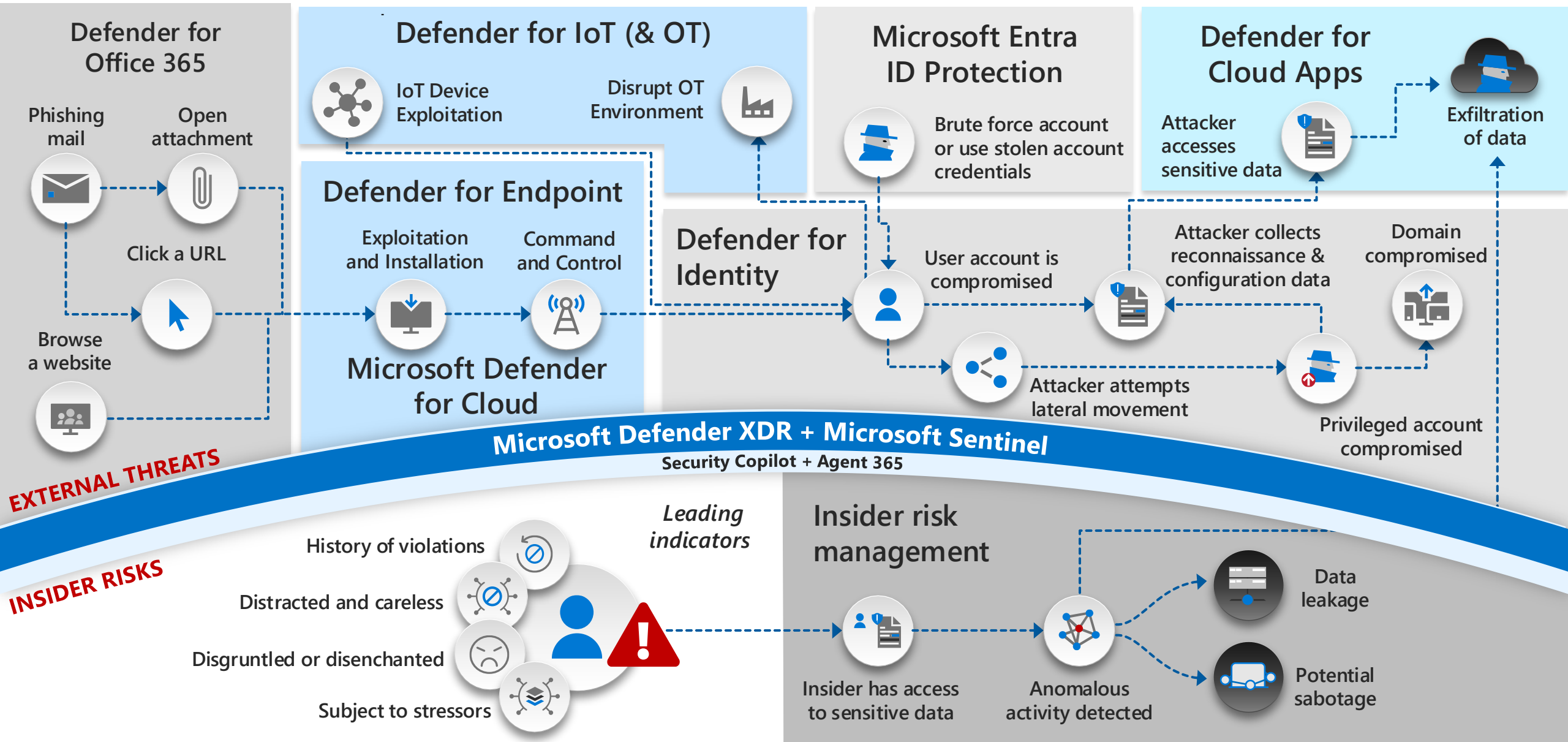


Defend across attack chains

Insider and external threats

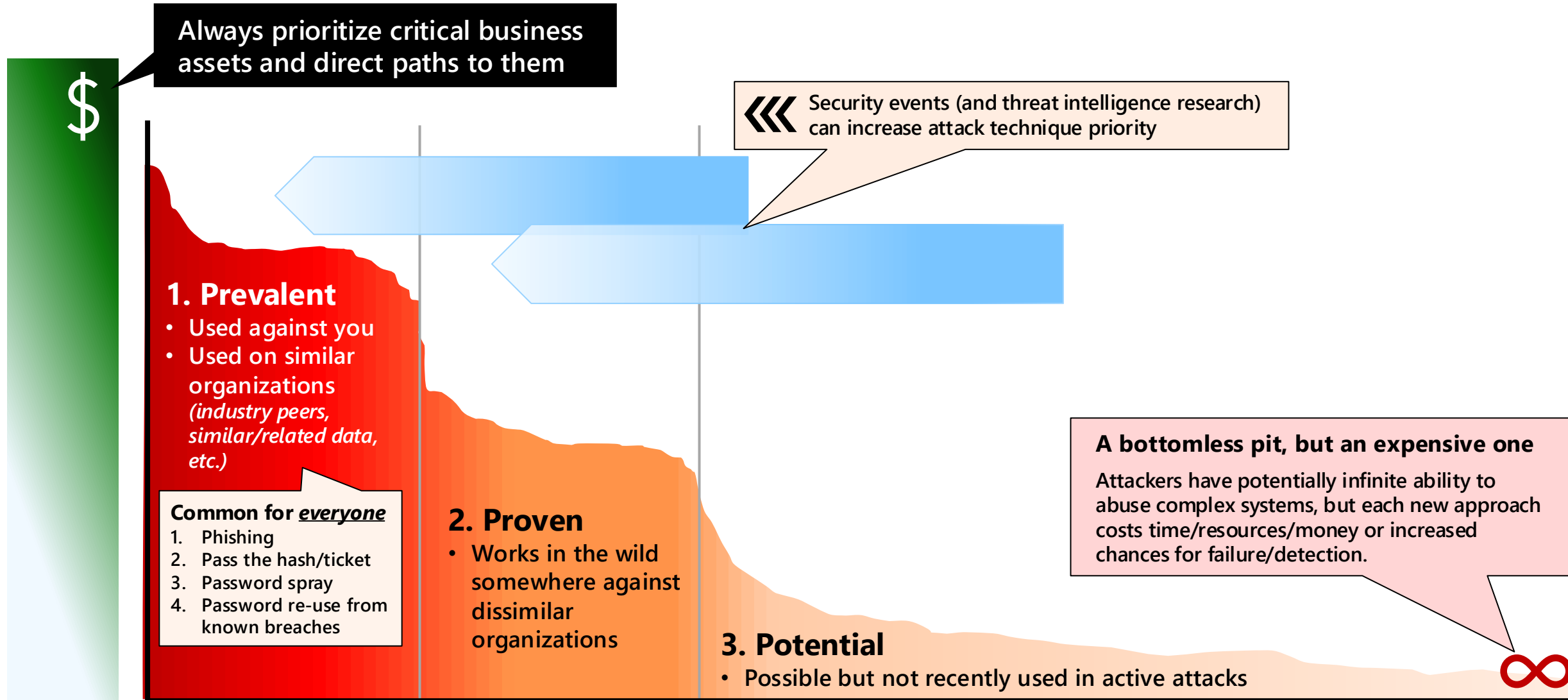


June 2026 – <https://aka.ms/MCRA>



Use Data to Prioritize Practically

Focus on most prevalent of effective and high impact attack techniques (not just attack of the day/week)



Human Operated Ransomware

What's different?



High Business impact

Extortion disrupt business operations to motivate payment



Profitable for Attackers

Economic incentive to continue growing



Room to Grow

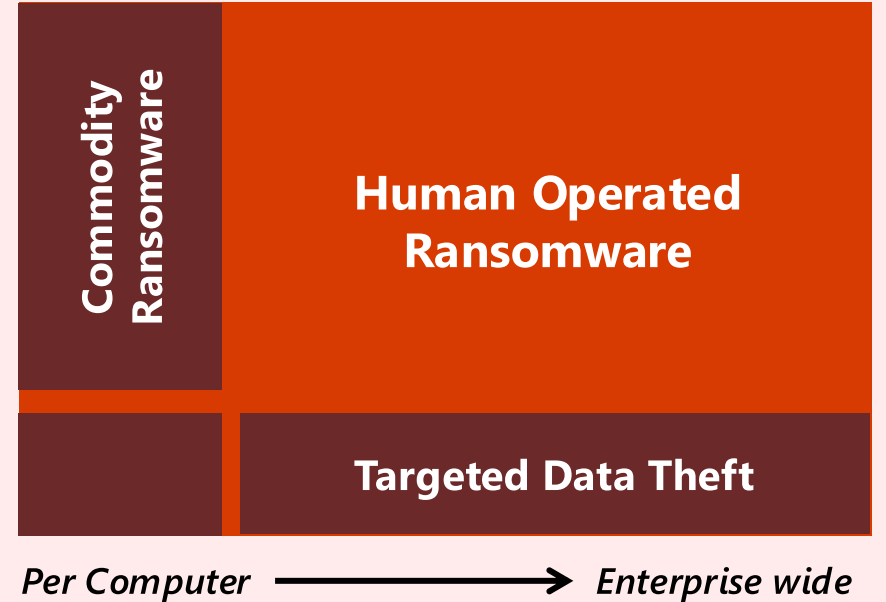
Attackers can monetize opportunities at most enterprises:

- **Implicit trust assumptions** of architecture and users
- **Software security vulnerabilities**
- **Privileged access and credential theft**
- ...and more

*Stop
Business
Operations*



*Limited
Immediate
Impact*



What to do first?

1



Prepare your recovery plan
Recover without paying

2



Limit the scope of damage
Protect privileged roles

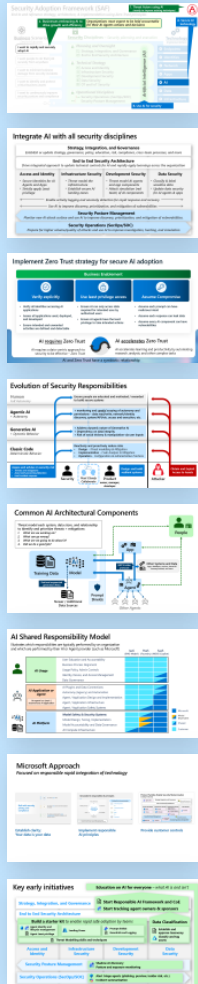
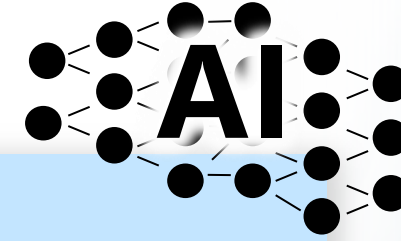
3



Make it harder to get in
Incrementally remove risks

Artificial Intelligence (AI) security

Architectural implications



Multiple types of security impacts

Affects all aspects of security

Requires and accelerates Zero Trust

Requires updating controls

Requires threat modelling systems

Requires managing a shared responsibility

Reference: Microsoft AI Approach

Recommendation: Key Early Priorities

Security Adoption Framework (SAF)

End to end reference strategy, architecture, & implementation using Zero Trust principles

1. Threat Actors using AI
(mostly to improve existing techniques)



2. Businesses embracing AI to drive growth and efficiency

Organizations must expect to be held accountable for their AI Agents actions and decisions

A. Secure AI technology



Business Scenarios

Desired Outcomes

I want to rapidly and securely adopt AI

I want people to do their job securely from anywhere

I want to minimize business damage from security incidents

I want to identify and protect critical business assets

I want to continuously improve security posture and compliance



Security Disciplines – Security planning and execution



Planning and Oversight



Strategy, Integration, and Governance



End to End Security Architecture



Technical Strategy



Access and Identity



Infrastructure Security



Development Security



Data Security



OT and IoT Security



Operational Disciplines



Security Operations (SecOps/SOC)



Security Posture Management

Artificial Intelligence (AI)



Technology Implementation

Implementation



Endpoints



Identities



Network



Apps



AI



Data



Infrastructure

B. Use AI for security

Integrate AI with all security disciplines

Strategy, Integration, and Governance

Establish or update strategy, governance, policy, education, risk, compliance, cross-team processes, and more

End to End Security Architecture

Drive integrated approach to update technical controls for AI and rapidly apply learnings across the organization

Access and Identity

- *Secure Identities for AI Agents and Apps*
- *Strictly apply Least privilege*

Infrastructure Security

- *Threat model the infrastructure*
- *Establish secure AI landing zones*

Development Security

- *Threat model AI agents and app components*
- *Attack simulation (red team) of AI components*

Data Security

- *Classify & label sensitive data*
- *Update data security for AI agents & apps*

← *Enable activity logging and anomaly detection for rapid response and recovery* →

← *Use AI to improve discovery, prioritization, and mitigation of vulnerabilities* →

Security Posture Management

Monitor new AI attack surface and use AI to improve discovery, prioritization, and mitigation of vulnerabilities.

Security Operations (SecOps/SOC)

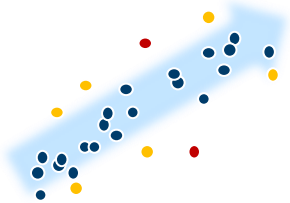
Prepare for higher volume/quality of attacks and use AI to improve investigation, hunting, and simulation

Key Differences of Generative AI Apps and Agents



Data-centric – GenAI is a data analysis and data generation technology

Increases prioritization of data classification and security to protect against unauthorized data losses, data poisoning attacks, and more.



Stochastic – GenAI results in similar, but not identical output (for the same inputs)

Requires redesigning policy and controls that assume all software is deterministic



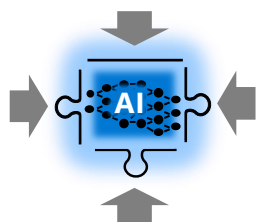
Social Processing – GenAI is based on social data (publications and communications)

Introduces social trickery vulnerabilities + risk of bias and deception for outputs



Human Language Interface and Programming – used for execution of AI tasks

Enables people to do more advanced tasks (and mitigate new risks resulting from them)



Over-capable – GenAI models have more capabilities than any app needs

Requires constrain-by-default programming + additional guardrails to govern GenAI

Evolution of Security Responsibilities

Human
Full Autonomy

Ensure people are educated and motivated / rewarded to build secure systems

Agentic AI
+ Autonomy

+ monitoring and careful scoping of autonomy and permissions – data read/write, network/identity discovery, system/API/etc. access and execution, etc.

Generative AI
+ Dynamic Behavior

+ Address dynamic nature of Generative AI
+ Dependency on data integrity
+ Risk of social trickery & manipulation via user inputs

Classic Code
Deterministic Behavior

Reactively and proactively reduce risks

- Design - *Threat modelling & Mitigation*
- Implementation - *Code Analysis & Mitigation*
- Operation - *Configuration & administrative Practices*

Assess and advise on security risk

- *Threats and mitigations*
- *Assist with prevention/detection*
- *Lead incident response*



Design and build resilient systems



Obtain and Exploit Access to Assets

Implement Zero Trust strategy for secure AI adoption

Business Enablement



Verify explicitly

- Verify all identities accessing AI applications
- Assess all applications used, deployed, and developed
- Ensure intended and unwanted activities are defined and detectable



Use least privilege access

- Ensure AI can only access data required for intended uses by authorized users
- Ensure AI agents have the least privilege to take intended actions

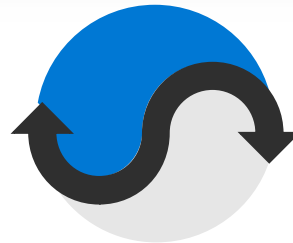


Assume Compromise

- Assume each prompt can have malicious intent
- Assume each response can leak data
- Assume every AI component can have vulnerabilities

AI requires Zero Trust

AI requires a data-centric approach to security to be effective – *Zero Trust*



AI accelerates Zero Trust

AI accelerates learning and productivity by automating research, analysis, and other complex tasks

AI and Zero Trust have a symbiotic relationship

AI Shared Responsibility Model

Illustrates which responsibilities are typically performed by an organization and which are performed by their AI or Agent provider (such as Microsoft)

		IaaS (BYO Model)	PaaS (Foundry)	SaaS (M365 Copilot)
	AI Usage User Education and Accountability Business Process Alignment Usage Policy, Admin Controls Identity, Device, and Access Management Data Governance			
	AI Application or Agent An agent is a (semi-) autonomous AI application AI Plugins and Data Connections Autonomy (Agency) and Automation Agent / Application Design and Implementation Agent / Application Infrastructure Agent / Application Safety Systems			
 	AI Platform Model Safety & Security Systems Model Design, Tuning, Implementation Model Accountability and Data Governance AI Compute Infrastructure			

 Microsoft

 Model Dependent

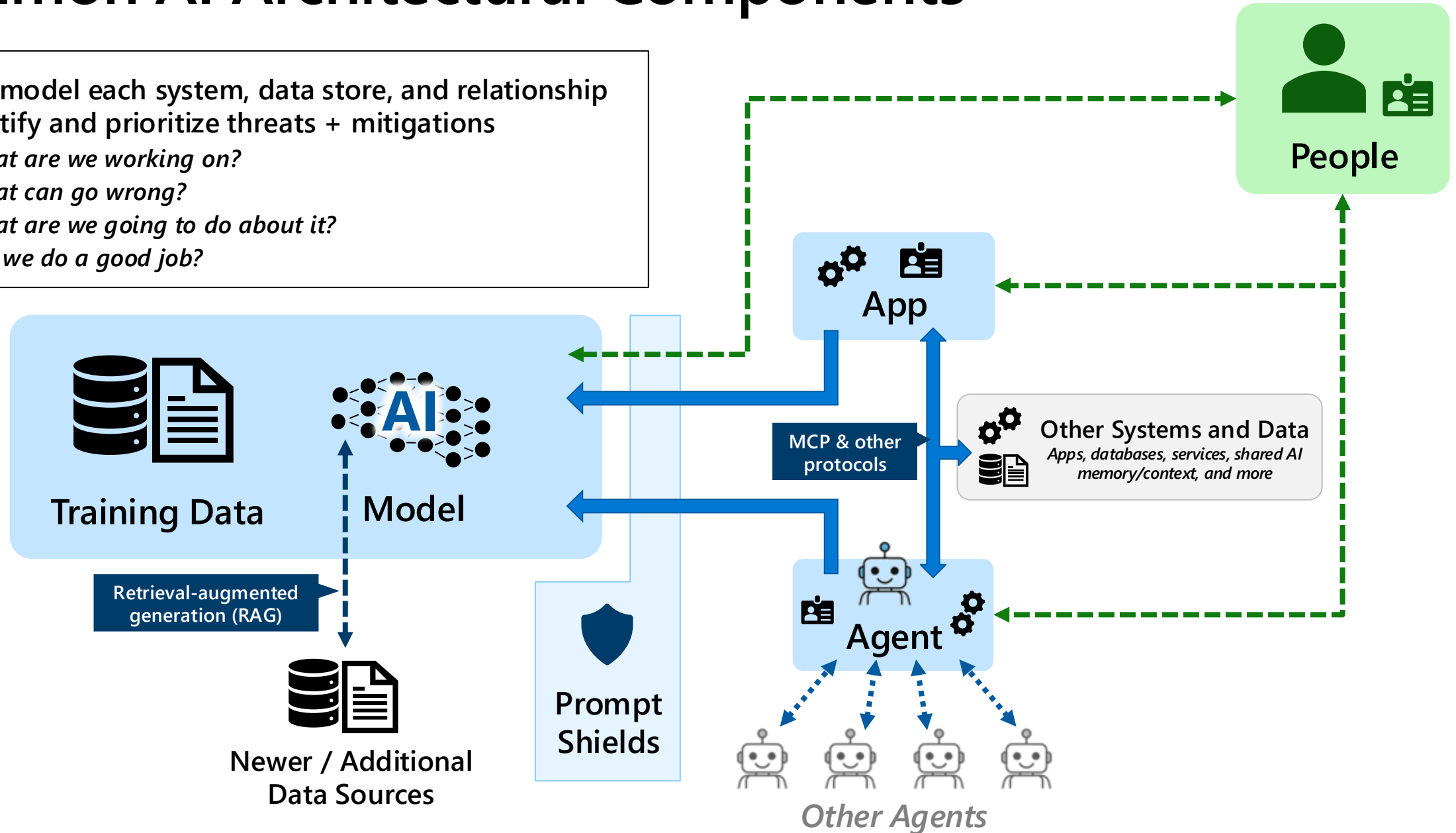
 Shared

 Customer

Common AI Architectural Components

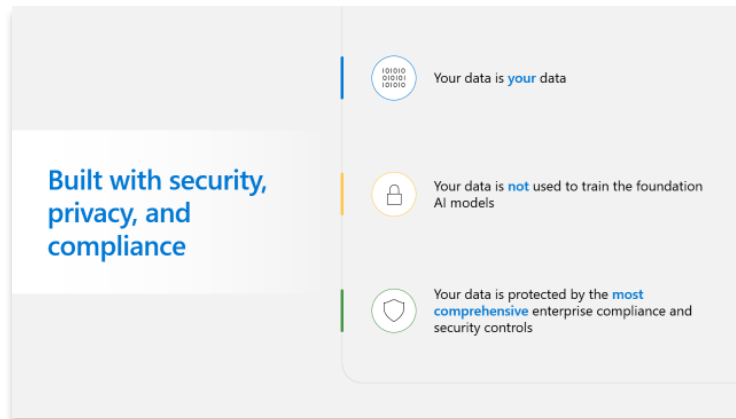
Threat model each system, data store, and relationship to identify and prioritize threats + mitigations

1. *What are we working on?*
2. *What can go wrong?*
3. *What are we going to do about it?*
4. *Did we do a good job?*

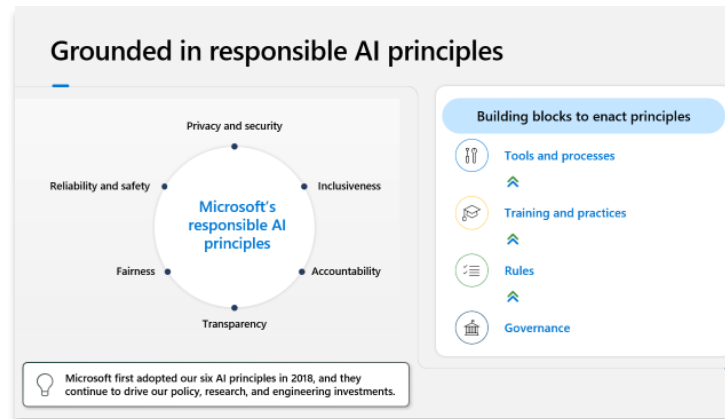


Microsoft Approach

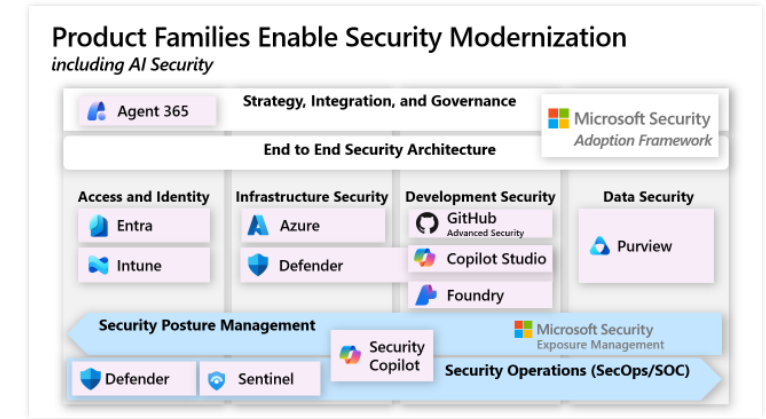
Focused on responsible rapid integration of technology



Establish clarity:
Your data is your data

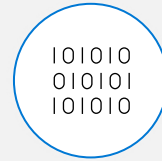


Implement responsible
AI principles



Provide customer controls

Built with security, privacy, and compliance



Your data is **your** data

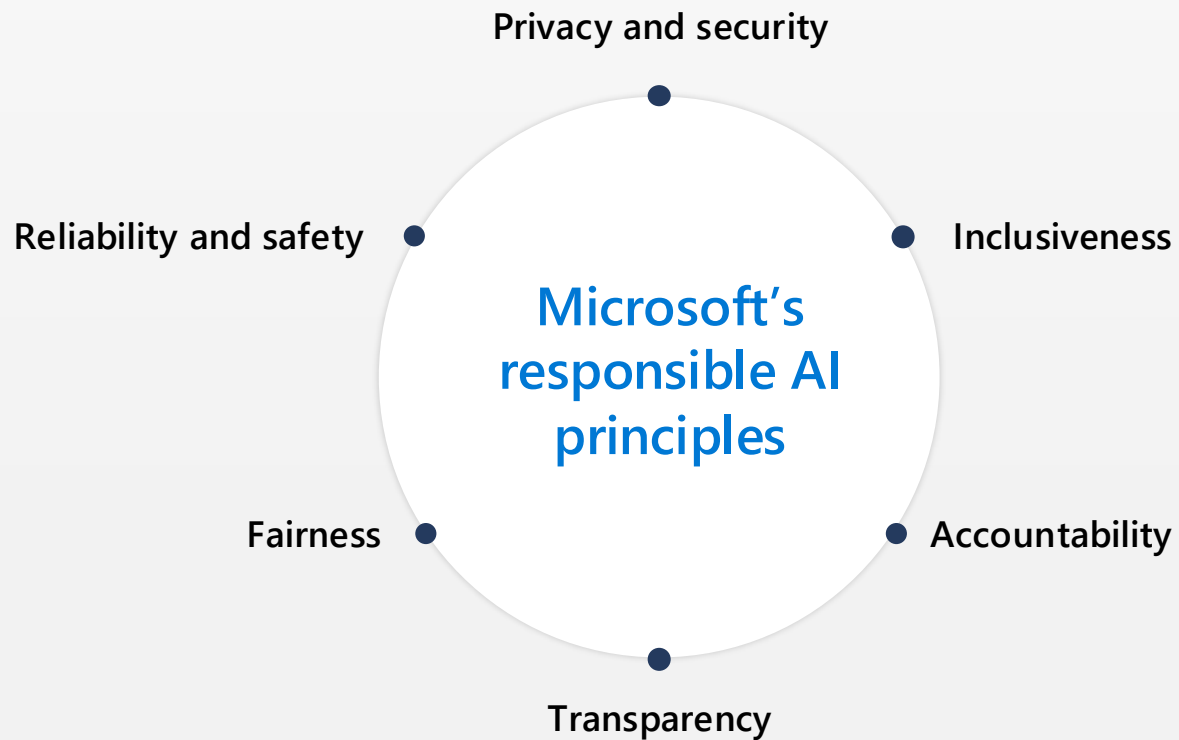


Your data is **not** used to train the foundation AI models

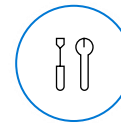


Your data is protected by the **most comprehensive** enterprise compliance and security controls

Grounded in responsible AI principles



Building blocks to enact principles



Tools and processes



Training and practices



Rules



Governance



Microsoft first adopted our six AI principles in 2018, and they continue to drive our policy, research, and engineering investments.

Key early initiatives

Education on AI for everyone – *what AI is and isn't*

Strategy, Integration, and Governance

-  **Start Responsible AI Framework and CoE**
-  **Start tracking agent owners & sponsors**

End to End Security Architecture

Build a starter kit *to enable rapid safe adoption by teams*

-   **Agent identity and lifecycle management**
-  **Agent Least privilege**

 **Landing Zones**

-  **Prompt shields**
-  **Guardrails and Logging**

-  **Threat Modelling skills and techniques**

Data Classification

-  **Establish and approve taxonomy**
-  **Classify and tag assets**

Access and Identity

Infrastructure Security

Development Security

Data Security

Security Posture Management

-  **Shadow AI discovery**
- Posture and exposure monitoring**

Security Operations (SecOps/SOC)

-  **Alert triage agents (phishing, purview, insider risk, etc.)**
-  **Incident summarization**

Review – Artificial Intelligence (AI)

- GenAI enables a new interface (natural language)
 - *Makes technology easier to use and learn*
 - *Enables people to do more advanced tasks*
- Critical to adapt quickly to this technology
 - *Educate on and mitigate attacker use of AI*
 - *Embrace security use of AI*
 - *Protect business use of AI*
- Securing AI is a shared responsibility
- Microsoft Approach to AI
 - *Establish clarity: your data is your data*
 - *Implement responsible AI principles*
 - *Focus initial security priorities on greatest needs*



AI Resources and References



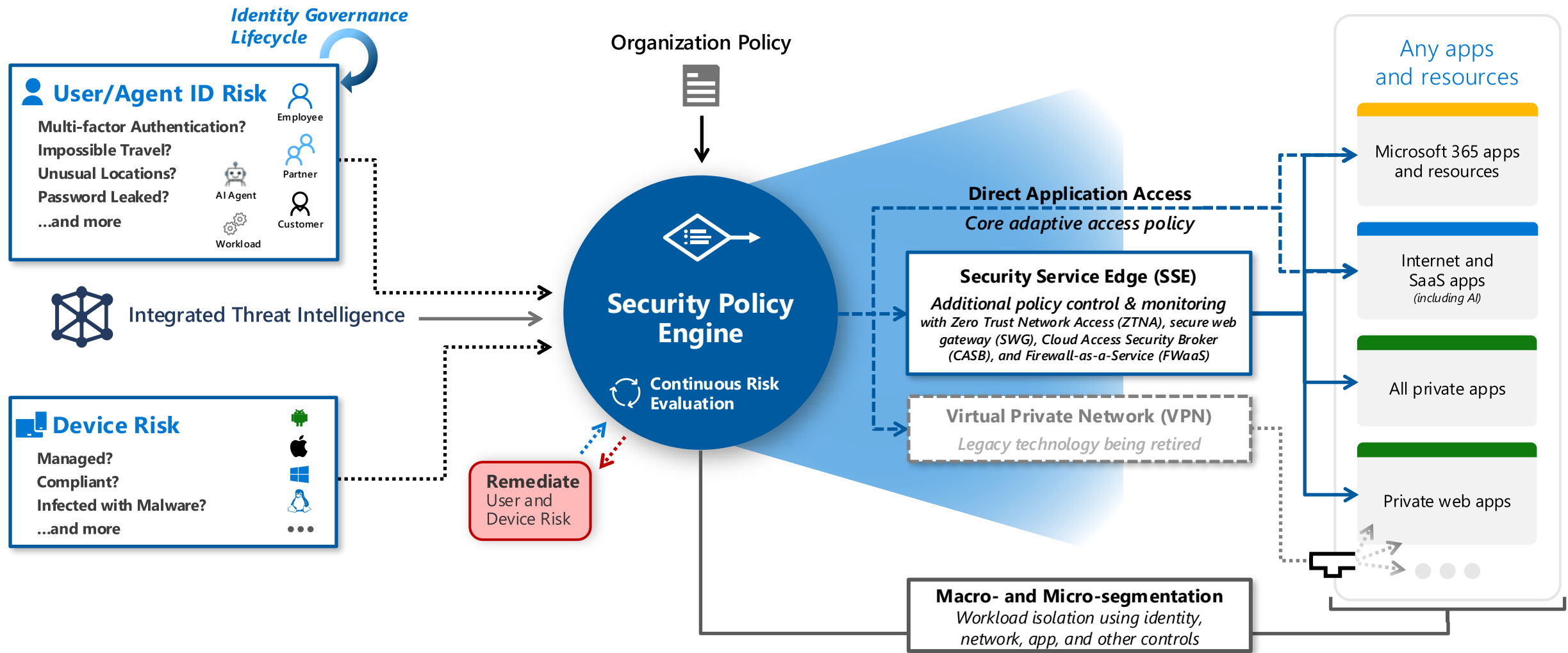
Access Management Capabilities

Adaptive Access applying Zero Trust Principles

Legend

- Trust Signal
- Adaptive Access Policy
- Threat Intelligence
- Additional Policy & Monitoring

Can be implemented today using Microsoft and partner capabilities



Signal

to make an informed decision



Decision

based on organizational policy



Enablement and Enforcement

of policy across resources

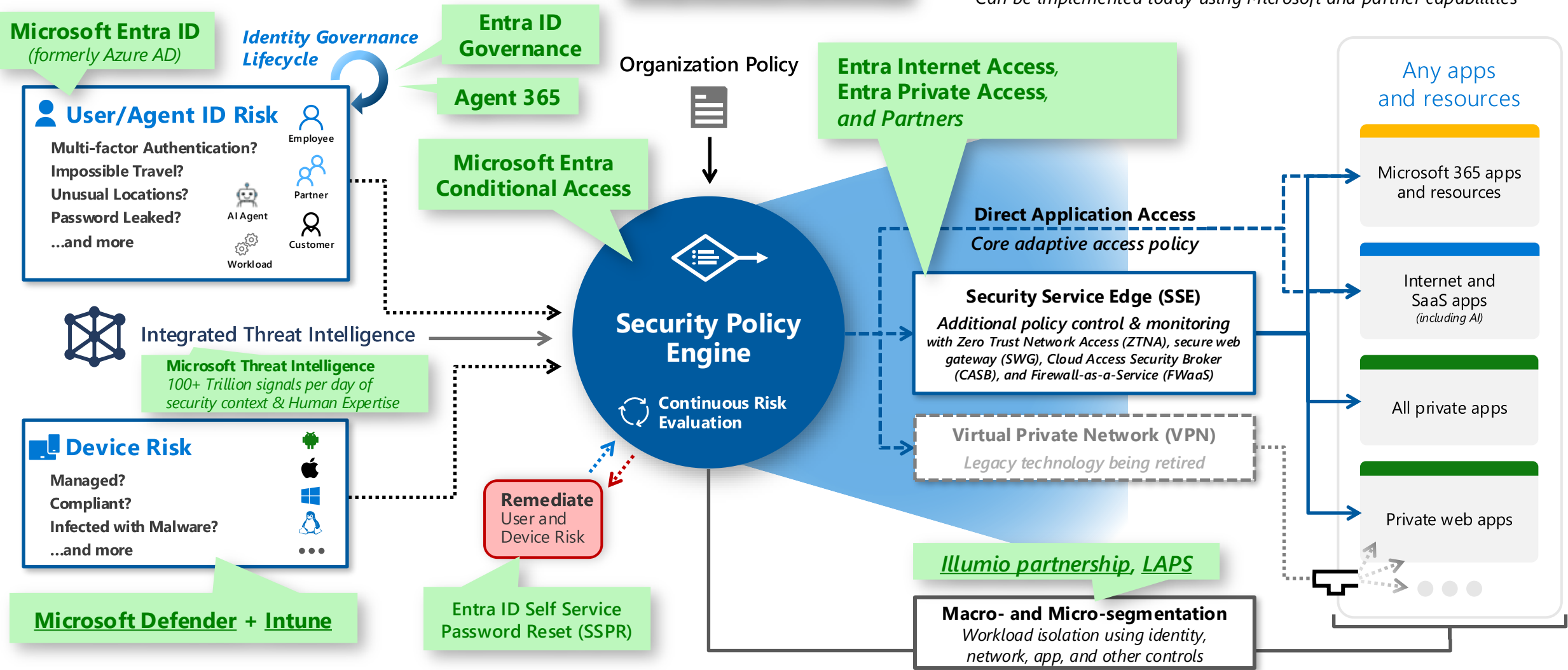
Access Management Capabilities

Adaptive Access applying Zero Trust Principles *Using Microsoft Technology*

Legend

- Trust Signal
- Adaptive Access Policy
- Threat Intelligence
- Additional Policy & Monitoring

Can be implemented today using Microsoft and partner capabilities



Signal

to make an informed decision



Decision

based on organizational policy

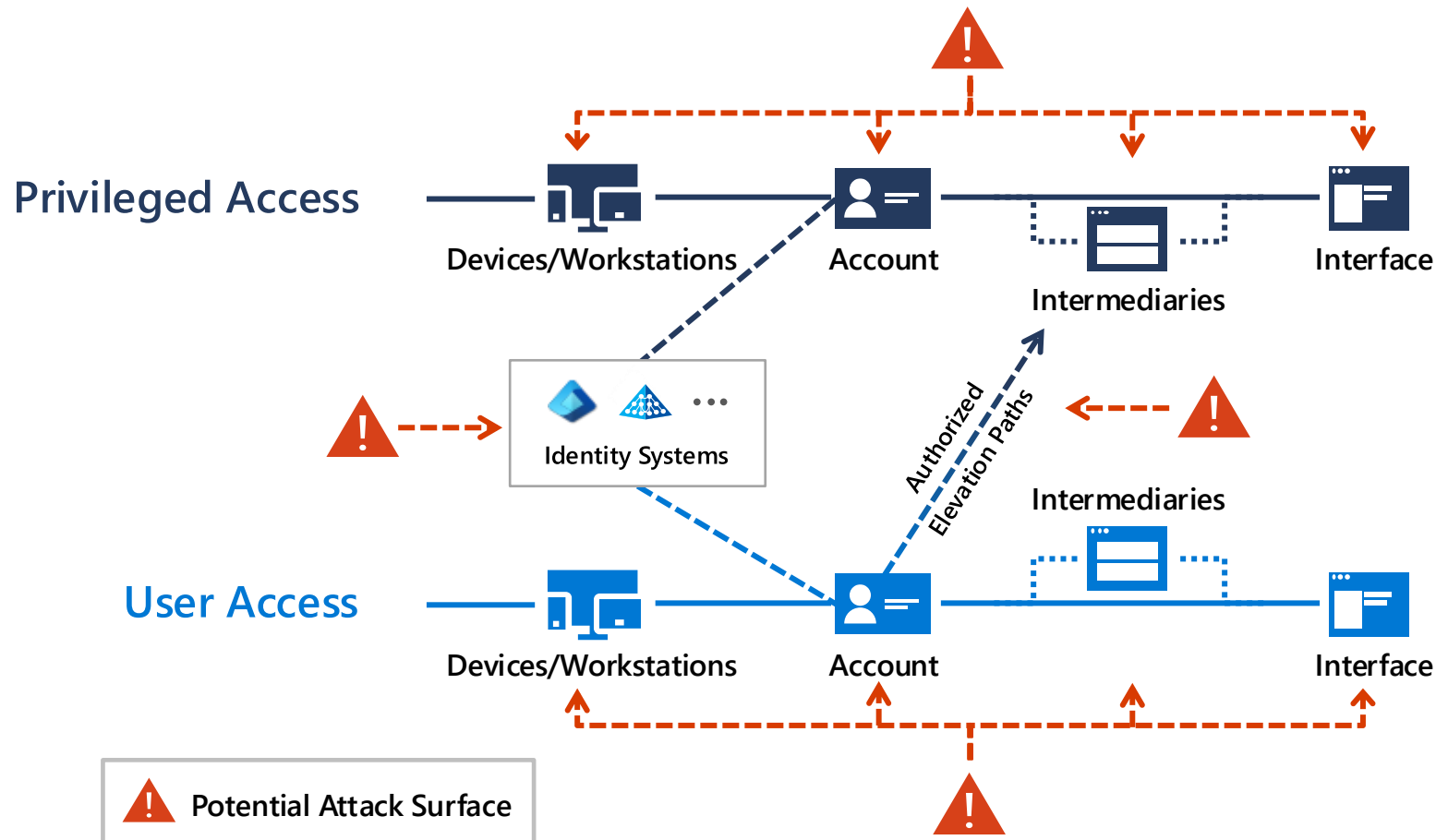


Enablement and Enforcement

of policy across resources

Attackers have options

to compromise privileged access



Business Critical Assets

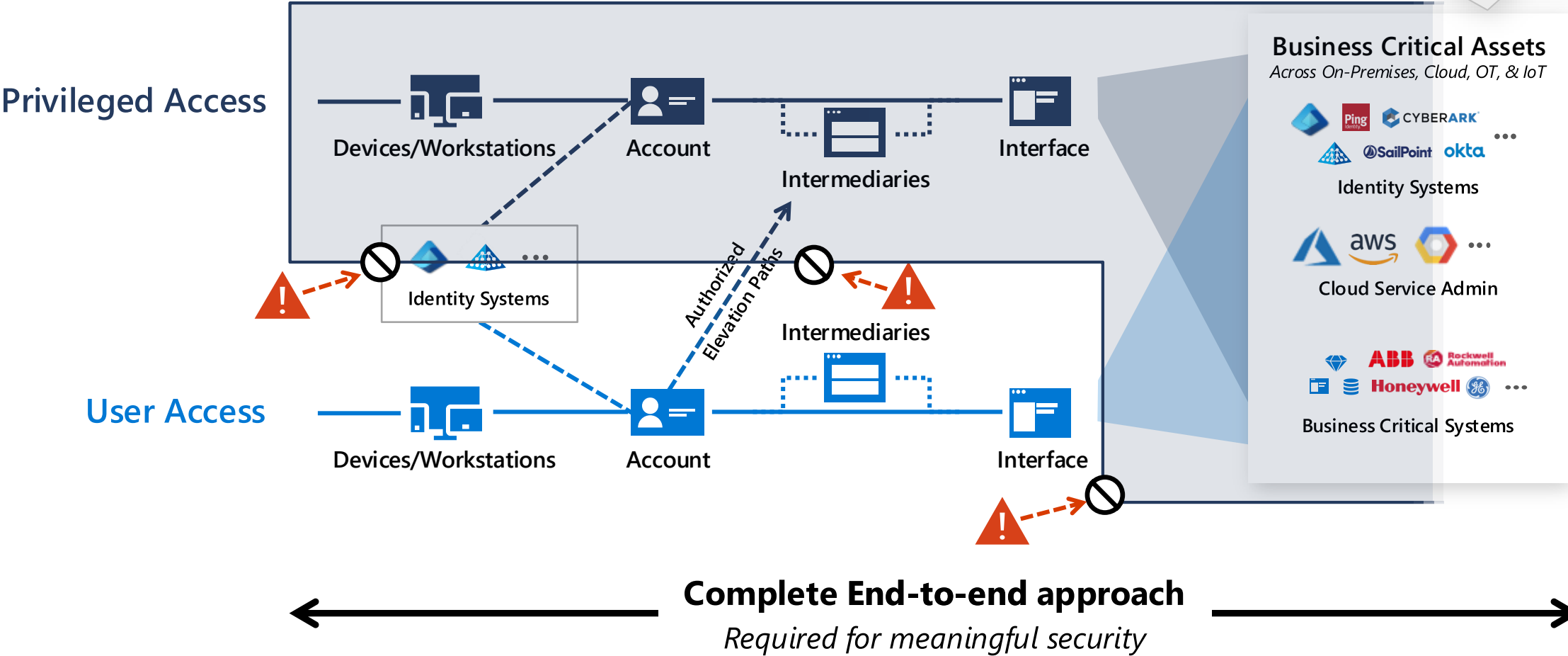
Across On-Premises, Cloud, OT, & IoT



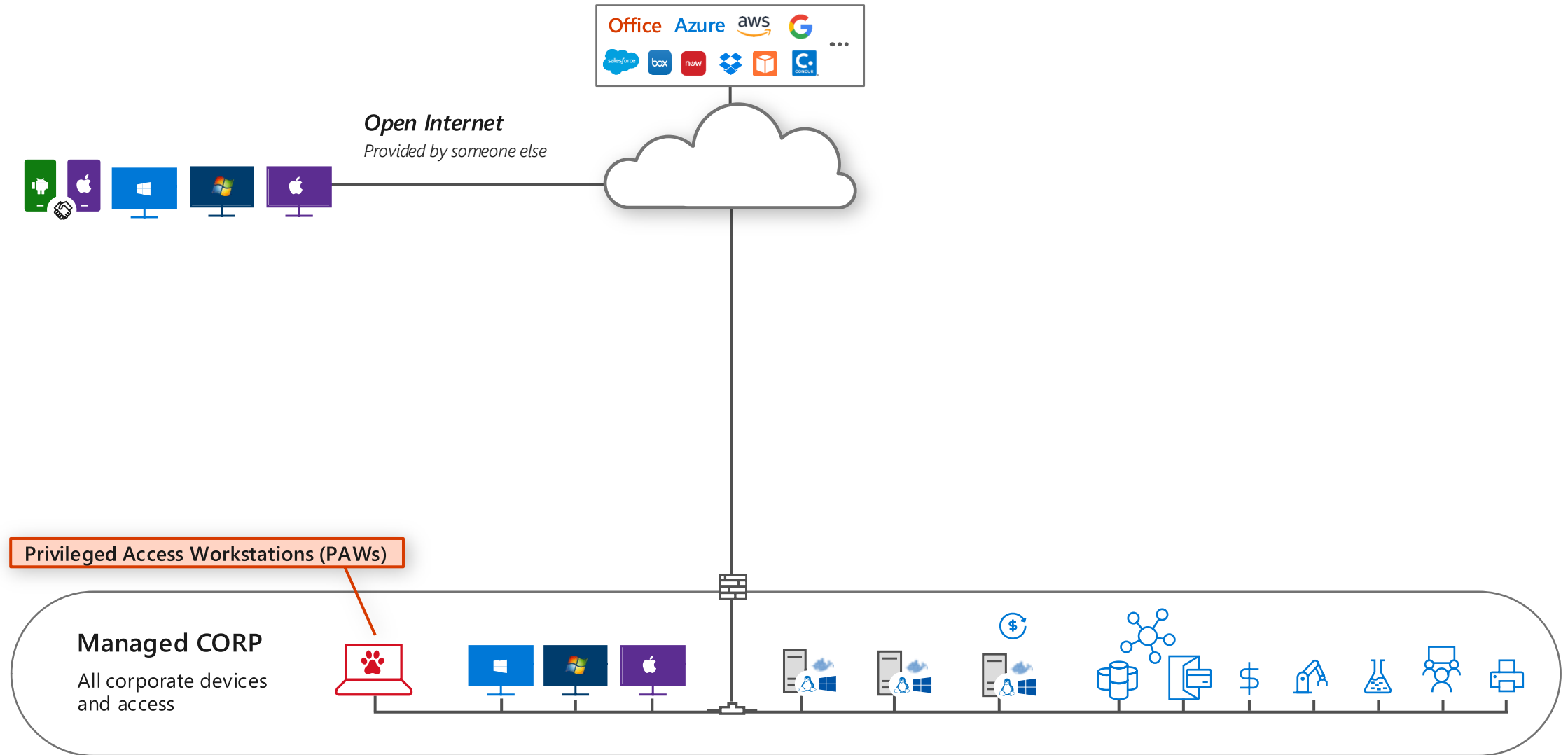
Limit and protect pathways to privileged access

Prevention and rapid response

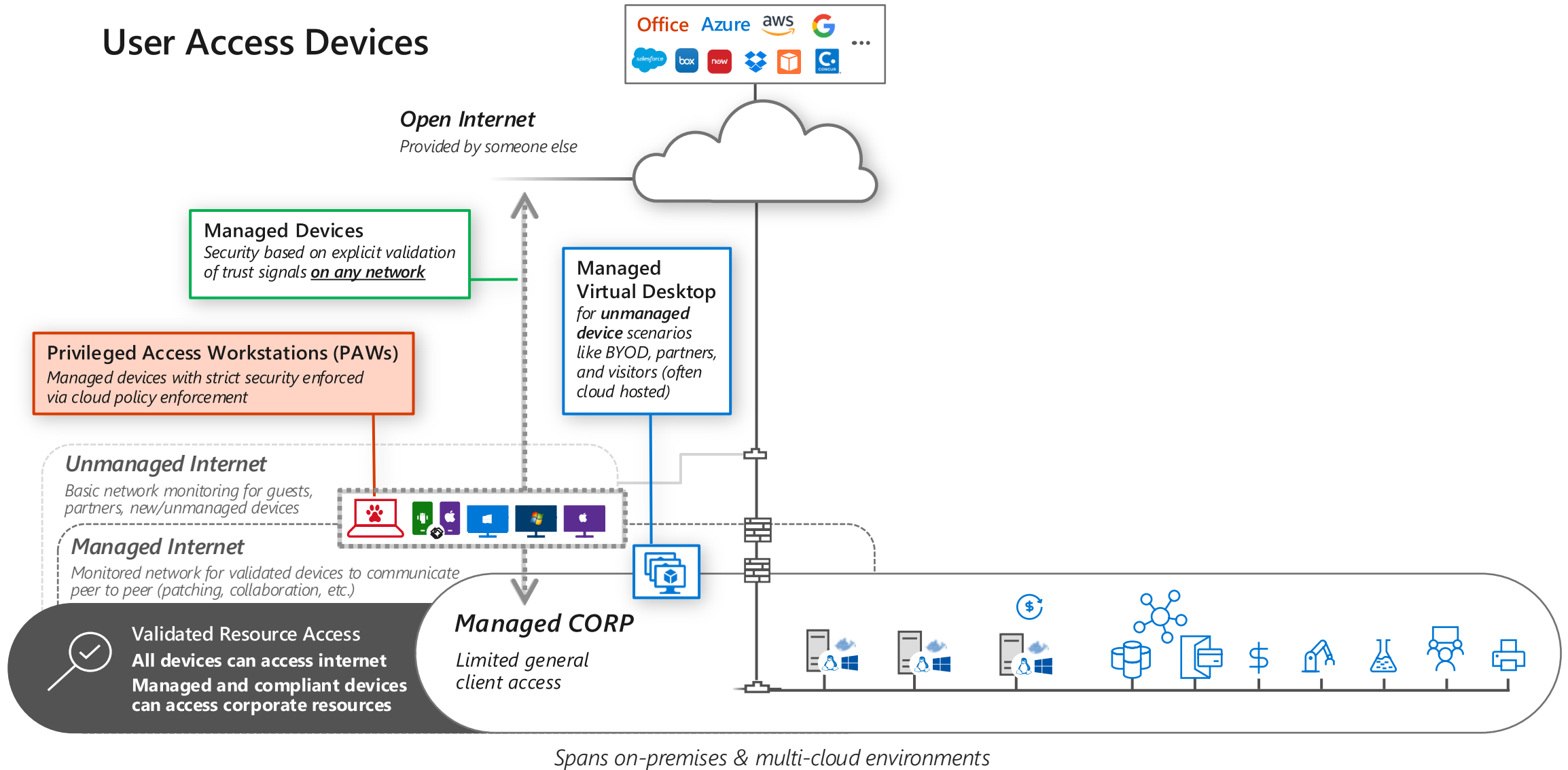
Asset Protection also required
*Security updates, DevSecOps,
data at rest / in transit, etc.*



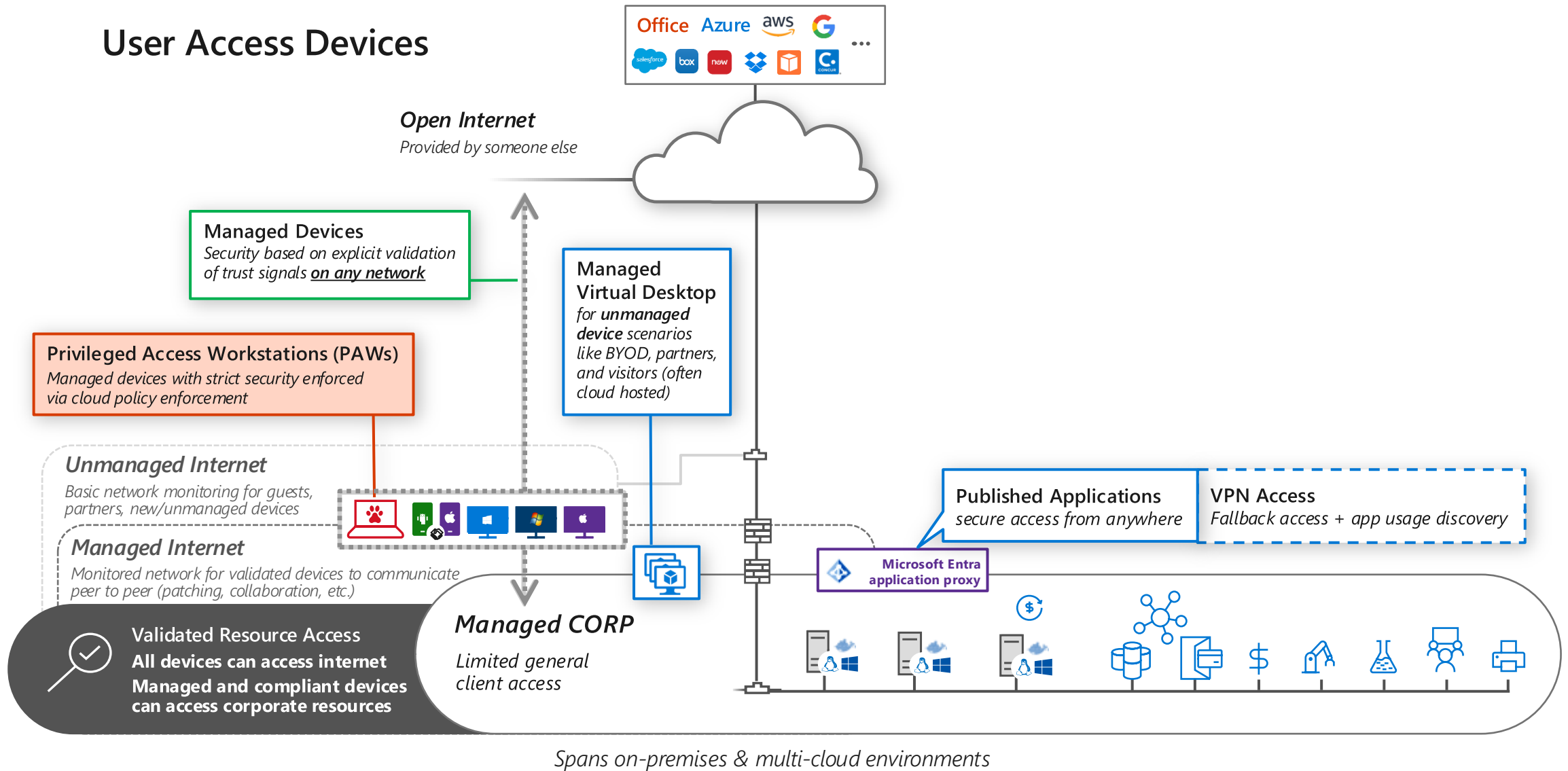
Typical 'Flat' Network



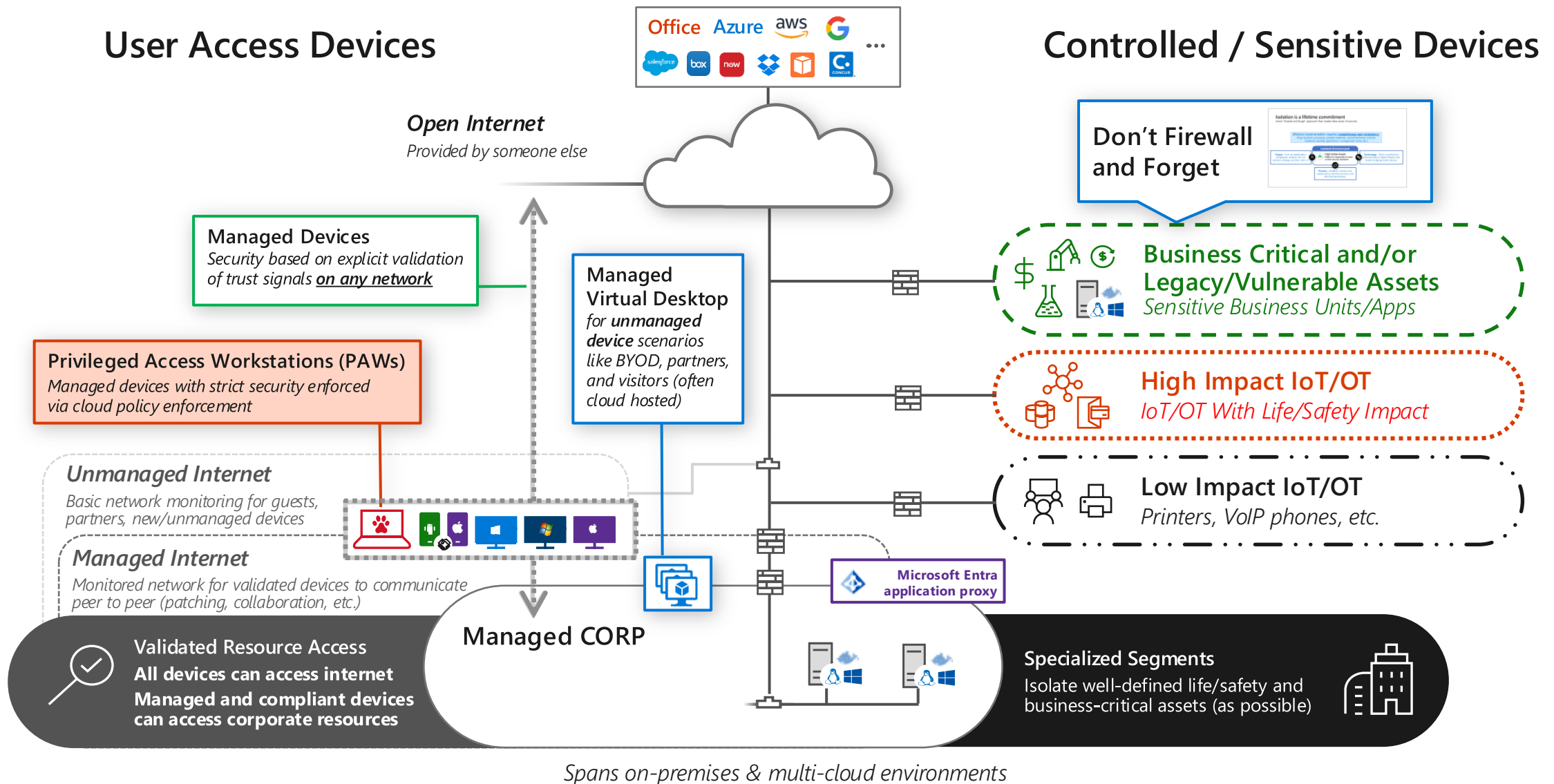
Zero Trust – Client Security Transformation



Zero Trust – App Access for Clients



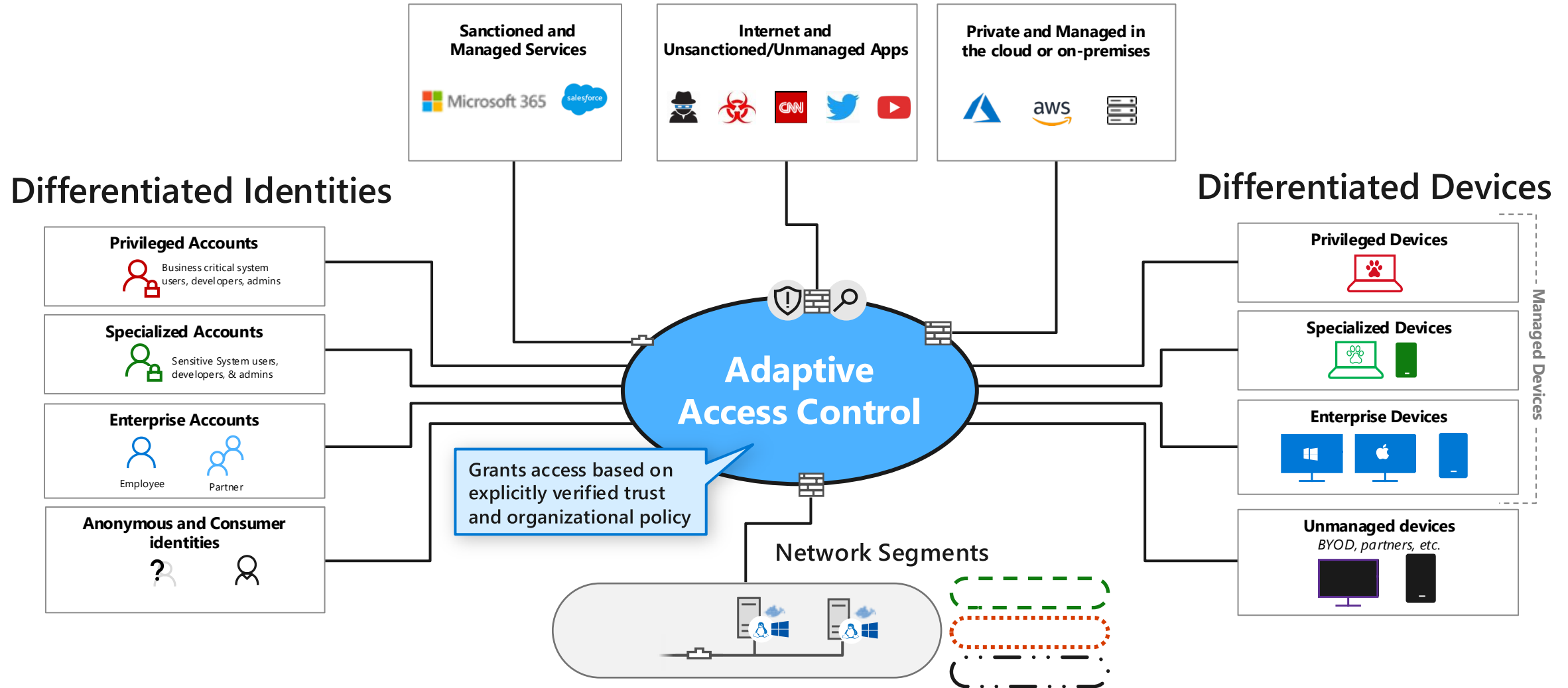
Zero Trust – Network Segment Transformation



End State - Secure Access and Identity

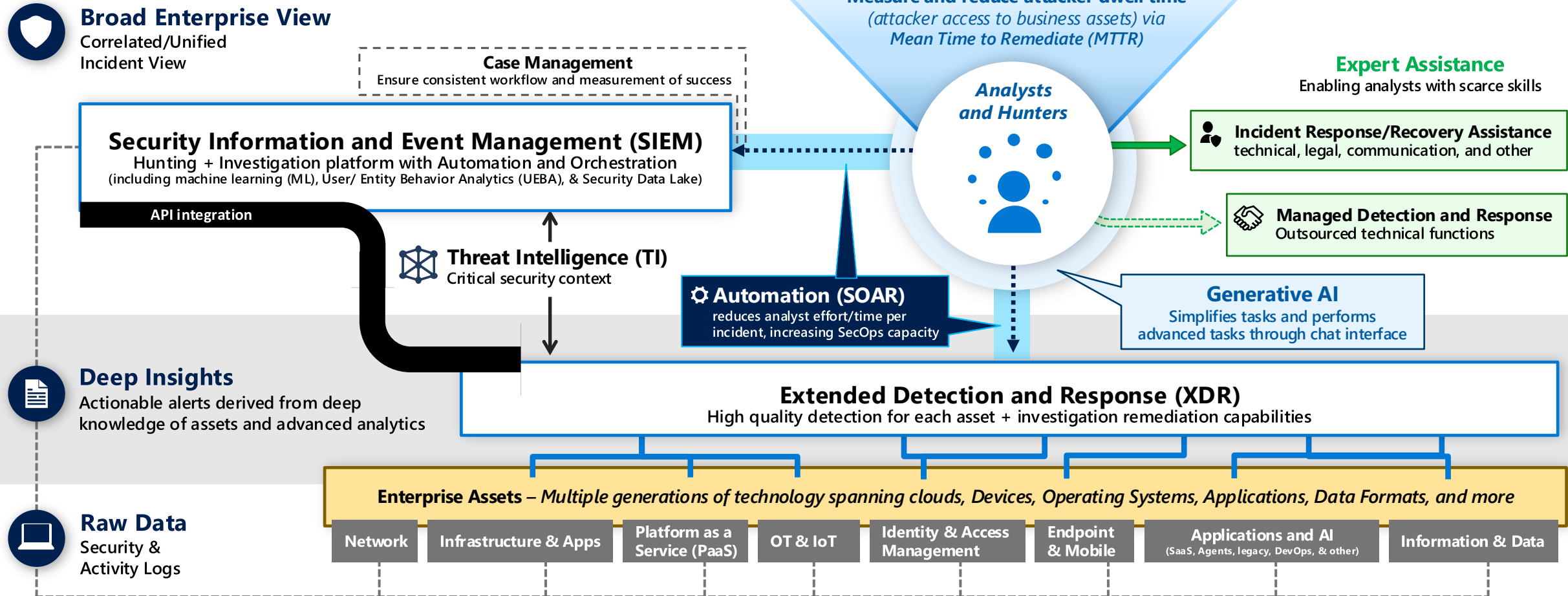
Full Adaptive Access bridging both worlds and fulfilling Zero Trust and SASE visions

Differentiated Resources



Security Operations Capabilities

Enabling a people-centric function focused rapid remediation of realized risk



Security Operations

Microsoft Reference Architecture

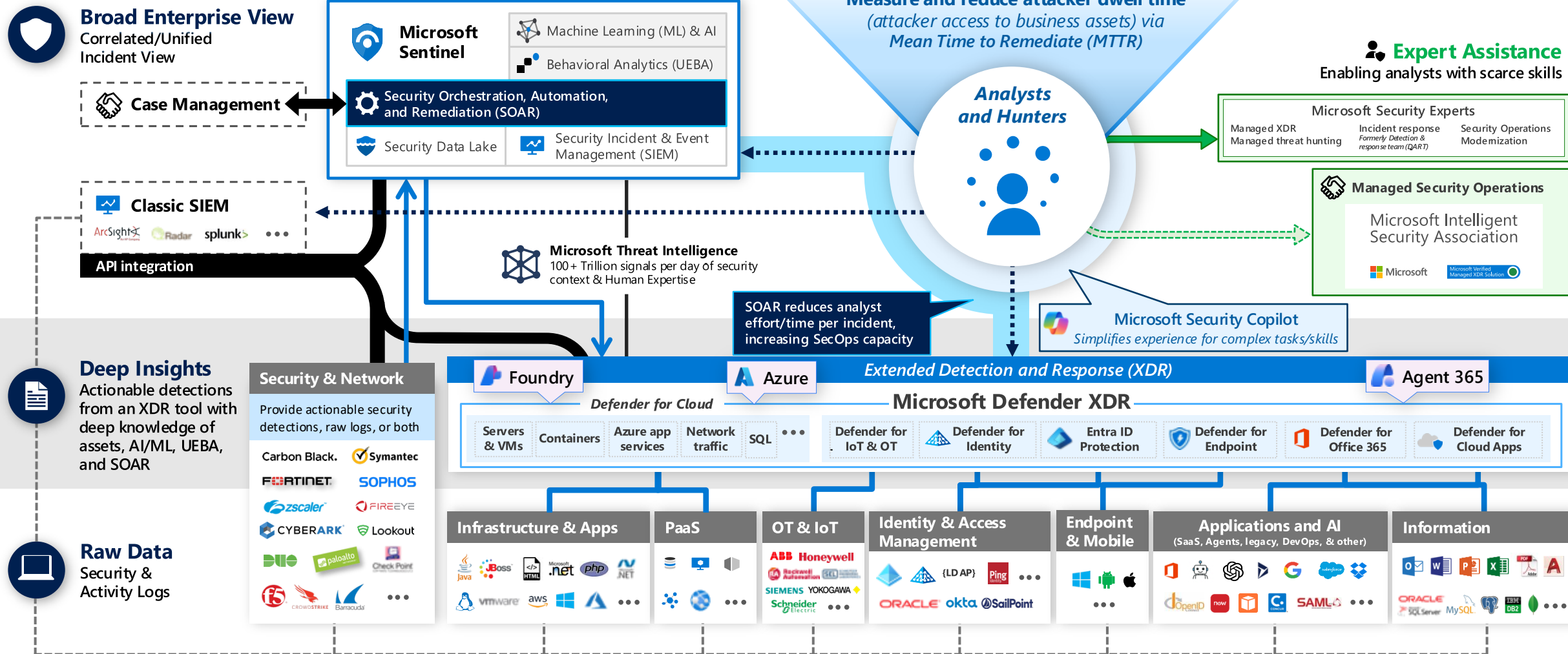
Legend

- Event Log Based Monitoring
- Investigation & Proactive Hunting

- Outsourcing
- Consulting and Escalation
- Native Resource Monitoring

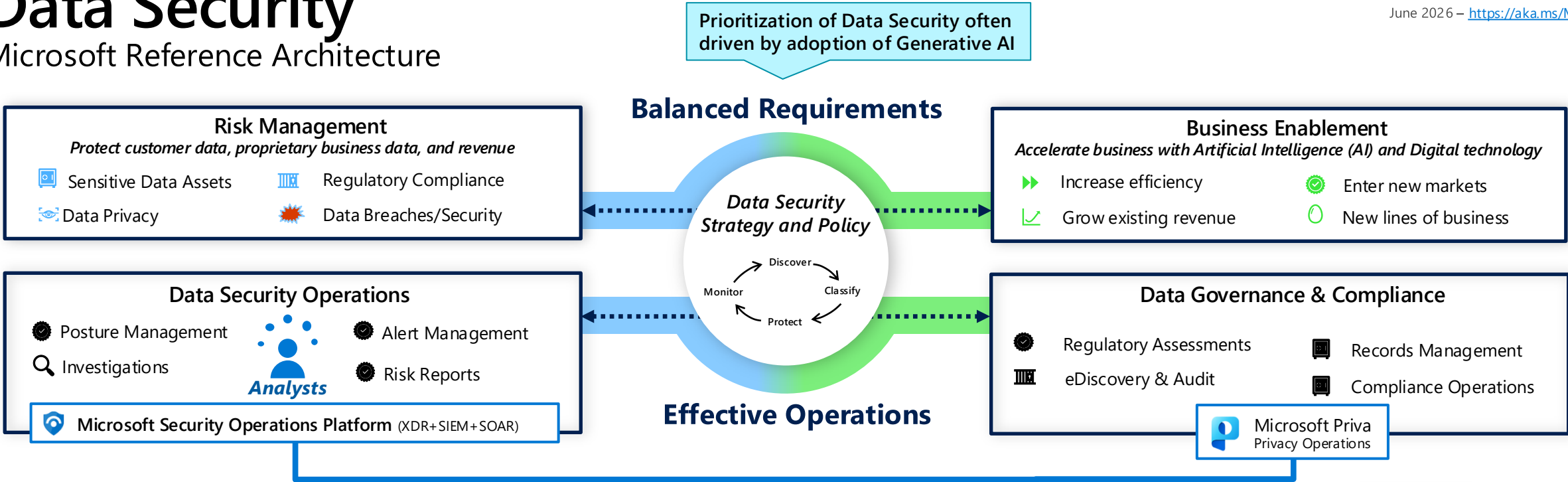


June 2026 – <https://aka.ms/MCRA>

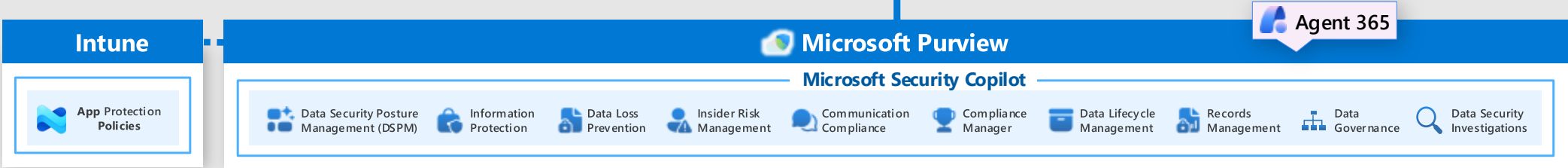


Data Security

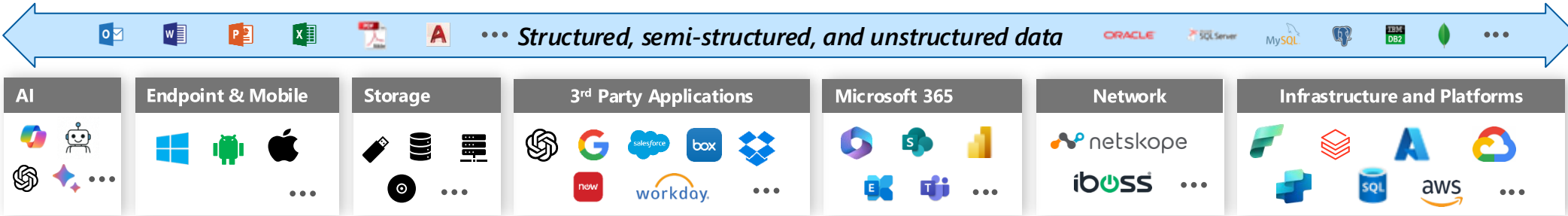
Microsoft Reference Architecture



Data Security Management
Risk assessment and mitigation across sensitive data assets

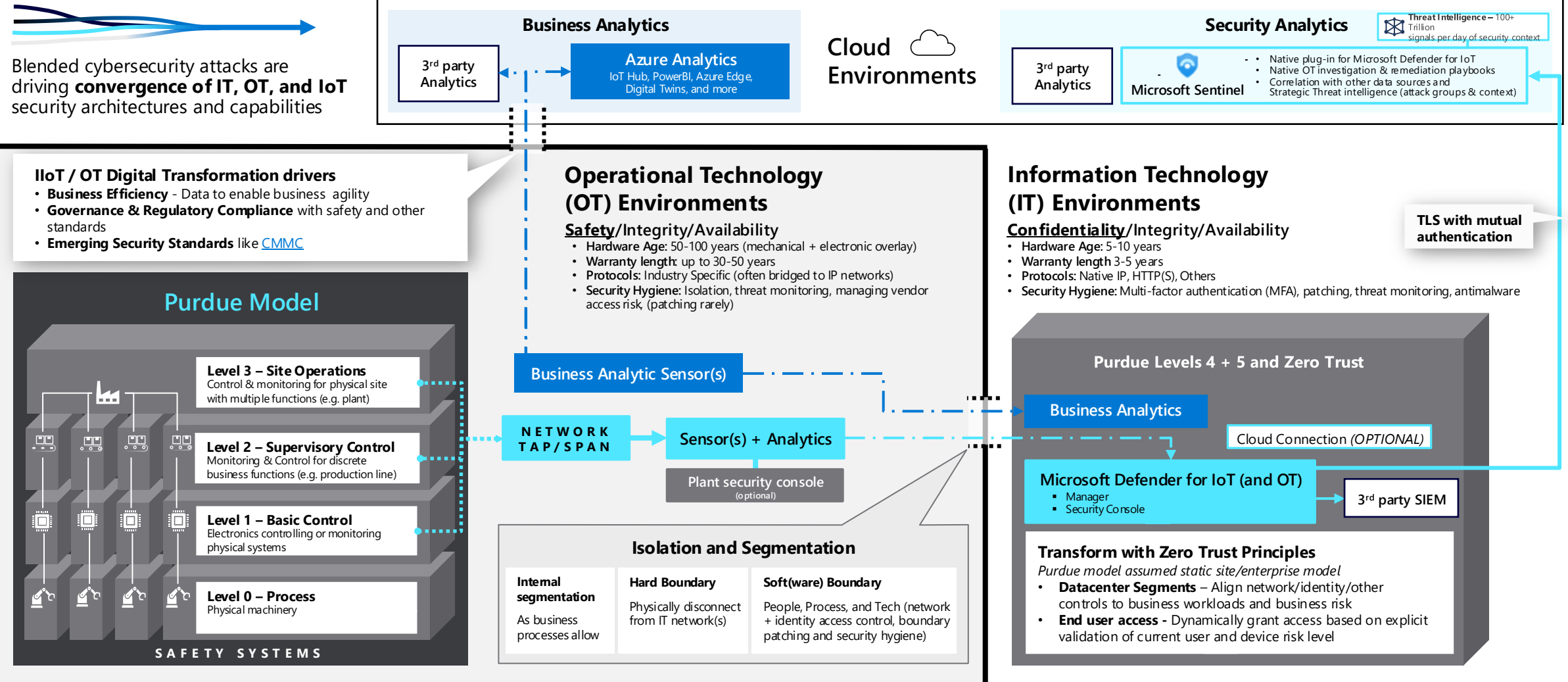


Data Estate
Data sources, storage, and processing



Operational Technology (OT) Security Reference Architecture

Apply zero trust principles to securing OT and industrial IoT environments



Infrastructure Security Capabilities

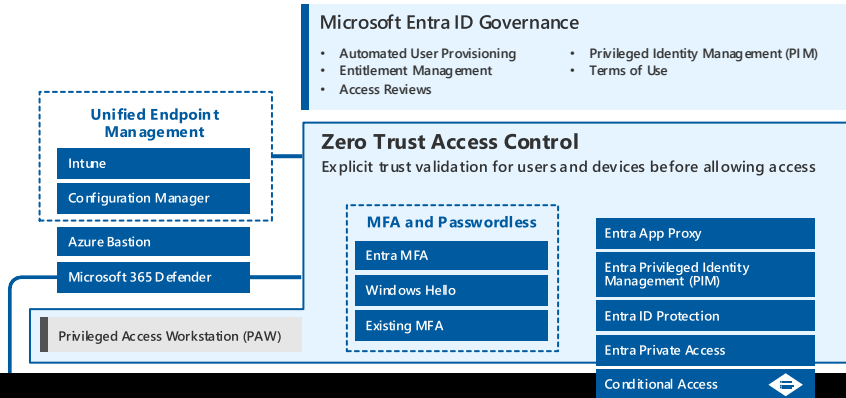
Apply Zero Trust principles Infrastructure & Platform as a Service (IaaS & PaaS) across multi-cloud cross-platform environments

Governance & Policy Enforcement

Control

Preventive Controls

Full Time Employees, Partners, and/or outsourced providers

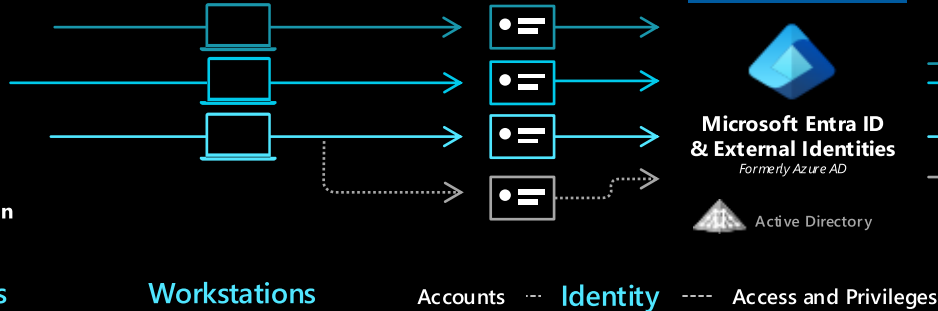


Business Users

Developers

Administrators

App/Service and Automation



Azure Cloud Adoption Framework (CAF)

Guidance on security strategy, planning, roles and responsibilities <https://aka.ms/CAF>

Top 10 Azure Security Best Practices

Management Plane Security

Platform provided security guard rails, governance, policy, and more

Azure Blueprints	Azure Policy	Management Groups	Role Based Access Control (RBAC)	...
Microsoft Defender for Cloud	Azure Lighthouse	Resource Locks	Azure Backup & Site Recovery	

Data Plane Security

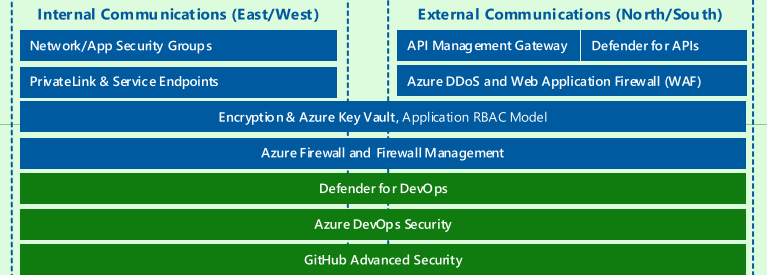
Per-Application/Workload Controls

Azure Well Architected Framework (WAF)

Microsoft Cloud Security Benchmark (MCSB)

Prescriptive Best Practices and Controls

Microsoft Defender for Cloud Apps



'Internal' Access

Workstations

Accounts

Identity

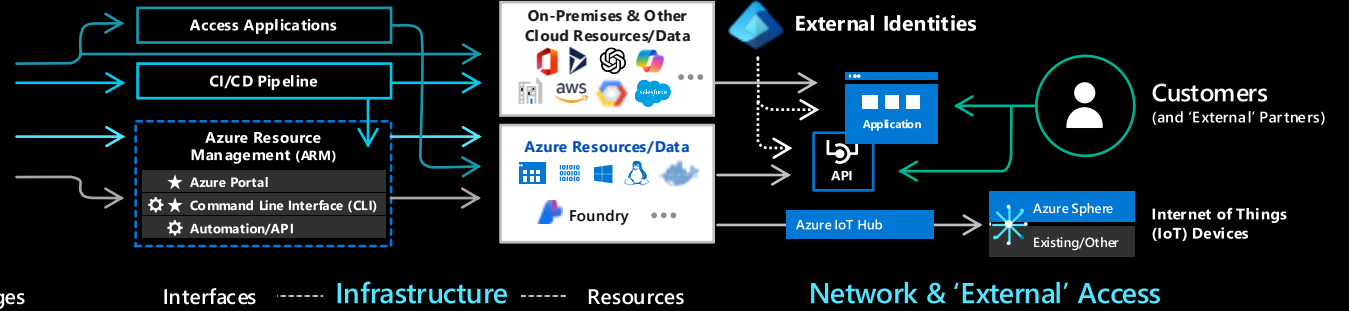
Access and Privileges

Interfaces

Infrastructure

Resources

Network & 'External' Access

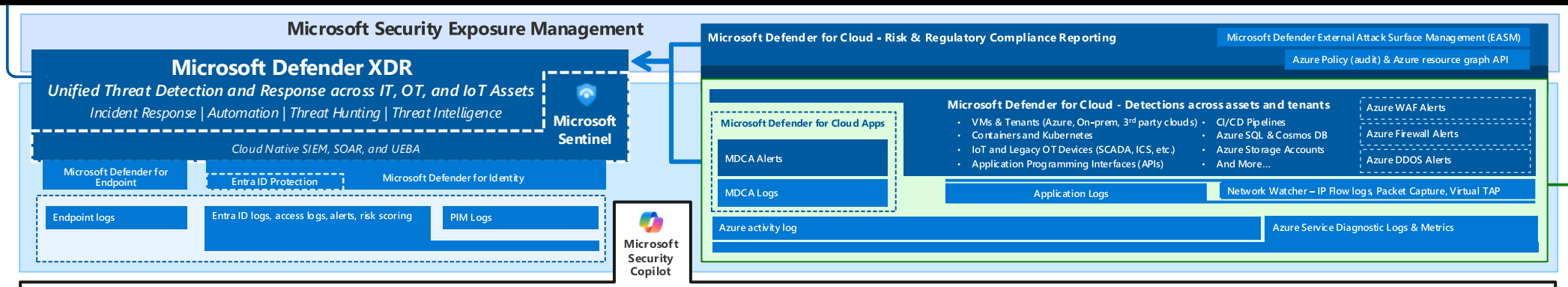


Security Posture

Threat Detection & Response

Visibility

Raw Logs and Signal for Investigation & Hunting



Cross-cloud and cross-platform

Comprehensive Security, Compliance and Identity capabilities that integrate with your existing solutions



June 2026
<https://aka.ms/MCRA>

Industry Partnerships

NIST / CIS / The Open Group / Others Microsoft Intelligent Security Association Solution Integration and MDR/MSSP Partners CERTs / ISACs / Others Law Enforcement ...



Microsoft Security, Compliance, and Identity Capabilities

Threat Intelligence – 100+ Trillion signals per day of security context

Access Control

Identity and Network

Modern Security Operations

Rapid Resolution with XDR, SIEM, SOAR, UEBA and more

Asset Protection

Information Protection and App Security / DevSecOps

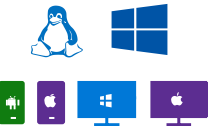
Technical Governance

Risk Visibility, Scoring, and Policy Enforcement

People Security – User Education/Empowerment and Insider Threats



Endpoints & Devices



Software as a Service (SaaS)



Hybrid Infrastructure – IaaS, PaaS, On-Premises



IoT Devices



Operational Technology (OT)

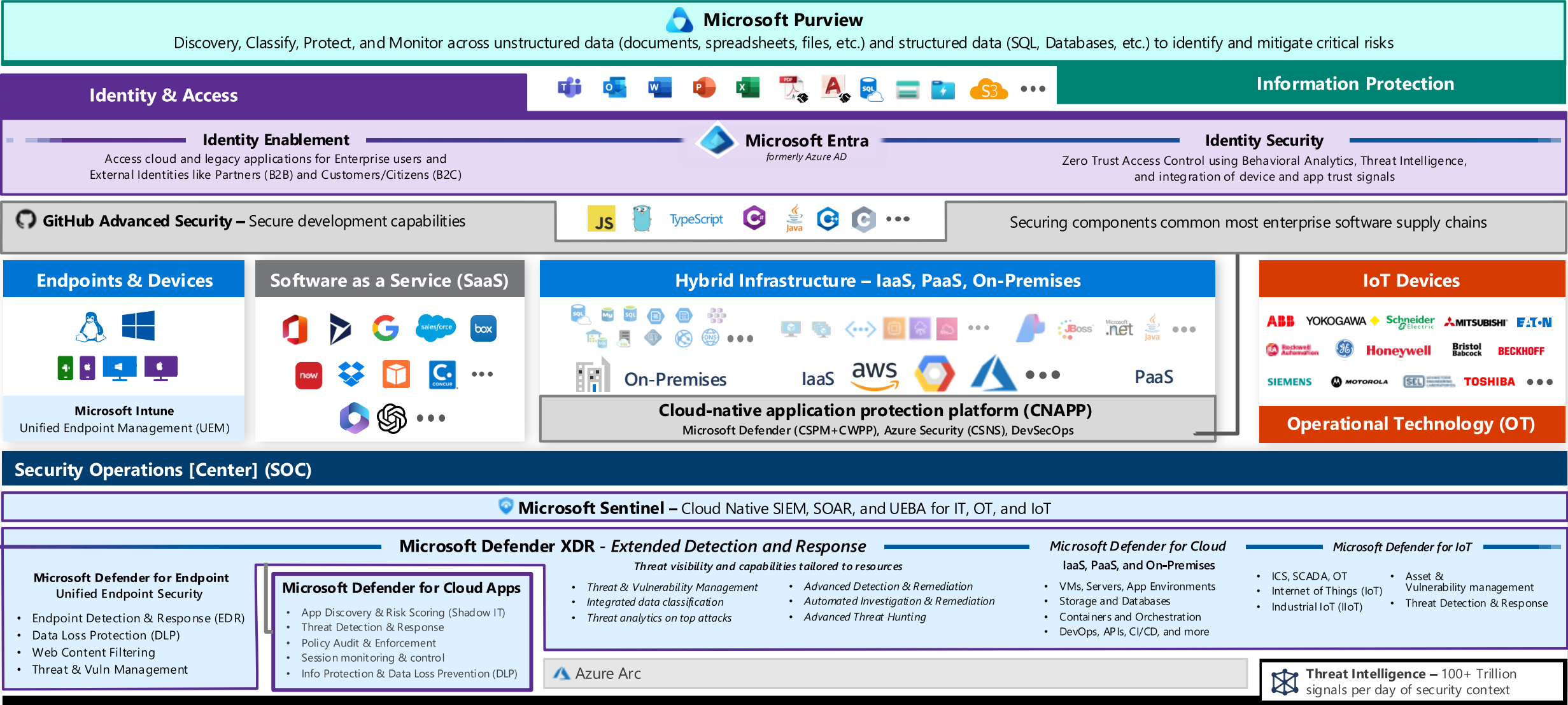
Security Operations [Center] (SOC) – Reduce attacker time/opportunity to impact business

Multi-Cloud and Cross-Platform Technology

Secure the enterprise you have



June 2026
<https://aka.ms/MCRA>

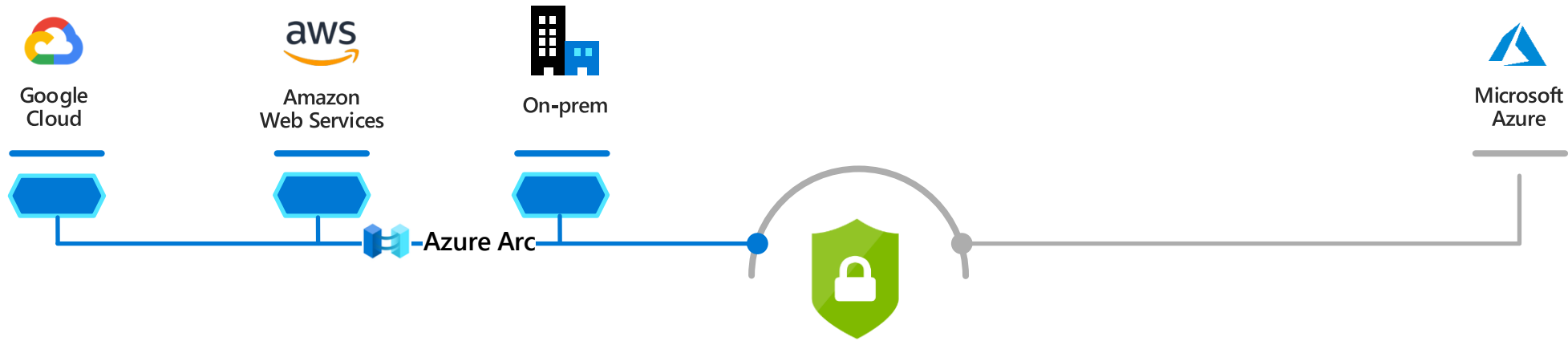


Key cross-platform and multi-cloud guidance

- [Microsoft Defender for Cloud multicloud solution](#)
- [Microsoft Defender for Endpoint – Linux Support](#)
- [Azure security solutions for AWS](#)
- [Entra ID identity and access management for AWS](#)

The image is a collage of several Microsoft documentation pages. The top right shows the 'Defender for Cloud for your multicloud environment' page, which describes how Microsoft Defender for Cloud connects to multicloud environments with agentless, API-based methods for CSPM insight. Below this, there are three columns of content: 'About multicloud deployments', 'Defend Amazon AWS resources', and 'Defend Google GCP resources'. The middle section shows the 'Microsoft Defender for Endpoint for Linux' page, dated 01/21/2021, which describes how to install, configure, update, and use Microsoft Defender for Endpoint for Linux. The bottom left shows the 'Azure security solutions for AWS' page, which discusses Azure AD identity and access management for AWS. The bottom right shows the 'How to install Microsoft Defender for Endpoint for Linux' page, which provides instructions on how to install and configure Microsoft Defender for Endpoint for Linux.

Multi-cloud & hybrid protection in Microsoft Defender for Cloud



Security posture
& compliance

Secure score

Asset management

Policy



Server protection
(Microsoft Defender for Cloud for VMs)

Threat detection

Vulnerability Assessment

Application control



Automation &
management at scale

Automation

SIEM integration

Export

DevSecOps – Agile security for workloads

Idea Incubation → First Production Release → Production DevSecOps

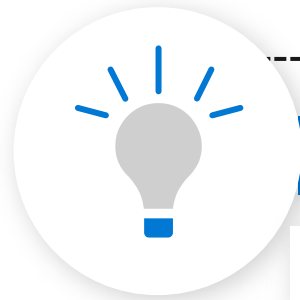
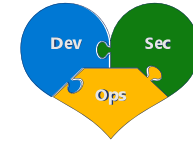
New Product or Service

Minimum viable product (MVP) for:

- **Dev** - Business / Technical Requirements
- **Sec** - Compliance / Security / Safety
- **Ops** - Quality / Performance / Support



Continuous improvement



Architecture & Governance

Security, Compliance, Identity, & Other Standards

DESIGN/CODE



Secure Design

BUILD



Secure Code

DEPLOY

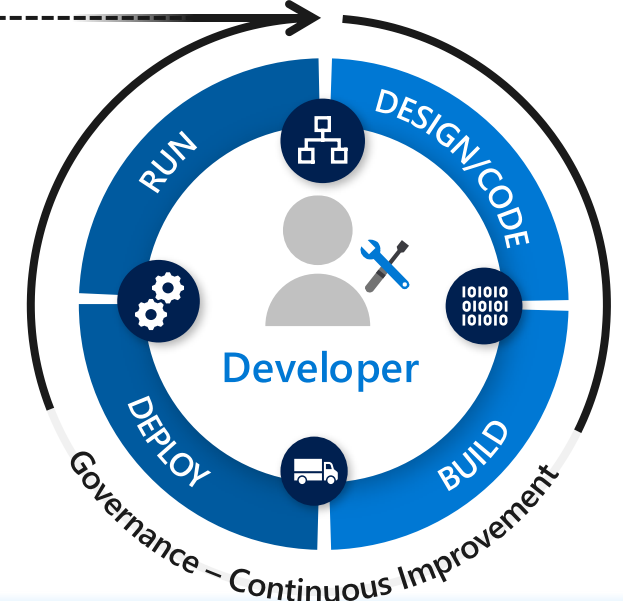


Secure CI/CD Pipeline

RUN



Secure the Operations



Continuous Improvement of DevSecOps Lifecycle

1. **MVP definitions** – Update minimum requirements for Dev, Sec, and Ops (agility, stability, security, identity standards, and more)
2. **Continuously improve** process, program, education, tooling, etc. to improve developer productivity, efficiency, security, identity, and more)

Security Resources



Security Adoption Framework

aka.ms/saf

Security Hub
aka.ms/SecurityDocs

Security Strategy and Program

- CISO Workshop – aka.ms/CISOworkshop | [-videos](#)

- Driving Business Outcomes Using Zero Trust
 - [Rapidly modernize your security posture for Zero Trust](#)
 - [Secure remote and hybrid work with Zero Trust](#)
 - [Identify and protect sensitive business data with Zero Trust](#)
 - [Meet regulatory and compliance requirements with Zero Trust](#)

End to End Security Architecture

- Microsoft Cybersecurity Reference Architectures (MCRA) - aka.ms/MCRA | [-videos](#)
- Ransomware and Extortion Mitigation - aka.ms/humanoperated
- Backup and restore plan to protect against ransomware - aka.ms/backup

- Zero Trust Workshop - <http://aka.ms/ztworkshop>
- Zero Trust Deployment Guidance - aka.ms/ztguide | aka.ms/ztramp

Access and Identities

- Securing Privileged Access (SPA) Guidance
aka.ms/SPA
- [Access Control Discipline](#)
- Ninja Training
 - Microsoft Defender for Identity
aka.ms/mdininja
- MCRA Video
 - [Zero Trust User Access](#)
- Microsoft Entra Documentation
aka.ms/entradocs

Security Operations (SecOps/SOC)

- Incident Response - aka.ms/IR
- CDOC Case Study - aka.ms/ITSOC
- Ninja Training
 - Microsoft 365 Defender
aka.ms/m365dninja
 - Microsoft Sentinel
aka.ms/sentinelinja
 - Microsoft Defender for Office 365
aka.ms/mdoninja
 - Microsoft Defender for Endpoint
aka.ms/mdeninja
 - Microsoft Cloud App Security
aka.ms/mcasninja
- MCRA Videos
 - [Security Operations](#)
 - [SecOps Integration](#)

Infrastructure & Development Security

- [Security Development Lifecycle \(SDL\)](#)
 - [Security Controls](#)
- Microsoft Cloud Security Benchmark
aka.ms/benchmarkdocs
- Well Architected Framework (WAF)
 - aka.ms/wafsecure
- Azure Security Top 10
 - aka.ms/azuresecuritytop10
- Ninja Training
 - [Defender for Cloud](#)
- MCRA Video
 - [Infrastructure Security](#)
- [Defender for Cloud Documentation](#)

Data Security

- [Secure data with Zero Trust](#)
- Ninja Training
 - Microsoft Purview Information Protection
aka.ms/MIPNinja
 - Microsoft Purview Data Loss Prevention
aka.ms/DLPNinja
 - Microsoft Purview Insider Risk Management
 - [Insider Risk Management](#)
 - Data Security for SOC
aka.ms/NinjaDSforSOC
- Microsoft Purview Documentation
aka.ms/purviewdocs

IoT and OT Security

- Ninja Training
 - [Defender for IoT Training](#)
- MCRA Videos
 - [MCRA Video OT & IIoT Security](#)
- Defender for IoT Documentation
aka.ms/D4IoTDocs

Key Industry References and Resources



The Open Group

- Zero Trust Commandments Standard - <https://publications.opengroup.org/c247>
- Zero Trust Reference Model - <https://publications.opengroup.org/s232>
- Security Principles for Architecture - <https://publications.opengroup.org/c246>



US National Institute of Standards and Technology (NIST)

- Cybersecurity Framework - <https://www.nist.gov/cyberframework>
- Zero Trust Architecture - <https://www.nist.gov/publications/zero-trust-architecture>
 - NCCoE Zero Trust Project - <https://www.nccoe.nist.gov/projects/implementing-zero-trust-architecture>
- Secure Software Development Framework (SSDF) - <https://csrc.nist.gov/pubs/sp/800/218/final>

CYBERSECURITY &
INFRASTRUCTURE
SECURITY AGENCY



Cybersecurity and Infrastructure Security Agency (CISA)

- Zero Trust Maturity Model - <https://www.cisa.gov/zero-trust-maturity-model>



Center for Internet Security (CIS)

- CIS Benchmarks - <https://www.cisecurity.org/cis-benchmarks/>